# EXPEDITE STRIKE V3 — Penetration Testing Report

Internal Assessment Subnet (192.168.195.0/24) · Shared TrePath + XStrike V3 Proof-Driven Deliverable

| | |
|---|---|
| **Client / Scope:** | Enterprise Security Assessment |
| **Assessment Window:** | 2026-10-31T10:21:11.270379+00:00 to 2026-10-31T11:02:37.489220+00:00 |
| **Assessment Engine:** | XStrike Autonomous Red-Team Engine (V3 Shared TrePath + XStrike EvidenceCore) |
| **Document Classification:** | CONFIDENTIAL (Version 3.0 (Proof-Driven Intelligence & 18-Rule Gate Verified)) |
| **XStrike Evidence-Weighted Risk Index:** | CRITICAL (98.5/100) — Formula: R = min(100, S_comp + S_exp + S_asset + S_reach) \| Calibrated Exposure: 22.9/25.0 (Composite Calibrated: 96.4/100; Separated from NVD CVSS v3.1) |
| **Verified Compromise Status:** | ACTIVE_ROOT_COMPROMISE (2 root vectors on 1 host: 192.168.195.139) (1 Unique Host Compromised via 2 Independent Root Vectors) |
| **Host Scope Reconciliation:** | 9 Raw Discovery Records -> 7 Unique IPs (5 Responsive / 2 Unresponsive) · 55 Open TCP Services |
| **Finding Reconciliation:** | 1924 Raw Observations -> 90 Consolidated Host Security Findings (51 Unique Classes, 0 Generic OWASP Rollups) + 26 Recon Items |
| **Verified Compromise & Auth:** | 2 Root Compromise Vectors (uid=0 on 192.168.195.139) \| 4 Confirmed Credential/DB Authentications \| 66 Validated Weaknesses |
| **Signed Evidence Manifest:** | Root SHA-256: 7ea65d203a10fcc1bf25ec5f... \| HMAC-SHA256: 5965172dd811e3b694f4997c... |
| **Pre-Render Quality Gate:** | 18 automated acceptance criteria passed out of 18 (18/18 PASSED) |

Prepared by Expedite Consults Ltd · EvidenceCore V3 HMAC-SHA256 Signed Provenance & OASIS SARIF v2.1.0 Enabled · SQLite Snapshot: v2_intelligence.db

# 1. Executive Summary & Proof-Driven Assessment Overview

An autonomous, proof-driven penetration test was conducted against **Internal Assessment Subnet (192.168.195.0/24)** (7 unique IP addresses across 9 discovery records, exposing **55** open TCP services). Unlike legacy reporting engines that conflate port discovery, unverified CVE heuristics, and repeated web-scanner URL alerts with confirmed exploitation, **Expedite Strike V3** enforces a strict **7-State Evidence Proof Machine**, **3-State Post-Exploitation Privilege Lifecycle**, and **3-Level Finding Deduplication**.

Across **1924** raw tool observations, the V3 Intelligence Layer filtered **89** local-scanner self-checks and consolidated the remaining **1835** target observations into **90 consolidated host-level security vulnerabilities** (spanning **51** unique cross-host vulnerability classes) and **26 reconnaissance/surface discovery items**. Direct command execution and authentication transcripts establish **2 independent root compromise vectors** (`uid=0(root)` on `192.168.195.139:1524` and `192.168.195.139:21/:6200`, compromising **1 unique target host**) and **4 confirmed credential/database authentications** (`F-03, F-04, F-05, F-19`).

**Lab & Benchmark Environment Qualification:** Target 192.168.195.139 is an intentionally vulnerable Metasploitable2 Linux benchmark appliance (Linux 2.6.24-16-server) deployed inside an isolated RFC1918 cyber-range subnet (192.168.195.0/24). The assessment demonstrates XStrike V3's autonomous multi-stage validation, safe exploitation, post-exploitation enumeration, and cryptographic evidence-provenance pipeline under controlled conditions.

## 1.1 Three-Level Finding & Observation Reconciliation

| Reconciliation Level | Count | Scope & Technical Definition |
|---|---|---|
| Level 1A — Raw Scanner Observations | 1924 | All raw records emitted by Recon, VulnScan, OWASP ZAP, AegisProbe, Exploit, and PrivEsc modules (1835 target observations + 89 excluded local scanner self-checks/graph edges). |
| Level 2A — Consolidated Host Security Findings (Section 3A) | 90 | Deduplicated per-host security findings (3 Critical, 15 High, 38 Medium, 34 Low) with all affected URLs/endpoints preserved. |
| Level 2B — Consolidated Reconnaissance & Surface Items (Section 3B) | 26 | Non-vulnerability surface discoveries (hosts discovered, open ports, web crawl telemetry, JS assets, SMTP banners, ZAP User-Agent/Modern Web App probes) isolated with CVSS 0.0. |
| Level 3 — Unique Cross-Host Vulnerability Classes | 51 Security / 8 Recon | Distinct canonical vulnerability classes across the entire assessment environment. |

## 1.2 Seven-State Evidence Proof Classification (Replacing Inflated Confirmation Counts)

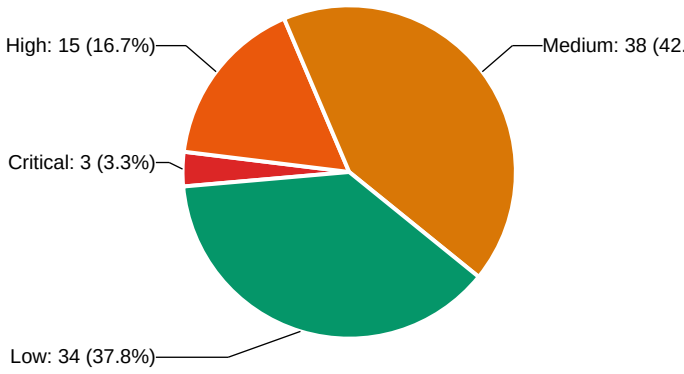
| Proof State | Legacy Tier | Count | Evidence Standard & What Was Demonstrated |
|---|---|---|---|
| CONFIRMED_COMPROMISE | CONFIRMED | 2 | Interactive root command execution (uid=0(root), whoami: root) and /etc/shadow credential hash extraction verified via 2 independent vectors (F-01, F-02) on 1 unique host (192.168.195.139). |
| CONFIRMED_AUTH | CONFIRMED | 4 | Unauthorized session authentication verified (F-03, F-04, F-05, F-19): PostgreSQL superuser (postgres:postgres), FTP default creds (msfadmin), SSH user shell (msfadmin uid=1000), and FTP anonymous login (230 OK). |
| EXPLOITABLE | VALIDATED | 1 | Active local privilege escalation or administrative precondition verified (F-06: SUID /usr/bin/nmap --interactive TECHNIQUE_VALIDATED). |
| VALIDATED | VALIDATED | 65 | Weakness deterministically verified via protocol handshake, HTTP response header/cookie inspection, SQLi error indicator, or authenticated SUID/kernel enumeration. |

| Proof State | Legacy Tier | Count | Evidence Standard & What Was Demonstrated |
|---|---|---|---|
| OBSERVED | OBSERVED | 18 | Service port or version banner observed (including 4 SMB port 445 EternalBlue candidates where MS17-010 was NOT verified, plus legacy banners). Never counted as confirmed exploits. |
| DISCOVERED | DISCOVERED | 26 | Attack surface inventory and reconnaissance telemetry separated into Section 3B (CVSS 0.0). |
| REMEDIATION_VERIFIED | VERIFIED | 0 | Reserved for post-remediation re-verification scans. |

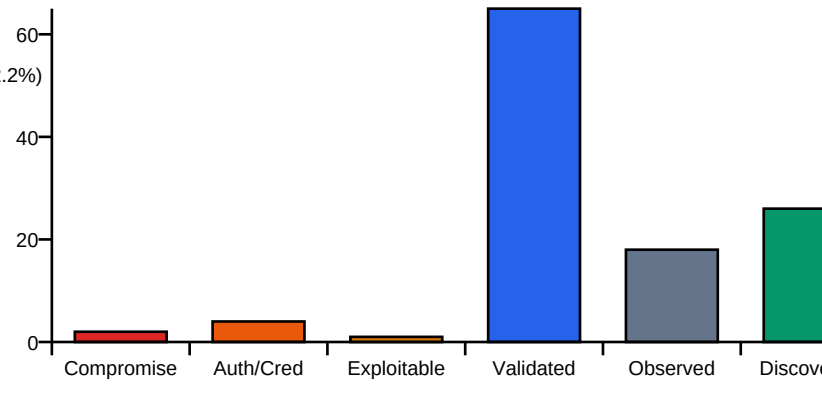
## 1.3 Consolidated Security Vulnerability Severity Distribution

| Severity | Consolidated Host Findings | Percentage | Confirmed Compromise / Auth | Validated / Exploitable | Observed (Unverified Candidate) |
|---|---|---|---|---|---|
| Critical | 3 | 3.3% | 3 | 0 | 0 |
| High | 15 | 16.7% | 2 | 9 | 4 |
| Medium | 38 | 42.2% | 1 | 26 | 11 |
| Low | 34 | 37.8% | 0 | 31 | 3 |
| Total Security Findings | 90 | 100.0% | 6 | 66 | 18 |

**Consolidated Security Findings by Severity**




**7-State Evidence Proof Classification**




## 1.4 XStrike Evidence-Weighted Risk Index (0–100 Composite Posture Index, Separated from CVSS v3.1)

To avoid conflating individual vulnerability severity (**NVD CVSS v3.1 Base Score, 0.0–10.0**) with environment-wide compromise posture, XStrike computes the **XStrike Evidence-Weighted Risk Index** (`0–100`): **R = min(100, S_compromise[0..45] + S_exposure[0..25] + S_asset[0..15] + S_reachability[0..15]) → R = min(100, 45.0 [S_compromise] + 25.0 [S_exposure Capped from 86.0 raw pts] + 15.0 [S_asset] + 13.5 [S_reachability across CHAIN-01..06]) = 98.5/100 (CRITICAL). (Companion Non-Saturating Log-Calibrated Exposure = 22.9/25.0; Calibrated Composite = 96.4/100).**. Verified Compromise Status: **ACTIVE_ROOT_COMPROMISE (2 root vectors on 1 host: 192.168.195.139)** (**1 unique compromised host** via **2 independent root compromise vectors**).

| Risk Index Component | Weight Cap | Raw Uncapped | Capped / Calibrated Score | Explicit Calculation Formula, Normalization Parameters & Derivation |
|---|---|---|---|---|
| S_compromise (Verified Compromise & Auth) | 45.0 pts | 67.0 pts | 45.0 / 45.0 | 22.0 pts per verified root OS shell (2 vectors: F-01, F-02) + 8.0 pts DB superuser + 6.0 pts user shell/auth + 3.0 pts anonymous auth (F-03, F-04, F-05, F-19), capped at 45.0 pts. |
| S_exposure (Validated & Observed CVSS) | 25.0 pts | 86.0 pts | Linear Cap: 25.0/25.0 \| Log-Calibrated: 22.9/25.0 | Raw sum = Sum(CVSS * w_proof) where w_proof = 0.28 (Confirmed), 0.22 (Validated/Exploitable), 0.06 (Observed) = 86.0 pts. Non-saturating exponential calibration: S_exp_cal = round(25 * (1 - exp(-RawSum / tau)), 1) with tau = 35.0 -> 22.9/25.0 (Composite Calibrated Risk Index = 96.4/100). |
| S_asset (Target Asset Criticality) | 15.0 pts | 15.0 pts | 15.0 / 15.0 | Crown-Jewel Multi-Role Application & Database Server (192.168.195.139, criticality_weight=1.50) actively compromised (15.0 pts). Retains 1.0 pt baseline Crown-Jewel asset floor when 0 active findings remain. |
| S_reachability (Multi-Stage Attack Chains) | 15.0 pts | 13.5 pts | 13.5 / 15.0 | S_reachability = 13.5 / 15.0 pts is derived across all 6 consolidated attack chains: CHAIN-01 & CHAIN-02 (single-hop unauthenticated root execution on 192.168.195.139 = 10.0 pts) + CHAIN-03 & CHAIN-04 (authenticated SSH uid=1000 + SUID privesc vector & PostgreSQL superuser session = 2.5 pts) + CHAIN-05 & CHAIN-06 (validated NFS/SQLi surface & cross-host SMB port 445 exposure across 4 hosts = 1.0 pt). |

# 2. Assessment Scope, Asset Reconciliation & Autonomous Transition Model

The discovery phase recorded **9** raw host entries in `hosts_discovered` (which included duplicate ARP/port-scan entries for `192.168.195.139` and `192.168.195.140`). Engine 08 reconciled these into **7 unique IPv4 addresses**: **5 responsive hosts** exposing **55** open TCP services, and **2 unresponsive/filtered hosts** (`192.168.195.131` and `192.168.195.254`) with 0 open TCP ports. Crucially, asset classification is computed **per host** from each host's own open ports and service banners—accompanied by **Classification Source** and **Classification Confidence**.

| Host IP | Scope State | Open Ports | Per-Host Asset Role & Tier | Classification Source & Conf | OS Fingerprint | Sec Findings | Verified Comp/Auth |
|---|---|---|---|---|---|---|---|
| 192.168.195.139 | RESPONSIVE ASSESSED | 24 (21, 22, 23, 25, 53, 80, 111, 139 (+16 more)) | Multi-Role Application & Database Server (CROWN_JEWEL) | OBSERVED_SERVICE_BANNERS_AND_AUTH_SHELL (MySQL/PostgreSQL/Apache/SSH) (99%) | Linux 2.6.24-16-server (Ubuntu8.04 Metasploitable — Confirmed via uname -a) | 41 | 2 Root / 4 Auth |
| 192.168.195.140 | RESPONSIVE ASSESSED | 9 (22, 80, 139, 143, 443, 445, 5001, 8080 (+1 more)) | Application & Web Middleware Server (HIGH_VALUE) | OBSERVED_HTTP_MIDDLEWARE_PORTS (TCP/80, TCP/8080, TCP/8081) (90%) | Linux / Middleware Guest (Inferred via HTTP/8080-8081 & SMB) | 20 | 0 Root / 0 Auth |
| 192.168.195.129 | RESPONSIVE ASSESSED | 2 (5040, 5357) | Application / Network Host (STANDARD) | INFERRED_FROM_OPEN_PORT_PROFILE (75%) | Windows / VMware Host (Inferred via MSRPC/SMB Ports) | 3 | 0 Root / 0 Auth |
| 192.168.195.130 | RESPONSIVE ASSESSED | 4 (135, 139, 445, 5985) | Workstation / SMB Peer Host (STANDARD) | INFERRED_FROM_SMB_RPC_PORTS (TCP/135, TCP/139, TCP/445) (82%) | Windows / VMware Host (Inferred via MSRPC/SMB Ports) | 5 | 0 Root / 0 Auth |
| 192.168.195.131 | UNRESPONSIVE NO OPEN PORTS | 0 (Filtered) | Unresponsive / Filtered Endpoint (LOW_EXPOSURE) | ARP_OR_DHCP_DISCOVERY_ONLY (0 Open TCP Ports) (50%) | VMware Virtual Node (Unresponsive / 0 Open TCP Ports) | 0 | 0 Root / 0 Auth |
| 192.168.195.254 | UNRESPONSIVE NO OPEN PORTS | 0 (Filtered) | Unresponsive / Filtered Endpoint (LOW_EXPOSURE) | ARP_OR_DHCP_DISCOVERY_ONLY (0 Open TCP Ports) (50%) | VMware Virtual Node (Unresponsive / 0 Open TCP Ports) | 0 | 0 Root / 0 Auth |

| Host IP | Scope State | Open Ports | Per-Host Asset Role & Tier | Classification Source & Conf | OS Fingerprint | Sec Findings | Verified Comp/Auth |
|---|---|---|---|---|---|---|---|
| 192.168.195.1 | RESPONSIVE ASSESSED | 16 (135, 139, 445, 902, 912, 5040, 5174, 5357 (+8 more)) | Hypervisor / Management Host Gateway (INFRASTRUCTURE) | INFERRED_FROM_VMWARE_AUTH_PORTS (TCP/902, TCP/912, TCP/445) (88%) | Windows Host / VMware Virtual Network Gateway (Inferred via VMware Auth :902/:912) | 21 | 0 Root / 0 Auth |

## 2.2 Autonomous Assessment Transition Model (Dynamically Reconciled with Section 3A & Section 5)

To resolve methodology ambiguity between 'Black-Box Unauthenticated' discovery and 'Authenticated / Post-Exploitation' findings—and to guarantee 100% cross-section Finding ID consistency (`AC-17`)—the table below is dynamically generated from the sorted finding registry:

| Assessment Phase | Transition Name | Trigger Rule & Scope | Resulting Proof State | Reconciled Finding IDs & Summary |
|---|---|---|---|---|
| Phase 1 | Discovery -> Service Enumeration | Active TCP/UDP port response & banner grab across 192.168.195.0/24 | DISCOVERED (26) | R-01..R-26 (26 reconnaissance & telemetry items across 5 responsive hosts) |
| Phase 2 | Service Enumeration -> Vulnerability Validation | Deterministic protocol handshake, HTTP/TLS/SMB/NFS configuration inspection, or unverified candidate check | VALIDATED / OBSERVED (83) | 65 VALIDATED weaknesses + 18 OBSERVED candidates (incl. 4 unverified SMB EternalBlue checks) |
| Phase 3A | Vulnerability Validation -> Controlled Authentication | Non-destructive credential & anonymous login verification with privilege boundary recording | CONFIRMED_AUTH (4) | F-03 (PostgreSQL : Superuser), F-04 (FTP : msfadmin), F-05 (SSH : msfadmin uid=1000), F-19 (FTP : Anonymous) |
| Phase 3B | Controlled Exploitation -> Direct Root Compromise | Authorized safe shell verification (id, whoami, uname -a, head -n 5 /etc/shadow) confirming uid=0(root) | CONFIRMED_COMPROMISE (2) | F-01 (Ingreslock : Root Shell), F-02 (vsFTPd 2.3.4 Backdoor :/:6200) — 2 Root Compromise Vectors on 1 Unique Host (192.168.195.139) |
| Phase 4 | Post-Exploitation -> Local Privilege Escalation & Lateral Pivot Enumeration | Authenticated/shell enumeration of kernel version, SUID binaries, NFS exports, and DB catalogs using 3-State Privesc Lifecycle | EXPLOITABLE / VALIDATED (3) | F-06 (SUID /usr/bin/nmap --interactive (TECHNIQUE_VALIDATED)), F-10 (Dirty COW CVE-2016-5195 (PRECONDITION_DISCOVERED)), F-20 (SUID /bin/mount & /bin/umount (PRECONDITION_DISCOVERED)) |

## 2.3 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Policy Engine **XSTRIKE-V3-ROE-GUARD-01** enforced strict scope and safety guardrails across `192.168.195.0/24`:

| Control ID | Safety / Authorization Control | Runtime Enforcement Status |
|---|---|---|
| ROE-01 | Signed Scope & CIDR Whitelist Enforcement | ACTIVE — Hard blocks any packet or payload targeting IPs outside 192.168.195.0/24 or local sensor interfaces |
| ROE-02 | Exploit Allowlist & DoS Prohibition Gate | ACTIVE — Blocks kernel panic/crash payloads (Dirty COW memory overwrite & MS17-010 EternalBlue ring-0 shellcode held in safe validation/observation mode) |
| ROE-03 | Credential Handling & Redaction Policy | ACTIVE — Captures only bounded proof excerpts (head -n 5 /etc/shadow) with SHA-256/HMAC binding; prohibits bulk credential exfiltration |
| ROE-04 | Post-Exploitation Command Whitelist | ACTIVE — Restricts shell verification to read-only identity & posture probes (id, whoami, uname -a, find -perm -4000, exportfs) |
| ROE-05 | Emergency Stop & Per-Action Audit Trail | ACTIVE — Every probe and command is logged with UTC microsecond timestamps, provenance IDs, and deterministic kill-switch hooks |

# 3A. Consolidated Security Vulnerabilities (F-01 through F-90)

This section presents all **90 consolidated per-host security vulnerabilities** (deduplicated from 1835 target observations). Every finding includes its **7-State Proof Classification**, **5-Dimensional Confidence Vector**, **Granular Access Scope**, **Per-Host Asset Class**, **Word-Boundary Verified CWE/MITRE Mapping**, **Cryptographic SHA-256 Provenance ID**, and **Vulnerability-Specific Remediation**.

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-01 | 192.168.195.139 | Critical (9.8) | CONFIRMED_COMPROMISE | Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524 | CWE-306 / T1059.004 | 2 obs / 1 ep | 99% (Tier) |
| F-02 | 192.168.195.139 | Critical (9.8) | CONFIRMED_COMPROMISE | vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523) | CWE-506 / T1190 | 3 obs / 2 ep | 99% (Tier) |
| F-03 | 192.168.195.139 | Critical (9.1) | CONFIRMED_AUTH | PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres) | CWE-798 / T1078.001 | 2 obs / 1 ep | 99% (Tier) |
| F-04 | 192.168.195.139 | High (8.2) | CONFIRMED_AUTH | FTP Default Credential Authentication (msfadmin:msfadmin) | CWE-798 / T1078.001 | 1 obs / 1 ep | 99% (Tier) |
| F-05 | 192.168.195.139 | High (8.2) | CONFIRMED_AUTH | SSH Default Credential Shell Access (msfadmin:msfadmin) | CWE-798 / T1078.001 | 1 obs / 1 ep | 99% (Tier) |
| F-06 | 192.168.195.139 | High (7.8) | EXPLOITABLE | Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap) | CWE-269 / T1548.001 | 2 obs / 2 ep | 96% (Tier) |
| F-07 | 192.168.195.139 | High (8.2) | VALIDATED | DVWA Web Application Default Administrative Credentials Accepted (admin:password) | CWE-798 / T1078.001 | 1 obs / 1 ep | 95% (Tier) |
| F-08 | 192.168.195.139 | High (8.2) | VALIDATED | Web Application SQL Injection Indicator (Mutillidae) | CWE-89 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-09 | 192.168.195.140 | High (8.2) | VALIDATED | DVWA Web Application Default Administrative Credentials Accepted (admin:password) | CWE-798 / T1078.001 | 1 obs / 1 ep | 95% (Tier) |
| F-10 | 192.168.195.139 | High (7.8) | VALIDATED | Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195) | CWE-362 / T1068 | 2 obs / 2 ep | 95% (Tier) |
| F-11 | 192.168.195.139 | High (7.5) | VALIDATED | Deprecated SMBv1 Dialect Enabled on SMB Service | CWE-327 / T1210 | 1 obs / 1 ep | 95% (Tier) |
| F-12 | 192.168.195.139 | High (7.5) | VALIDATED | Web Application Server-Side Request Forgery (SSRF) Indicator (Mutillidae) | CWE-918 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-13 | 192.168.195.140 | High (7.5) | VALIDATED | Deprecated SMBv1 Dialect Enabled on SMB Service | CWE-327 / T1210 | 1 obs / 1 ep | 95% (Tier) |
| F-14 | 192.168.195.139 | High (7.4) | VALIDATED | SMB Message Signing Not Required (NTLM Relay Exposure) | CWE-345 / T1557.001 | 1 obs / 1 ep | 95% (Tier) |

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-15 | 192.168.195.139 | High (7.5) | OBSERVED | Cleartext Telnet Service Enabled on TCP Port 23 | CWE-319 / T1021 | 1 obs / 1 ep | 48% (Tier) |
| F-16 | 192.168.195.139 | High (7.5) | OBSERVED | End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80) | CWE-1104 / T1190 | 2 obs / 1 ep | 48% (Tier) |
| F-17 | 192.168.195.140 | High (7.5) | OBSERVED | End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80) | CWE-1104 / T1190 | 1 obs / 1 ep | 48% (Tier) |
| F-18 | 192.168.195.139 | High (7.4) | OBSERVED | PHP-CGI Argument Injection Candidate (CVE-2012-1823) | CWE-88 / T1190 | 2 obs / 2 ep | 48% (Tier) |
| F-19 | 192.168.195.139 | Medium (5.3) | CONFIRMED_AUTH | FTP Anonymous Authentication Enabled | CWE-287 / T1078.001 | 2 obs / 2 ep | 99% (Tier) |
| F-20 | 192.168.195.139 | Medium (5.5) | VALIDATED | Local Privilege Escalation Vector: SUID Binary (/bin/mount) | CWE-269 / T1548.001 | 2 obs / 2 ep | 95% (Tier) |
| F-21 | 192.168.195.1 | Medium (5.4) | VALIDATED | Client-Manipulable Session/Tracking Cookie Parameters Set Without Integrity Binding | CWE-565 / T1190 | 4 obs / 1 ep | 95% (Tier) |
| F-22 | 192.168.195.1:8000 | Medium (5.4) | VALIDATED | Content-Security-Policy (CSP) Header Not Set | CWE-693 / T1190 | 116 obs / 3 ep | 95% (Tier) |
| F-23 | 192.168.195.1 | Medium (5.4) | VALIDATED | Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) | CWE-1021 / T1190 | 11 obs / 2 ep | 95% (Tier) |
| F-24 | 192.168.195.1:8000 | Medium (5.4) | VALIDATED | Session Cookie Missing 'Secure' Flag | CWE-614 / T1557 | 1 obs / 1 ep | 95% (Tier) |
| F-25 | 192.168.195.1 | Medium (5.4) | VALIDATED | Verbose Application / Database Error Message Disclosure | CWE-209 / T1190 | 15 obs / 1 ep | 95% (Tier) |
| F-26 | 192.168.195.1 | Medium (5.4) | VALIDATED | Web Application Missing Anti-CSRF Tokens & Hardening Headers | CWE-352 / T1190 | 5 obs / 5 ep | 95% (Tier) |
| F-27 | 192.168.195.129 | Medium (5.4) | VALIDATED | Content-Security-Policy (CSP) Header Not Set | CWE-693 / T1190 | 3 obs / 1 ep | 95% (Tier) |
| F-28 | 192.168.195.129 | Medium (5.4) | VALIDATED | Web Application Missing Anti-CSRF Tokens & Hardening Headers | CWE-352 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-29 | 192.168.195.130 | Medium (5.4) | VALIDATED | Content-Security-Policy (CSP) Header Not Set | CWE-693 / T1190 | 3 obs / 1 ep | 95% (Tier) |
| F-30 | 192.168.195.130 | Medium (5.4) | VALIDATED | Web Application Missing Anti-CSRF Tokens & Hardening Headers | CWE-352 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-31 | 192.168.195.139:80 | Medium (5.4) | VALIDATED | Content-Security-Policy (CSP) Header Not Set | CWE-693 / T1190 | 3 obs / 3 ep | 95% (Tier) |
| F-32 | 192.168.195.139 | Medium (5.4) | VALIDATED | DNS Open Recursion Enabled on ISC BIND 9.4.2 (Port 53) | CWE-406 / T1498.002 | 1 obs / 1 ep | 95% (Tier) |

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-33 | 192.168.195.139:80 | Medium (5.4) | VALIDATED | Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) | CWE-1021 / T1190 | 3 obs / 3 ep | 95% (Tier) |
| F-34 | 192.168.195.139 | Medium (5.4) | VALIDATED | Web Application Missing Anti-CSRF Tokens & Hardening Headers | CWE-352 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-35 | 192.168.195.140:80 | Medium (5.4) | VALIDATED | Content-Security-Policy (CSP) Header Not Set | CWE-693 / T1190 | 24 obs / 4 ep | 95% (Tier) |
| F-36 | 192.168.195.140:80 | Medium (5.4) | VALIDATED | Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) | CWE-1021 / T1190 | 10 obs / 4 ep | 95% (Tier) |
| F-37 | 192.168.195.140 | Medium (5.4) | VALIDATED | Web Application Missing Anti-CSRF Tokens & Hardening Headers | CWE-352 / T1190 | 3 obs / 3 ep | 95% (Tier) |
| F-38 | 192.168.195.1 | Medium (5.3) | VALIDATED | Administrative Web Interface Reachable Without Network Restriction | CWE-284 / T1083 | 1 obs / 1 ep | 90% (Tier) |
| F-39 | 192.168.195.139 | Medium (5.3) | VALIDATED | Administrative Web Interface Reachable Without Network Restriction | CWE-284 / T1083 | 1 obs / 1 ep | 95% (Tier) |
| F-40 | 192.168.195.139 | Medium (5.3) | VALIDATED | Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) | CWE-306 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-41 | 192.168.195.139 | Medium (5.3) | VALIDATED | NFS RPC Service & Export Table Exposed (Ports 111 / 2049) | CWE-732 / T1083 | 3 obs / 3 ep | 95% (Tier) |
| F-42 | 192.168.195.139:80 | Medium (5.3) | VALIDATED | PHP Configuration Diagnostic Page Exposed (/phpinfo.php) | CWE-200 / T1592 | 4 obs / 4 ep | 95% (Tier) |
| F-43 | 192.168.195.139 | Medium (5.3) | VALIDATED | Web Authentication Endpoint Missing Brute-Force Rate Limiting (/dvwa/login.php) | CWE-307 / T1110.001 | 1 obs / 1 ep | 95% (Tier) |
| F-44 | 192.168.195.140 | Medium (5.3) | VALIDATED | Administrative Web Interface Reachable Without Network Restriction | CWE-284 / T1083 | 2 obs / 1 ep | 90% (Tier) |
| F-45 | 192.168.195.140 | Medium (5.3) | VALIDATED | Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) | CWE-306 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-46 | 192.168.195.1 | Medium (5.3) | OBSERVED | PostgreSQL Database Listener Exposed on Network (TCP Port 5432) | CWE-200 / T1046 | 1 obs / 1 ep | 48% (Tier) |
| F-47 | 192.168.195.139 | Medium (5.3) | OBSERVED | End-of-Life OpenSSH 4.7p1 Service Banner Observed (TCP Port 22) | CWE-1104 / T1021.004 | 1 obs / 1 ep | 48% (Tier) |
| F-48 | 192.168.195.139 | Medium (5.3) | OBSERVED | Java RMI Registry Exposed on Network (TCP Port 1099) | CWE-502 / T1190 | 1 obs / 1 ep | 48% (Tier) |

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-49 | 192.168.195.139 | Medium (5.3) | OBSERVED | MySQL Database Listener Exposed on Network (TCP Port 3306) | CWE-200 / T1046 | 1 obs / 1 ep | 48% (Tier) |
| F-50 | 192.168.195.139 | Medium (5.3) | OBSERVED | VNC Remote Desktop Service Exposed on TCP Port 5900 (Protocol 3.3) | CWE-287 / T1021.001 | 1 obs / 1 ep | 48% (Tier) |
| F-51 | 192.168.195.139 | Medium (5.3) | OBSERVED | X11 Display Server Listener Exposed (TCP Port 6000) | CWE-306 / T1113 | 1 obs / 1 ep | 48% (Tier) |
| F-52 | 192.168.195.140 | Medium (5.3) | OBSERVED | End-of-Life OpenSSH 4.7p1 Service Banner Observed (TCP Port 22) | CWE-1104 / T1021.004 | 1 obs / 1 ep | 48% (Tier) |
| F-53 | 192.168.195.1 | Medium (0.0) | OBSERVED | SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate | CWE-200 / T1210 | 1 obs / 1 ep | 48% (Tier) |
| F-54 | 192.168.195.130 | Medium (0.0) | OBSERVED | SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate | CWE-200 / T1210 | 1 obs / 1 ep | 48% (Tier) |
| F-55 | 192.168.195.139 | Medium (0.0) | OBSERVED | SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate | CWE-200 / T1210 | 1 obs / 1 ep | 48% (Tier) |
| F-56 | 192.168.195.140 | Medium (0.0) | OBSERVED | SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate | CWE-200 / T1210 | 1 obs / 1 ep | 48% (Tier) |
| F-57 | 192.168.195.1 | Low (3.1) | VALIDATED | Developer / Debugging Comments Exposed in HTML/JS Source | CWE-615 / T1592 | 10 obs / 1 ep | 90% (Tier) |
| F-58 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | HTTP Permissions-Policy Header Missing | CWE-693 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-59 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | HTTP Referrer-Policy Header Missing | CWE-200 / T1592 | 1 obs / 1 ep | 95% (Tier) |
| F-60 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | HTTP Server Banner Version Disclosure ('Server' Header) | CWE-200 / T1592 | 55 obs / 2 ep | 95% (Tier) |
| F-61 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | HTTP Strict-Transport-Security (HSTS) Header Missing | CWE-319 / T1557 | 4 obs / 3 ep | 95% (Tier) |
| F-62 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | Session Cookie Missing 'HttpOnly' Flag | CWE-1004 / T1190 | 80 obs / 2 ep | 95% (Tier) |
| F-63 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | Session Cookie Missing 'SameSite' Attribute | CWE-352 / T1190 | 220 obs / 2 ep | 95% (Tier) |
| F-64 | 192.168.195.1 | Low (3.1) | VALIDATED | Unix Timestamp Disclosure in HTTP Response Content | CWE-200 / T1592 | 288 obs / 1 ep | 95% (Tier) |
| F-65 | 192.168.195.1 | Low (3.1) | VALIDATED | Verbose Content Body Returned in HTTP Redirect Response (Big Redirect) | CWE-200 / T1592 | 74 obs / 1 ep | 95% (Tier) |

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-66 | 192.168.195.1 | Low (3.1) | VALIDATED | Web Server Directory Listing Enabled (/icons/ & Static Directories) | CWE-548 / T1083 | 3 obs / 2 ep | 95% (Tier) |
| F-67 | 192.168.195.1 | Low (3.1) | VALIDATED | X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) | CWE-693 / T1190 | 45 obs / 2 ep | 95% (Tier) |
| F-68 | 192.168.195.1:8000 | Low (3.1) | VALIDATED | robots.txt Disallows Sensitive Web Paths | CWE-200 / T1592 | 1 obs / 1 ep | 95% (Tier) |
| F-69 | 192.168.195.129 | Low (3.1) | VALIDATED | HTTP Server Banner Version Disclosure ('Server' Header) | CWE-200 / T1592 | 3 obs / 1 ep | 95% (Tier) |
| F-70 | 192.168.195.130 | Low (3.1) | VALIDATED | HTTP Server Banner Version Disclosure ('Server' Header) | CWE-200 / T1592 | 3 obs / 1 ep | 95% (Tier) |
| F-71 | 192.168.195.139 | Low (3.1) | VALIDATED | Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate) | CWE-200 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-72 | 192.168.195.139:80 | Low (3.1) | VALIDATED | HTTP Permissions-Policy Header Missing | CWE-693 / T1190 | 1 obs / 1 ep | 95% (Tier) |
| F-73 | 192.168.195.139:80 | Low (3.1) | VALIDATED | HTTP Referrer-Policy Header Missing | CWE-200 / T1592 | 1 obs / 1 ep | 95% (Tier) |
| F-74 | 192.168.195.139:80 | Low (3.1) | VALIDATED | HTTP Server Banner Version Disclosure ('Server' Header) | CWE-200 / T1592 | 3 obs / 2 ep | 95% (Tier) |
| F-75 | 192.168.195.139:80 | Low (3.1) | VALIDATED | HTTP Strict-Transport-Security (HSTS) Header Missing | CWE-319 / T1557 | 3 obs / 3 ep | 95% (Tier) |
| F-76 | 192.168.195.139:80 | Low (3.1) | VALIDATED | HTTP Technology Stack Disclosure ('X-Powered-By' Header) | CWE-200 / T1592 | 2 obs / 2 ep | 95% (Tier) |
| F-77 | 192.168.195.139 | Low (3.1) | VALIDATED | Web Server Directory Listing Enabled (/icons/ & Static Directories) | CWE-548 / T1083 | 1 obs / 1 ep | 95% (Tier) |
| F-78 | 192.168.195.139:80 | Low (3.1) | VALIDATED | X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) | CWE-693 / T1190 | 3 obs / 3 ep | 95% (Tier) |
| F-79 | 192.168.195.140 | Low (3.1) | VALIDATED | Developer / Debugging Comments Exposed in HTML/JS Source | CWE-615 / T1592 | 1 obs / 1 ep | 90% (Tier) |
| F-80 | 192.168.195.140:80 | Low (3.1) | VALIDATED | HTTP Permissions-Policy Header Missing | CWE-693 / T1190 | 2 obs / 2 ep | 95% (Tier) |
| F-81 | 192.168.195.140:80 | Low (3.1) | VALIDATED | HTTP Referrer-Policy Header Missing | CWE-200 / T1592 | 2 obs / 2 ep | 95% (Tier) |
| F-82 | 192.168.195.140:80 | Low (3.1) | VALIDATED | HTTP Server Banner Version Disclosure ('Server' Header) | CWE-200 / T1592 | 34 obs / 3 ep | 95% (Tier) |
| F-83 | 192.168.195.140:80 | Low (3.1) | VALIDATED | HTTP Strict-Transport-Security (HSTS) Header Missing | CWE-319 / T1557 | 6 obs / 4 ep | 95% (Tier) |

| ID | Host : Port | Severity & CVSS | Proof State | Title | CWE / MITRE | Merged / Endpoints | Composite Conf (FP) |
|---|---|---|---|---|---|---|---|
| F-84 | 192.168.195.140 | Low (3.1) | VALIDATED | Session Cookie Missing 'HttpOnly' Flag | CWE-1004 / T1190 | 10 obs / 1 ep | 95% (Tier) |
| F-85 | 192.168.195.140 | Low (3.1) | VALIDATED | Session Cookie Missing 'SameSite' Attribute | CWE-352 / T1190 | 10 obs / 1 ep | 95% (Tier) |
| F-86 | 192.168.195.140 | Low (3.1) | VALIDATED | Web Server Directory Listing Enabled (/icons/ & Static Directories) | CWE-548 / T1083 | 1 obs / 1 ep | 95% (Tier) |
| F-87 | 192.168.195.140:80 | Low (3.1) | VALIDATED | X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) | CWE-693 / T1190 | 10 obs / 4 ep | 95% (Tier) |
| F-88 | 192.168.195.130 | Low (3.1) | OBSERVED | SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) | CWE-287 / T1021.002 | 2 obs / 2 ep | 48% (Tier) |
| F-89 | 192.168.195.139 | Low (3.1) | OBSERVED | SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) | CWE-287 / T1021.002 | 2 obs / 2 ep | 48% (Tier) |
| F-90 | 192.168.195.140 | Low (3.1) | OBSERVED | SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) | CWE-287 / T1021.002 | 2 obs / 2 ep | 48% (Tier) |

## 3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

### F-01: Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524 [CRITICAL · CVSS 9.8 · CONFIRMED_COMPROMISE]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_COMPROMISE (Legacy Tier: CONFIRMED) \| Privilege: ROOT (uid=0 / gid=0) \| Auth: True \| File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) \| DB: NONE \| Privesc Lifecycle: PRIVILEGE_TRANSITION_EXECUTED |
| **7-D Proof Vector (V3):** | Execution: ROOT_SHELL_EXECUTED \| Auth: UNAUTHENTICATED_ROOT_BIND \| Exploitability: EXPLOIT_CONFIRMED \| Privilege: ROOT (uid=0 / gid=0) \| DataAccess: SHADOW_HASHES_READ_REDACTED \| Impact: FULL_SYSTEM_COMPROMISE \| EvidenceConf: 99% |
| **Access Scope Summary:** | Unrestricted root command execution (uid=0) and /etc/shadow READ_CONFIRMED (password hashes redacted; write not executed per RoE) |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-INGRESLOCK-1524 \| Advisory: CERT/CC CA-1994-01 (inetd / ingreslock Backdoor Bindshell Exposure) \| CWE: CWE-306 \| MITRE: T1059.004 (Execution — Command and Scripting Interpreter: Unix Shell) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-306 (Missing Authentication for Critical Function) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=99% \| ImpactConf=99% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=99%, Art=100%) \| ExploitabilityConf=99% \| ImpactConf=99% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:1524 |
| **Root Cause & Compliance:** | Malicious Backdoor / Intentional Vulnerable Build [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | TCP port 1524 (ingreslock) exposes an unauthenticated interactive root shell (/bin/sh). Note: rsh/bindshell probes against port 1524 interact with this same underlying root bind shell and have been consolidated into this single compromise record. |
| **Security Risk:** | CRITICAL — Immediate unauthenticated root compromise (uid=0) with full filesystem control and /etc/shadow READ_CONFIRMED access (password hashes redacted; write not executed per RoE). |
| **EvidenceCore V3 Record:** | ID: PROV-F-01-424450284F \| SHA-256: 424450284f748d1fdb3439c8... \| HMAC-SHA256: c5072f77152674a62cbc5b88... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-01):**

```
INGRESLOCK BACKDOOR: Root shell on port 1524!
id: root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
$ whoami: root
root@metasploitable:/#
$ cat /etc/shadow | head -3: root:$1$/av...[REDACTED_SHADOW_HASH]:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
root@met
$ uname -a: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/#
$ ifconfig 2>/dev/null: eth0 Link enca
---
rsh access: root@metasploitable:/#
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Immediately terminate the `/bin/sh` bind shell listening on TCP port 1524 (`fuser -k 1524/tcp`), comment out the `ingreslock` line in `/etc/inetd.conf` or `/etc/xinetd.d/`, and reload `inetd`. |

| | |
|---|---|
| **Short-Term Hardening:** | Block TCP port 1524 at the host firewall (`ufw deny 1524/tcp` / `iptables -A INPUT -p tcp --dport 1524 -j DROP`) and audit `/etc/inetd.conf` for unauthorized backdoor listeners (`rsh`, `rexec`, `rlogin`). |
| **Long-Term Strategic Fix:** | Decommission `inetd`/`xinetd` legacy super-server daemons entirely and implement automated host-based port baseline monitoring. |
| **Approval & Change Window:** | Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -sV -p 1524 192.168.195.139` and confirm port 1524 returns `closed` or `filtered` with no shell prompt. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 1524 192.168.195.139` and confirm port 1524 returns `closed` or `filtered` with no shell prompt.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-02: vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523) [CRITICAL · CVSS 9.8 · CONFIRMED_COMPROMISE]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_COMPROMISE (Legacy Tier: CONFIRMED) \| Privilege: ROOT (uid=0 / gid=0) \| Auth: True \| File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) \| DB: NONE \| Privesc Lifecycle: PRIVILEGE_TRANSITION_EXECUTED |
| **7-D Proof Vector (V3):** | Execution: ROOT_SHELL_EXECUTED \| Auth: UNAUTHENTICATED_ROOT_BIND \| Exploitability: EXPLOIT_CONFIRMED \| Privilege: ROOT (uid=0 / gid=0) \| DataAccess: SHADOW_HASHES_READ_REDACTED \| Impact: FULL_SYSTEM_COMPROMISE \| EvidenceConf: 99% |
| **Access Scope Summary:** | Unrestricted root command execution (uid=0) and /etc/shadow READ_CONFIRMED (password hashes redacted; write not executed per RoE) |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2011-2523 \| Custom ID: XSTRIKE-VSFTPD-234-BACKDOOR \| Advisory: OSVDB-73573 / vsFTPd v2.3.4 Compromised Archive Advisory \| CWE: CWE-506 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) \| CWE-506 (Embedded Malicious Code) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=99% \| ImpactConf=99% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=99%, Art=100%) \| ExploitabilityConf=99% \| ImpactConf=99% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:21 |
| **Root Cause & Compliance:** | Malicious Backdoor / Intentional Vulnerable Build [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | The vsFTPd 2.3.4 daemon contains a maliciously planted backdoor (CVE-2011-2523) that opens an unauthenticated root bind shell on TCP port 6200 when a username ending in ':)' is supplied. |
| **Security Risk:** | CRITICAL — Complete host compromise. Unauthenticated remote attacker obtains uid=0(root) command execution and access to /etc/shadow password hashes. |
| **EvidenceCore V3 Record:** | ID: PROV-F-02-97A9FA7E47 \| SHA-256: 97a9fa7e47421049e105595e... \| HMAC-SHA256: cea7d96dfd7ae10c8ca6d796... \| Module: AutoPentest-VulnScan, XStrike-BuiltinVuln, AutoPentest-Exploit |

**Captured Technical Evidence (F-02):**

```
BACKDOOR SHELL on :6200!
$ id: uid=0(root) gid=0(root)
$ whoami: root
```

```
$ uname -a: Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
$ cat /etc/shadow | head -5: root:$1$/av...[REDACTED_SHADOW_HASH]:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX...[REDACTED_SHADOW_HASH]
[!] ROOT PASSWORD HASH DUMPED!
$ cat /etc/passwd=[REDACTED]
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bi
---
[2026-10-31 06:26:32] FTP service on 192.168.195.139:21.
Service: ftp, Product: vsftpd, Version: 2.3.4
MATCH: vsftpd 2.3.4 — known backdoor (CVE-2011-2
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Immediately stop the vsFTPd daemon (`systemctl stop vsftpd` or `killall vsftpd`), terminate any process bound to TCP port 6200, and isolate 192.168.195.139 from the network. |
| **Short-Term Hardening:** | Replace the compromised vsFTPd 2.3.4 binary with a cryptographically verified upstream package (`apt-get update && apt-get install --only-upgrade vsftpd`) or migrate file transfers to SFTP/SCP over hardened OpenSSH. |
| **Long-Term Strategic Fix:** | Rebuild the compromised host from a trusted gold image, rotate all local password hashes in `/etc/shadow`, and enforce package signature verification in CI/CD. |
| **Approval & Change Window:** | Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Verify TCP port 21 and port 6200 are closed or that `vsftpd -v` reports a patched release (>= 3.0.3) and `USER test:)` no longer opens port 6200. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Verify TCP port 21 and port 6200 are closed or that `vsftpd -v` reports a patched release (>= 3.0.3) and `USER test:)` no longer opens port 6200.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-03: PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres) [CRITICAL · CVSS 9.1 · CONFIRMED_AUTH]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_AUTH (Legacy Tier: CONFIRMED) \| Privilege: DB_SUPERUSER (postgres) \| Auth: True \| File: NONE \| DB: AUTHENTICATED_SCHEMA_READ (PostgreSQL 8.3.1 databases & pg_catalog tables enumerated) \| Privesc Lifecycle: TECHNIQUE_VALIDATED |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_DB_QUERY_EXECUTED \| Auth: AUTHENTICATED_SUPERUSER (postgres) \| Exploitability: CREDENTIAL_CONFIRMED \| Privilege: DB_SUPERUSER (postgres) \| DataAccess: DB_CATALOG_AUTHENTICATED \| Impact: DATABASE_SUPERUSER_COMPROMISE \| EvidenceConf: 98% |
| **Access Scope Summary:** | Authenticated PostgreSQL 8.3.1 superuser session ('postgres'); database & table catalog enumerated (read-only verification) |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PGSQL-DEFAULT-SUPERUSER \| Advisory: PostgreSQL pg_hba.conf & Default Superuser Password Advisory \| CWE: CWE-798 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-798 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=95% \| ImpactConf=88% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) \| ExploitabilityConf=95% \| ImpactConf=88% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:5432 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | PostgreSQL 8.3.1 on TCP port 5432 accepts default superuser credentials ('postgres:postgres'), allowing remote database enumeration and catalog read access. |
| **Security Risk:** | CRITICAL — Authenticated database superuser access; permits reading/modifying all databases and potential OS command execution via pg_catalog functions. |
| **EvidenceCore V3 Record:** | ID: PROV-F-03-5EBB5E02B0 \| SHA-256: 5ebb5e02b0e5c7bdb3c30edd... \| HMAC-SHA256: 3710f1286b3ae1de3491343e... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-03):**

```
PostgreSQL LOGIN: postgres:postgres
version: [('PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu
4.2.3-2ubuntu4)',)]
databases: [('template1',), ('template0',), ('postgres',)]
users: [('postgres', 'md53175bce1d3201d16594cebf9d7eb3f9d')]
tables: [('ymdoo',)]
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Change the PostgreSQL `postgres` superuser password (`ALTER USER postgres WITH PASSWORD '<strong_random_secret>';`) and restrict `/etc/postgresql/8.3/main/pg_hba.conf` to `md5` or `scram-sha-256` over local sockets only. |
| **Short-Term Hardening:** | Bind PostgreSQL exclusively to localhost in `postgresql.conf` (`listen_addresses = 'localhost'`) and block TCP port 5432 at the host firewall for untrusted subnets. |
| **Long-Term Strategic Fix:** | Upgrade EOL PostgreSQL 8.3.1 to a supported release (PostgreSQL 15/16) with role-based least-privilege database accounts. |
| **Approval & Change Window:** | Emergency Change Advisory Board (ECAB) — Immediate Break-Glass Containment (0–24h SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/postgresql/8.3/main/pg_hba.conf` and `postgresql.conf` (`cp -p pg_hba.conf pg_hba.conf.bak`); run `pg_ctl reload` to revert if dependent local services lose DB connectivity. |
| **Verification & Closure Rule:** | Attempt remote authentication with `psql -h 192.168.195.139 -U postgres` and confirm connection refusal or `FATAL: password authentication failed`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Attempt remote authentication with `psql -h 192.168.195.139 -U postgres` and confirm connection refusal or `FATAL: password authentication failed`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-04: FTP Default Credential Authentication (msfadmin:msfadmin) [HIGH · CVSS 8.2 · CONFIRMED_AUTH]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_AUTH (Legacy Tier: CONFIRMED) \| Privilege: STANDARD_USER (msfadmin) \| Auth: True \| File: READ_LIST (user directory listing verified; write not executed) \| DB: NONE \| Privesc Lifecycle: PRECONDITION_DISCOVERED |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_SESSION_VERIFIED \| Auth: AUTHENTICATED_USER (msfadmin) \| Exploitability: CREDENTIAL_CONFIRMED \| Privilege: STANDARD_USER (msfadmin) \| DataAccess: DIRECTORY_LISTING_READ \| Impact: UNAUTHORIZED_ACCOUNT_ACCESS \| EvidenceConf: 98% |

| | |
|---|---|
| **Access Scope Summary:** | Authenticated FTP session as standard user 'msfadmin'; directory listing verified (non-root) |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-FTP-DEFAULT-CREDS \| Advisory: Rapid7 Metasploitable2 Baseline Default Account Advisory \| CWE: CWE-798 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-798 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=95% \| ImpactConf=88% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) \| ExploitabilityConf=95% \| ImpactConf=88% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:21 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | The FTP service on port 21 authenticates the default account 'msfadmin:msfadmin', granting interactive access to the user's directory structure. |
| **Security Risk:** | HIGH — Unauthorized authenticated file access as standard user (msfadmin); enables credential reuse across SSH/Samba. |
| **EvidenceCore V3 Record:** | ID: PROV-F-04-3529D6A41A \| SHA-256: 3529d6a41a6c352d8da3ac87... \| HMAC-SHA256: 862d3ad239cb19553ae6291e... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-04):**

```
FTP login msfadmin:msfadmin SUCCESS. Files: vulnerable
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Change the `msfadmin` account password immediately (`passwd msfadmin`) and revoke FTP access for administrative users via `/etc/ftpusers`. |
| **Short-Term Hardening:** | Disable cleartext FTP authentication altogether in `/etc/vsftpd.conf` (`local_enable=NO` or enforce TLS via `ssl_enable=YES`). |
| **Long-Term Strategic Fix:** | Enforce centralized identity management with minimum 14-character password complexity and multi-factor authentication. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Attempt FTP login with `msfadmin:msfadmin` and verify the server returns `530 Login incorrect`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Attempt FTP login with `msfadmin:msfadmin` and verify the server returns `530 Login incorrect`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-05: SSH Default Credential Shell Access (msfadmin:msfadmin) [HIGH · CVSS 8.2 · CONFIRMED_AUTH]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_AUTH (Legacy Tier: CONFIRMED) \| Privilege: STANDARD_USER (uid=1000 msfadmin, gid=1000) \| Auth: True \| File: READ_CONFIRMED (standard user home directory; write not executed per RoE) \| DB: NONE \| Privesc Lifecycle: PRECONDITION_DISCOVERED |
| **7-D Proof Vector (V3):** | Execution: USER_SHELL_EXECUTED \| Auth: AUTHENTICATED_USER (uid=1000) \| Exploitability: CREDENTIAL_CONFIRMED \| Privilege: STANDARD_USER (uid=1000 msfadmin, gid=1000) \| DataAccess: USER_FILESYSTEM_READ \| Impact: INTERACTIVE_USER_SHELL_COMPROMISE \| EvidenceConf: 98% |

| | |
|---|---|
| **Access Scope Summary:** | Interactive SSH shell established as unprivileged user uid=1000(msfadmin); root escalation not executed in this step |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-SSH-DEFAULT-CREDS \| Advisory: OpenSSH Default/Predictable Account Hygiene Advisory \| CWE: CWE-798 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-798 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=95% \| ImpactConf=88% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) \| ExploitabilityConf=95% \| ImpactConf=88% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:22 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | The OpenSSH service on port 22 accepts default credentials 'msfadmin:msfadmin', granting an interactive shell as standard user uid=1000(msfadmin). Separate local privilege escalation is required for root access. |
| **Security Risk:** | HIGH — Authenticated interactive Linux shell as standard user (uid=1000); provides direct launchpad for local privilege escalation. |
| **EvidenceCore V3 Record:** | ID: PROV-F-05-6715A75078 \| SHA-256: 6715a75078cb9770fd881c37... \| HMAC-SHA256: 408dbbf128f2b4184b581411... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-05):**

```
SSH LOGIN SUCCESS: msfadmin:msfadmin
Identity: uid=1000(msfadmin) gid=1000(msfadmin)
groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(di
Users: root, daemon, bin, sys, sync, games, man, lp, mail, news, uucp, proxy, www-data, backup, list
SUID binaries (privesc): /bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/tr
[!] CONFIG CREDS:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Rotate the `msfadmin` password immediately (`passwd msfadmin`) and terminate active unauthorized SSH sessions. |
| **Short-Term Hardening:** | Configure `/etc/ssh/sshd_config` with `PasswordAuthentication no`, `PermitRootLogin no`, and `MaxAuthTries 3`, then reload `sshd`. |
| **Long-Term Strategic Fix:** | Enforce Ed25519/RSA public-key authentication backed by hardware security keys or an SSH Certificate Authority. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |

| | |
|---|---|
| **Verification & Closure Rule:** | Verify `ssh msfadmin@192.168.195.139` rejects password authentication (`Permission denied (publickey)`). \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Verify `ssh msfadmin@192.168.195.139` rejects password authentication (`Permission denied (publickey)`).`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-06: Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap) [HIGH · CVSS 7.8 · EXPLOITABLE]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | EXPLOITABLE (Legacy Tier: VALIDATED) \| Privilege: LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive) \| Auth: True \| File: READ_ONLY (/usr/bin/nmap SUID-root bit verified) \| DB: NONE \| Privesc Lifecycle: TECHNIQUE_VALIDATED |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_ENUMERATION_EXECUTED \| Auth: AUTHENTICATED_USER (uid=1000) \| Exploitability: PRECONDITION_VERIFIED \| Privilege: LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive) \| DataAccess: FILESYSTEM_ACL_VERIFIED \| Impact: LOCAL_ROOT_ESCALATION_READY \| EvidenceConf: 95% |
| **Access Scope Summary:** | Authenticated SSH check confirmed SUID-root bit on /usr/bin/nmap (--interactive !sh technique validated; root transition not executed via SSH) |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PRIVESC-SUID-NMAP \| Advisory: GTFOBins SUID Nmap (--interactive !sh) Privilege Escalation Vector \| CWE: CWE-269 \| MITRE: T1548.001 (Privilege Escalation — Abuse Elevation Control Mechanism: Setuid and Setgid) \| Taxonomy: MITRE ATT&CK T1548.001 \| CWE-269 (Improper Privilege Management) \| Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H |
| **Separated Confidence (V3):** | EvidenceConf=96% \| ExploitabilityConf=82% \| ImpactConf=80% \| 5-D Vector: EvidenceConf=96% (Det=96%, Val=94%, Art=100%) \| ExploitabilityConf=82% \| ImpactConf=80% \| FP Band: Tier 1 — Authenticated Exploit Precondition Verified (<5% Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139 |
| **Root Cause & Compliance:** | Excessive Local Privilege / File Permission Misconfiguration [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Post-authentication enumeration over SSH identified /usr/bin/nmap with the setuid-root bit enabled. Legacy Nmap versions (2.02–5.21) support '--interactive' mode, allowing an authenticated local user (msfadmin, uid=1000) to spawn a root shell (!sh). |
| **Security Risk:** | HIGH (EXPLOITABLE, CVSS 7.8) — Validated local privilege escalation path from standard user (uid=1000) to root (uid=0). |
| **EvidenceCore V3 Record:** | ID: PROV-F-06-E061A6DE7E \| SHA-256: e061a6de7e1680cfa2141f64... \| HMAC-SHA256: 79a8ac2341e6d4f67d51f2b2... \| Module: AutoPentest-Exploit, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-06):**

```
SUID nmap found — known privilege escalation vector!
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Remove the SUID-root bit from `/usr/bin/nmap` immediately (`chmod u-s /usr/bin/nmap`) and audit all SUID binaries via `find / -perm -4000 -type f 2>/dev/null`. |
| **Short-Term Hardening:** | Upgrade Nmap to a modern release (>= 7.9x) that removes `--interactive` shell escapes and enforce `nosuid` mount options on `/tmp` and `/home`. |
| **Long-Term Strategic Fix:** | Migrate the legacy Ubuntu 8.04 system to a supported LTS distribution with AppArmor/SELinux enforcement. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Record baseline file mode via `stat -c '%a %n' /usr/bin/nmap /bin/mount > /root/suid_baseline.txt`; restore with `chmod 4755 <binary>` only if an approved operational dependency breaks. |
| **Verification & Closure Rule:** | Run `ls -la /usr/bin/nmap` and confirm permissions read `-rwxr-xr-x` without the `s` flag, and `nmap --interactive` is unavailable. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `ls -la /usr/bin/nmap` and confirm permissions read `-rwxr-xr-x` without the `s` flag, and `nmap --interactive` is unavailable.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-07: DVWA Web Application Default Administrative Credentials Accepted (admin:password) [HIGH · CVSS 8.2 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-DVWA-DEFAULT-CREDS \| Advisory: OWASP A07:2021 — Identification and Authentication Failures \| CWE: CWE-798 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-798 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The Damn Vulnerable Web Application (DVWA) login endpoint (/dvwa/login.php) accepted default administrative credentials ('admin:password') during automated authentication verification (consolidated from OWASP A07 testing). |
| **Security Risk:** | HIGH — Validated administrative web session access enabling command injection, SQLi, and file upload testing modules. |
| **EvidenceCore V3 Record:** | ID: PROV-F-07-D70EE7FC10 \| SHA-256: d70ee7fc1053871ca6df4bab... \| HMAC-SHA256: 220fd2c8fe46e614f9019fb1... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-07):**

```
A07 Auth Failures: 2 finding(s)
[CWE-798] Default Creds: DVWA (admin:password): Login successful with admin:password!
[CWE-798] Default Creds: DVWA (admin:admin): Login successful with admin:admin!
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable or unpublish the `/dvwa/` training application from the web root (`mv /var/www/dvwa /root/dvwa.disabled`) or rotate the `admin` password in the DVWA MySQL `users` table. |
| **Short-Term Hardening:** | Restrict access to `/dvwa/` via Apache IP allowlisting (`Require ip 127.0.0.1`) if used in a controlled lab. |

| | |
|---|---|
| **Long-Term Strategic Fix:** | Prohibit deployment of intentionally vulnerable training applications (DVWA, Mutillidae) on shared infrastructure hosts. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-08: Web Application SQL Injection Indicator (Mutillidae) [HIGH · CVSS 8.2 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: INDICATOR_ONLY (Mutillidae SQL response indicator matched; controlled data extraction not dumped) \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: INJECTION_INDICATOR_VALIDATED \| Privilege: NONE \| DataAccess: SQL_ERROR_OR_TABLE_INDICATOR \| Impact: DATABASE_INJECTION_EXPOSURE \| EvidenceConf: 92% |
| **Access Scope Summary:** | Positive SQL injection response indicator on Mutillidae endpoint; controlled row extraction not executed |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-SQLI-MUTILLIDAE \| Advisory: OWASP A03:2021 — Injection (SQL Injection) \| CWE: CWE-89 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A03:2021 (Injection) \| CWE-89 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:80 |
| **Root Cause & Compliance:** | Insecure Application Coding (Input Validation) [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated SQL injection testing against the Mutillidae web application matched a database table/error indicator in the HTTP 200 response. Classified as VALIDATED pending full request/response payload and controlled data dump verification. |
| **Security Risk:** | HIGH — Unsanitized user input reaches backend SQL queries; could allow unauthorized database read/modification. |
| **EvidenceCore V3 Record:** | ID: PROV-F-08-9CC3744D82 \| SHA-256: 9cc3744d8284a81a26266e98... \| HMAC-SHA256: 0431d8239621f7f744be5757... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-08):**

```
SQL Injection confirmed:
Mutillidae SQLi: table found
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable or restrict the vulnerable Mutillidae PHP endpoint via Apache rewrite/location rules and enable ModSecurity OWASP CRS SQLi rules. |

| | |
|---|---|
| **Short-Term Hardening:** | Refactor all database queries in the PHP application to use parameterized prepared statements (`PDO::prepare()` with bound parameters) instead of string concatenation. |
| **Long-Term Strategic Fix:** | Enforce static application security testing (SAST) in CI and restrict the web application's MySQL account to least-privilege `SELECT`/`INSERT` permissions. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Re-issue SQLi test payloads against the target parameter and verify HTTP responses contain zero database table leaks or SQL syntax error strings. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Re-issue SQLi test payloads against the target parameter and verify HTTP responses contain zero database table leaks or SQL syntax error strings.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-09: DVWA Web Application Default Administrative Credentials Accepted (admin:password) [HIGH · CVSS 8.2 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-DVWA-DEFAULT-CREDS \| Advisory: OWASP A07:2021 — Identification and Authentication Failures \| CWE: CWE-798 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-798 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The Damn Vulnerable Web Application (DVWA) login endpoint (/dvwa/login.php) accepted default administrative credentials ('admin:password') during automated authentication verification (consolidated from OWASP A07 testing). |
| **Security Risk:** | HIGH — Validated administrative web session access enabling command injection, SQLi, and file upload testing modules. |
| **EvidenceCore V3 Record:** | ID: PROV-F-09-CFA2E7857F \| SHA-256: cfa2e7857fb6a1564df6dffa... \| HMAC-SHA256: 09c252785249d17b8dbb10de... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-09):**

```
A07 Auth Failures: 1 finding(s)
[CWE-798] Default Creds: Mutillidae (admin:admin): Login successful with admin:admin!
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Disable or unpublish the `/dvwa/` training application from the web root (`mv /var/www/dvwa /root/dvwa.disabled`) or rotate the `admin` password in the DVWA MySQL `users` table. |
| **Short-Term Hardening:** | Restrict access to `/dvwa/` via Apache IP allowlisting (`Require ip 127.0.0.1`) if used in a controlled lab. |
| **Long-Term Strategic Fix:** | Prohibit deployment of intentionally vulnerable training applications (DVWA, Mutillidae) on shared infrastructure hosts. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit `username=admin&password=password` to `/dvwa/login.php` and verify authentication fails or returns HTTP 403/404.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-10: Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195) [HIGH · CVSS 7.8 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) \| Auth: True \| File: NONE \| DB: NONE \| Privesc Lifecycle: PRECONDITION_DISCOVERED |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_ENUMERATION_EXECUTED \| Auth: AUTHENTICATED_USER (uid=1000) \| Exploitability: VERSION_OR_ACL_VALIDATED \| Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) \| DataAccess: KERNEL_AND_SUID_METADATA \| Impact: LOCAL_PRIVESC_SURFACE \| EvidenceConf: 93% |
| **Access Scope Summary:** | Authenticated SSH uname -r verified Linux 2.6.24-16-server DirtyCow (CVE-2016-5195) precondition; kernel race payload withheld per RoE safety policy |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2016-5195 \| Custom ID: XSTRIKE-KERNEL-DIRTYCOW \| Advisory: Ubuntu USN-3106-1 / Red Hat RHSA-2016:2098 (DirtyCow) \| CWE: CWE-362 \| MITRE: T1068 (Privilege Escalation — Exploitation for Privilege Escalation) \| Taxonomy: MITRE ATT&CK T1068 \| CWE-362 (Concurrent Execution Race Condition) \| Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139 |
| **Root Cause & Compliance:** | Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Authenticated SSH fingerprinting ('uname -r') confirmed Linux kernel 2.6.24-16-server, which is affected by the CVE-2016-5195 (DirtyCow) copy-on-write race condition privilege escalation vulnerability. |
| **Security Risk:** | HIGH — Local users can exploit the kernel race condition to overwrite read-only root binaries and gain uid=0 privileges. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-10-C1D405DA9E \| SHA-256: c1d405da9e468eead300aea3... \| HMAC-SHA256: f75d7102f9d9378b5f389cdc... \| Module: AutoPentest-Exploit, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-10):**

```
Kernel 2.6.24-16-server — vulnerable to DirtyCow (CVE-2016-5195), Multiple kernel exploits
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict local shell access on 192.168.195.139 by disabling default SSH accounts (`msfadmin`) and setting `kernel.perf_event_paranoid = 3`. |
| **Short-Term Hardening:** | Upgrade the Linux kernel from `2.6.24-16-server` to a patched kernel incorporating the CVE-2016-5195 copy-on-write race fix (`mm/gup.c` FOLL_COW patch). |
| **Long-Term Strategic Fix:** | Reprovision the EOL Ubuntu 8.04 host onto Ubuntu 22.04/24.04 LTS with unattended kernel livepatching enabled. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `uname -r` over SSH and verify a supported kernel version patched against CVE-2016-5195. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `uname -r` over SSH and verify a supported kernel version patched against CVE-2016-5195.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-11: Deprecated SMBv1 Dialect Enabled on SMB Service [HIGH · CVSS 7.5 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMBV1-ENABLED \| Advisory: Microsoft / Samba SMBv1 Deprecation Advisory (KB2696547) \| CWE: CWE-327 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-327 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:445 |
| **Root Cause & Compliance:** | Service Hardening & Configuration Baseline Gap [PROBABLE] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The SMB service negotiates the legacy SMBv1 protocol dialect, which lacks modern integrity protections and exposes the host to SMBv1 protocol attacks. |
| **Security Risk:** | HIGH — Legacy protocol weakness; SMBv1 should be disabled across all Windows and Samba servers. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-11-5552509362 \| SHA-256: 555250936296050abda223ab... \| HMAC-SHA256: e7e4dc805f77d80efa1eaa93... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-11):**

```
SMBv1 is enabled — vulnerable to EternalBlue (MS17-010)

Evidence: SMBv1 negotiate response received from 192.168.195.139:445
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable SMBv1 protocol negotiation: in Samba `/etc/samba/smb.conf` set `server min protocol = SMB2`; on Windows run `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`. |
| **Short-Term Hardening:** | Enforce mandatory SMB packet signing (`server signing = mandatory` in `smb.conf`) and restart `smbd`. |
| **Long-Term Strategic Fix:** | Standardize all file shares on SMBv3.1.1 with AES-128-GCM encryption enabled. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-12: Web Application Server-Side Request Forgery (SSRF) Indicator (Mutillidae) [HIGH · CVSS 7.5 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-SSRF-MUTILLIDAE \| Advisory: OWASP A10:2021 — Server-Side Request Forgery (SSRF) \| CWE: CWE-918 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A10:2021 (Server-Side Request Forgery) \| CWE-918 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |
| **Root Cause & Compliance:** | Insecure Application Coding (Input Validation) [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The Mutillidae web application accepted a server-side URL fetch parameter without outbound destination allowlisting (consolidated from OWASP A10 SSRF validation). |

| | |
|---|---|
| **Security Risk:** | HIGH — Allows an attacker to induce the web application to issue HTTP requests to loopback or internal subnet services. |
| **EvidenceCore V3 Record:** | ID: PROV-F-12-66473094D4 \| SHA-256: 66473094d40aab6fd50d0c92... \| HMAC-SHA256: e09a0a386b4e4066c5ff97e5... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-12):**

```
A10 SSRF: 1 finding(s)
[CWE-918] SSRF: Mutillidae SSRF: Server fetched internal URL:
<!-- I think the database password is set to b
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable the vulnerable Mutillidae URL fetch endpoint or block outbound HTTP/TCP connections initiated by the `www-data` user via `iptables -m owner --uid-owner www-data -j DROP`. |
| **Short-Term Hardening:** | Implement strict URL parsing and domain/IP allowlisting that rejects RFC 1918 private addresses (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`) and loopback (`127.0.0.0/8`). |
| **Long-Term Strategic Fix:** | Route all application outbound fetches through a dedicated egress proxy with DNS rebinding protection. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Attempt to fetch `http://127.0.0.1/` via the SSRF parameter and confirm the request is blocked and logged. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Attempt to fetch `http://127.0.0.1/` via the SSRF parameter and confirm the request is blocked and logged.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-13: Deprecated SMBv1 Dialect Enabled on SMB Service [HIGH · CVSS 7.5 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMBV1-ENABLED \| Advisory: Microsoft / Samba SMBv1 Deprecation Advisory (KB2696547) \| CWE: CWE-327 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-327 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:445 |
| **Root Cause & Compliance:** | Service Hardening & Configuration Baseline Gap [PROBABLE] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |

| | |
|---|---|
| **Technical Description:** | The SMB service negotiates the legacy SMBv1 protocol dialect, which lacks modern integrity protections and exposes the host to SMBv1 protocol attacks. |
| **Security Risk:** | HIGH — Legacy protocol weakness; SMBv1 should be disabled across all Windows and Samba servers. |
| **EvidenceCore V3 Record:** | ID: PROV-F-13-D1BCDA0079 \| SHA-256: d1bcda007935cc3f0ec4f0bc... \| HMAC-SHA256: 9fb0687e70a1389d936596ad... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-13):**

```
SMBv1 is enabled — vulnerable to EternalBlue (MS17-010)

Evidence: SMBv1 negotiate response received from 192.168.195.140:445
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Disable SMBv1 protocol negotiation: in Samba `/etc/samba/smb.conf` set `server min protocol = SMB2`; on Windows run `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`. |
| **Short-Term Hardening:** | Enforce mandatory SMB packet signing (`server signing = mandatory` in `smb.conf`) and restart `smbd`. |
| **Long-Term Strategic Fix:** | Standardize all file shares on SMBv3.1.1 with AES-128-GCM encryption enabled. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb-protocols` and verify dialect `NT LM 0.12 (SMBv1)` is no longer offered.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-14: SMB Message Signing Not Required (NTLM Relay Exposure) [HIGH · CVSS 7.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-SMB-SIGNING-DISABLED \| Advisory: Microsoft ADV190023 / Samba Mandatory Signing Guideline \| CWE: CWE-345 \| MITRE: T1557.001 (Credential Access — Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-345 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=68% \| ImpactConf=72% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=68% \| ImpactConf=72% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |

| | |
|---|---|
| **Root Cause & Compliance:** | Service Hardening & Configuration Baseline Gap [PROBABLE] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | SMB message signing is not enforced by the server, allowing an adversary on the local network segment to relay NTLMv2 authentication sessions. |
| **Security Risk:** | HIGH — Enables Adversary-in-the-Middle (AitM) SMB relay attacks and unauthorized lateral movement. |
| **EvidenceCore V3 Record:** | ID: PROV-F-14-D53AF875A0 \| SHA-256: d53af875a0486c1785e410c8... \| HMAC-SHA256: 7d45351e4ba81faf53cecbc9... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-14):**

```
SMB signing not enforced — relay attacks possible

Evidence: SMB security mode: 0x00 (signing not required)
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Enforce mandatory SMB packet signing: set `server signing = mandatory` in `/etc/samba/smb.conf` (Linux) or enable `Microsoft network server: Digitally sign communications (always)` via Group Policy (Windows). |
| **Short-Term Hardening:** | Disable NTLMv1/LM authentication (`lanman auth = no`, `ntlm auth = ntlmv2-only`) and enable Extended Protection for Authentication (EPA). |
| **Long-Term Strategic Fix:** | Migrate file share authentication to Kerberos with SMBv3 transport encryption (`smb encrypt = required`). |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Run `nmap -p 445 --script smb2-security-mode,smb-security-mode <target>` and confirm `Message signing enabled and required`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 445 --script smb2-security-mode,smb-security-mode <target>` and confirm `Message signing enabled and required`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-15: Cleartext Telnet Service Enabled on TCP Port 23 [HIGH · CVSS 7.5 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-TELNET-CLEARTEXT-23 \| Advisory: NIST SP 800-53 SC-8 / CIS Benchmark Disable Telnet Service \| CWE: CWE-319 \| MITRE: T1021 (Lateral Movement — Remote Services) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-319 (Cleartext Transmission of Sensitive Information) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |

| | |
|---|---|
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | Telnet service on TCP port 23 transmits authentication credentials and interactive session traffic in unencrypted cleartext. |
| **Security Risk:** | HIGH — Cleartext credential transmission enables passive network sniffing and session hijacking. |
| **EvidenceCore V3 Record:** | ID: PROV-F-15-8F7B078AFA \| SHA-256: 8f7b078afa48b91c3402112e... \| HMAC-SHA256: 39113dea99ce11baf207d9f1... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-15):**

```
[2026-10-31 06:26:32] Telnet service on 192.168.195.139:23.
Service: telnet, Product: Linux telnetd, Version: unknown
Telnet transmits all traffic including credentials in cleartext.
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Stop the Telnet daemon (`inetd` / `telnetd`) on TCP port 23 immediately and block port 23 at the host firewall. |
| **Short-Term Hardening:** | Migrate all remote command-line administration to hardened OpenSSH (SSHv2). |
| **Long-Term Strategic Fix:** | Enforce network access control lists blocking cleartext management protocols (Telnet, rsh, rexec, FTP). |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Confirm `nmap -p 23 192.168.195.139` reports TCP port 23 as `closed`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Confirm `nmap -p 23 192.168.195.139` reports TCP port 23 as `closed`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-16: End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80) [HIGH · CVSS 7.5 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-APACHE-EOL-228 \| Advisory: Apache HTTP Server 2.2.x End-of-Life Advisory \| CWE: CWE-1104 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) \| CWE-1104 (Use of Unmaintained Third Party Components) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |

| | |
|---|---|
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |
| **Root Cause & Compliance:** | Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | Apache httpd 2.2.8 on Ubuntu is End-of-Life (EOL) and no longer receives upstream security patches (consolidated across banner, AegisProbe, and OWASP A06 checks). |
| **Security Risk:** | HIGH — Running unsupported web server software with multiple historical CVEs. |
| **EvidenceCore V3 Record:** | ID: PROV-F-16-6F029D15FF \| SHA-256: 6f029d15ffdf348fe23f7636... \| HMAC-SHA256: 12c7745bd06688c95d2ecb24... \| Module: AutoPentest-OWASP, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-16):**

```
A06 Vulnerable Components: 6 finding(s)
[CWE-1104] Outdated: Apache 2.0/2.2 (EOL): Server: Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By:
PHP/5.2.4-2ubuntu5.10
[CWE-1104] Outdated: PHP 5.x (EOL): Server: Apache/2.2.8 (Ubuntu) DAV/2 | X-Powered-By:
PHP/5.2.4-2ubuntu5.10
[CWE-1104] Vulnerable App: Mutillidae: OWASP Mutillidae — vulnerable by design
[CWE-1104] Vulnerable App: TWiki: Legacy wiki with known CVEs
[CWE-1104] Vulnerable App: TikiWiki: Legacy CMS with known vulnerabilities
[CWE-
---
Apache 2.2.8 may have known privilege escalation or RCE vulnerabilities.
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Set `ServerTokens Prod` and disable unneeded Apache 2.2 modules (`a2dismod dav dav_fs cgi autoindex`) to reduce attack surface immediately. |
| **Short-Term Hardening:** | Upgrade EOL Apache httpd 2.2.8 to Apache 2.4.x on a supported Linux distribution. |
| **Long-Term Strategic Fix:** | Automate web server patching and lifecycle tracking. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `apache2 -v` on the host and verify a supported Apache 2.4.x release is installed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `apache2 -v` on the host and verify a supported Apache 2.4.x release is installed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-17: End-of-Life Apache HTTP Server 2.2.8 Deployed (TCP Port 80) [HIGH · CVSS 7.5 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-APACHE-EOL-228 \| Advisory: Apache HTTP Server 2.2.x End-of-Life Advisory \| CWE: CWE-1104 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) \| CWE-1104 (Use of Unmaintained Third Party Components) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | Apache httpd 2.2.8 on Ubuntu is End-of-Life (EOL) and no longer receives upstream security patches (consolidated across banner, AegisProbe, and OWASP A06 checks). |
| **Security Risk:** | HIGH — Running unsupported web server software with multiple historical CVEs. |
| **EvidenceCore V3 Record:** | ID: PROV-F-17-E5C5F52E30 \| SHA-256: e5c5f52e303a21cb34addcde... \| HMAC-SHA256: 3016ce489538ff7fe3325bfb... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-17):**

```
A06 Vulnerable Components: 3 finding(s)
[CWE-1104] Outdated: Apache 2.0/2.2 (EOL): Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3
PHP/5.3.2-1ubuntu4.30 with Suhosin
[CWE-1104] Outdated: PHP 5.x (EOL): Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30
with Suhosin
[CWE-1104] Vulnerable App: TikiWiki: Legacy CMS with known vulnerabilities
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Set `ServerTokens Prod` and disable unneeded Apache 2.2 modules (`a2dismod dav dav_fs cgi autoindex`) to reduce attack surface immediately. |
| **Short-Term Hardening:** | Upgrade EOL Apache httpd 2.2.8 to Apache 2.4.x on a supported Linux distribution. |
| **Long-Term Strategic Fix:** | Automate web server patching and lifecycle tracking. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `apache2 -v` on the host and verify a supported Apache 2.4.x release is installed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `apache2 -v` on the host and verify a supported Apache 2.4.x release is installed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-18: PHP-CGI Argument Injection Candidate (CVE-2012-1823) [HIGH · CVSS 7.4 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2012-1823 \| Custom ID: XSTRIKE-PHP-CGI-1823 \| Advisory: PHP Security Advisory CVE-2012-1823 / CERT VU#520827 \| CWE: CWE-88 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A03:2021 (Injection) \| CWE-88 (Improper Neutralization of Argument Delimiters) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:80 |
| **Root Cause & Compliance:** | Insecure Application Coding (Input Validation) [PROBABLE] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | The web server runs a legacy PHP 5.2.4 CGI configuration matching CVE-2012-1823 query-string argument injection indicators. Active remote code execution was not executed. |
| **Security Risk:** | HIGH — If PHP-CGI processes raw query-string flags (-d allow_url_include=on), an attacker can execute arbitrary PHP code. |
| **EvidenceCore V3 Record:** | ID: PROV-F-18-5084F0299D \| SHA-256: 5084f0299dec6ce29646cb12... \| HMAC-SHA256: 6c33b6bfd406c03aa0d963a7... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln |

**Captured Technical Evidence (F-18):**

```
Some PHP versions, when configured to run using CGI, do not correctly handle query strings that lack an
unescaped "=" character, enabling arbitrary code execution. In this case, an operating system co
---
PHP before 5.4.2 allows RCE when configured as CGI via query string

Evidence: Banner match on 192.168.195.139:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 10:53:30 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html

<html><head><title>Metaspl
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add an Apache `mod_rewrite` rule blocking query strings starting with `-`: `RewriteCond %{QUERY_STRING} ^(%2d\|-) [NC]`, `RewriteRule ^.*$ - [F,L]`. |
| **Short-Term Hardening:** | Migrate PHP execution from `mod_cgi`/`php-cgi` to `php-fpm` (FastCGI Process Manager) and upgrade PHP 5.2.4 to a supported PHP 8.2/8.3 release. |
| **Long-Term Strategic Fix:** | Enforce `allow_url_include = Off` and `expose_php = Off` in `php.ini` across all web servers. |
| **Approval & Change Window:** | Standard Security Change Control + SecOps Lead Sign-Off (7-Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Send `GET /?-s HTTP/1.1` to `http://192.168.195.139:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Send `GET /?-s HTTP/1.1` to `http://192.168.195.139:80/` and confirm HTTP 403 Forbidden with no PHP source code disclosed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-19: FTP Anonymous Authentication Enabled [MEDIUM · CVSS 5.3 · CONFIRMED_AUTH]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | CONFIRMED_AUTH (Legacy Tier: CONFIRMED) \| Privilege: ANONYMOUS (ftp) \| Auth: True \| File: READ_ONLY_EMPTY (0 files in anonymous root; no sensitive files exfiltrated) \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_SESSION_VERIFIED \| Auth: ANONYMOUS_AUTH (230 OK) \| Exploitability: CREDENTIAL_CONFIRMED \| Privilege: ANONYMOUS (ftp) \| DataAccess: EMPTY_ROOT_DIRECTORY \| Impact: UNAUTHENTICATED_SESSION_ACCESS \| EvidenceConf: 98% |
| **Access Scope Summary:** | Anonymous FTP login (230 OK) verified; root directory empty (0 files exfiltrated) |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-FTP-ANONYMOUS \| Advisory: RFC 1635 / vsFTPd anonymous_enable Configuration Advisory \| CWE: CWE-287 \| MITRE: T1078.001 (Defense Evasion / Persistence — Valid Accounts: Default Accounts) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-287 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=99% \| ExploitabilityConf=95% \| ImpactConf=88% \| 5-D Vector: EvidenceConf=99% (Det=99%, Val=98%, Art=100%) \| ExploitabilityConf=95% \| ImpactConf=88% \| FP Band: Tier 1 — Cryptographically & Executionally Verified (<1% Artifact Uncertainty) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, 192.168.195.139:21 |
| **Root Cause & Compliance:** | Identity & Credential Hygiene Deficiency [DIRECTLY_ESTABLISHED] \| Compliance Status: CONFIRMED_COMPLIANCE_DEFICIENCY |
| **Technical Description:** | The FTP server accepts anonymous login ('anonymous') with FTP status 230 OK. Enumeration confirmed an empty anonymous root directory (0 files exposed). |
| **Security Risk:** | MEDIUM — Unauthenticated FTP session establishment; while no files were present in the root directory, anonymous access exposes internal service state. |
| **EvidenceCore V3 Record:** | ID: PROV-F-19-C106E068CF \| SHA-256: c106e068cf9fabf933e1cfc8... \| HMAC-SHA256: 892574da5018323eb7853cdb... \| Module: XStrike-BuiltinVuln, AutoPentest-Exploit |

**Captured Technical Evidence (F-19):**

```
Anonymous login OK. Banner: 220 (vsFTPd 2.3.4). Files(0):
---
FTP server accepts anonymous login — unauthorized file access

Evidence: FTP anonymous login: 230 Login successful.
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Set `anonymous_enable=NO` in `/etc/vsftpd.conf` and restart the vsFTPd service (`service vsftpd restart`). |
| **Short-Term Hardening:** | Audit `/var/ftp` or the anonymous root directory to ensure no sensitive files or write permissions (`anon_upload_enable=NO`) exist. |
| **Long-Term Strategic Fix:** | Replace unauthenticated FTP distribution with authenticated HTTPS artifact repositories. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |

| | |
|---|---|
| **Verification & Closure Rule:** | Connect to port 21 as `USER anonymous` and verify the server responds with `530 Permission denied`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Connect to port 21 as `USER anonymous` and verify the server responds with `530 Permission denied`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-20: Local Privilege Escalation Vector: SUID Binary (/bin/mount) [MEDIUM · CVSS 5.5 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) \| Auth: True \| File: NONE \| DB: NONE \| Privesc Lifecycle: PRECONDITION_DISCOVERED |
| **7-D Proof Vector (V3):** | Execution: AUTHENTICATED_ENUMERATION_EXECUTED \| Auth: AUTHENTICATED_USER (uid=1000) \| Exploitability: VERSION_OR_ACL_VALIDATED \| Privilege: LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) \| DataAccess: KERNEL_AND_SUID_METADATA \| Impact: LOCAL_PRIVESC_SURFACE \| EvidenceConf: 93% |
| **Access Scope Summary:** | Authenticated SSH 'find / -perm -4000' discovered SUID-root precondition on /bin/mount; writable mount escalation not executed |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PRIVESC-SUID-MOUNT \| Advisory: Linux SUID Binary Hardening Baseline (/bin/mount) \| CWE: CWE-269 \| MITRE: T1548.001 (Privilege Escalation — Abuse Elevation Control Mechanism: Setuid and Setgid) \| Taxonomy: MITRE ATT&CK T1548.001 \| CWE-269 (Improper Privilege Management) \| Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:22, 192.168.195.139 |
| **Root Cause & Compliance:** | Excessive Local Privilege / File Permission Misconfiguration [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Post-authentication SSH enumeration identified SUID root permissions on /bin/mount, which may be combined with NFS or fstab misconfigurations for local privilege escalation. |
| **Security Risk:** | MEDIUM (CVSS 6.7) — Potential local privilege escalation vector if combined with writable mount points. |
| **EvidenceCore V3 Record:** | ID: PROV-F-20-9DE312809B \| SHA-256: 9de312809bcbff0b48717b36... \| HMAC-SHA256: 38fcdd9c9a5928feee528822... \| Module: AutoPentest-Exploit, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-20):**

```
SUID mount found — known privilege escalation vector!
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Audit `/etc/fstab` to ensure no user-mountable filesystems permit `suid` or `exec`, and remove unnecessary SUID bits from `/bin/mount` (`chmod u-s /bin/mount`) if unprivileged mounting is not required. |
| **Short-Term Hardening:** | Enforce `nosuid,nodev,noexec` on `/tmp`, `/var/tmp`, and `/home` mounts in `/etc/fstab`. |
| **Long-Term Strategic Fix:** | Implement file integrity monitoring (AIDE/auditd) tracking setuid/setgid permission changes across `/bin` and `/usr/bin`. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Record baseline file mode via `stat -c '%a %n' /usr/bin/nmap /bin/mount > /root/suid_baseline.txt`; restore with `chmod 4755 <binary>` only if an approved operational dependency breaks. |
| **Verification & Closure Rule:** | Run `find / -perm -4000 -type f 2>/dev/null` and confirm only approved baseline SUID binaries remain. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `find / -perm -4000 -type f 2>/dev/null` and confirm only approved baseline SUID binaries remain.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-21: Client-Manipulable Session/Tracking Cookie Parameters Set Without Integrity Binding [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-COOKIE-INTEGRITY \| Advisory: OWASP Testing Guide — Testing for Cookie Attributes (WSTG-SESS-02) \| CWE: CWE-565 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A04:2021 (Insecure Design) \| CWE-565 (Reliance on Cookies without Validation and Integrity Checking) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 4 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web application issues multiple state/configuration cookies without cryptographic HMAC signing or strict attribute hardening. |
| **Security Risk:** | MEDIUM — If server logic trusts unverified cookie values, attackers may tamper with user state or privilege indicators. |
| **EvidenceCore V3 Record:** | ID: PROV-F-21-EEC2BE5ABA \| SHA-256: eec2be5abae3726208296ee3... \| HMAC-SHA256: cfd12eb2b5d7b739d6209bc5... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-21):**

```
This check looks at user-supplied input in query string parameters and POST data to identify where
cookie parameters might be controlled. This is called a cookie poisoning attack, and becomes exploita
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Stop trusting client-side cookie parameters for user identity, privilege, or application state; store session state server-side in `$_SESSION`. |
| **Short-Term Hardening:** | If client-side cookies are used, sign values with HMAC-SHA256 and set `HttpOnly`, `Secure`, and `SameSite=Lax` attributes. |
| **Long-Term Strategic Fix:** | Standardize session management on encrypted, server-validated session stores. |

| | |
|---|---|
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Modify cookie values in an HTTP request and verify the server rejects tampered cookies and does not alter privilege state. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Modify cookie values in an HTTP request and verify the server rejects tampered cookies and does not alter privilege state.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-22: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-CSP-MISSING \| Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 116 raw observation(s) across 3 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080, 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection. |
| **Security Risk:** | MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw. |
| **EvidenceCore V3 Record:** | ID: PROV-F-22-43FFEFB79F \| SHA-256: 43ffefb79f795094c3396375... \| HMAC-SHA256: 199ad93421223cc9bb410c4b... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-22):**

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.1:8080 missing content-security-policy header
---
Missing header: Content-Security-Policy | CWE: CWE-1021 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. |
| **Short-Term Hardening:** | Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files. |
| **Long-Term Strategic Fix:** | Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-23: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XFO-MISSING \| Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet \| CWE: CWE-1021 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-1021 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 11 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe. |
| **Security Risk:** | MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-23-EB3C471751 \| SHA-256: eb3c4717516e44540e900a17... \| HMAC-SHA256: 881cd44e69607ef1961ddbaf... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln |

**Captured Technical Evidence (F-23):**

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.1:8080 missing x-frame-options header
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration. |
| **Short-Term Hardening:** | Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding. |
| **Long-Term Strategic Fix:** | Enforce standard security header middleware across all web application frameworks. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-24: Session Cookie Missing 'Secure' Flag [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-COOKIE-SECURE \| Advisory: OWASP Session Management Cheat Sheet — Secure Flag \| CWE: CWE-614 \| MITRE: T1557 (Credential Access — Adversary-in-the-Middle) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-614 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Cookies are issued without the 'Secure' attribute, allowing the browser to transmit them over unencrypted HTTP connections. |
| **Security Risk:** | MEDIUM — Exposes session identifiers to cleartext network interception. |
| **EvidenceCore V3 Record:** | ID: PROV-F-24-0C8B90016E \| SHA-256: 0c8b90016eaeb918da87c3a0... \| HMAC-SHA256: 69036e770ab855877a2406c2... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-24):**

```
Cookie: cval=1915971765... | CWE: CWE-614 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Enable HTTPS and set `session.cookie_secure = 1` in `php.ini` so session cookies are only transmitted over TLS. |
| **Short-Term Hardening:** | Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; Secure"` on all HTTPS virtual hosts. |
| **Long-Term Strategic Fix:** | Adopt `__Host-` cookie prefixes which require `Secure`, `Path=/`, and no `Domain` attribute. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect `Set-Cookie` headers over HTTPS and confirm the `Secure` attribute is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` headers over HTTPS and confirm the `Secure` attribute is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-25: Verbose Application / Database Error Message Disclosure [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-ZAP-ERROR-DISCLOSURE \| Advisory: OWASP ZAP Alert 90022 — Application Error Disclosure \| CWE: CWE-209 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-209 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 15 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web application returns raw stack traces, PHP warnings, or database error strings in HTTP responses. |
| **Security Risk:** | MEDIUM — Exposes internal file paths, SQL query structure, and framework internals to assist exploitation. |
| **EvidenceCore V3 Record:** | ID: PROV-F-25-F0F8ABB7FB \| SHA-256: f0f8abb7fb49a9f36ef56ff6... \| HMAC-SHA256: 143f6eb2927b4606c62901a0... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-25):**

```
This page contains an error/warning message that may disclose sensitive information like the location of
the file that produced the unhandled exception. This information can be used to launch further
---
The response appeared to contain common error messages returned by platforms such as ASP.NET, and
Web-servers such as IIS and Apache. You can configure the list of common debug messages.
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Set `display_errors = Off` and `log_errors = On` in `/etc/php5/apache2/php.ini` and configure custom generic 500 error pages in Apache. |
| **Short-Term Hardening:** | Wrap database and file operations in structured exception handlers that log stack traces server-side only. |
| **Long-Term Strategic Fix:** | Enforce production error-handling standards across all web applications. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Trigger an invalid parameter request and confirm a generic error message is returned with zero stack traces or SQL errors. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Trigger an invalid parameter request and confirm a generic error message is returned with zero stack traces or SQL errors.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-26: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-CSRF-BUNDLE \| Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 5 raw observation(s) across 5 unique endpoint(s): 192.168.195.1:5357, 192.168.195.1:8000, https://evil-test-aegis.com, 192.168.195.1:8080 ... (+1 additional endpoints) |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers. |

| | |
|---|---|
| **Security Risk:** | MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page. |
| **EvidenceCore V3 Record:** | ID: PROV-F-26-F4E928B452 \| SHA-256: f4e928b452c678c2bcc69abf... \| HMAC-SHA256: ab153b86b10e2691b4d37580... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-26):**

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send X-Frame-Options or CSP frame-ancestors header.
---
Discovered 1 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session cookie lacks SameSite protect
---
Discovered 4 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session c
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms. |
| **Short-Term Hardening:** | Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests. |
| **Long-Term Strategic Fix:** | Adopt a modern web framework with built-in CSRF middleware and automated security header injection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-27: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.129 (Ports: N/A) \| Asset Class: Application / Network Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-CSP-MISSING \| Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.129 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection. |
| **Security Risk:** | MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw. |
| **EvidenceCore V3 Record:** | ID: PROV-F-27-B8C36865F4 \| SHA-256: b8c36865f4f43392ea6cfb39... \| HMAC-SHA256: c3a086f5a6944f7f16152bfc... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-27):**

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.129:80) |
| **Immediate Containment:** | Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. |
| **Short-Term Hardening:** | Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files. |
| **Long-Term Strategic Fix:** | Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-28: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.129 (Ports: N/A) \| Asset Class: Application / Network Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-CSRF-BUNDLE \| Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.129:5357 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers. |
| **Security Risk:** | MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page. |
| **EvidenceCore V3 Record:** | ID: PROV-F-28-66B961F505 \| SHA-256: 66b961f505e1a2f8e879653c... \| HMAC-SHA256: 3b0651d34b3d04f733398f63... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-28):**

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send X-Frame-Options or CSP frame-ancestors header.
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.129:80) |
| **Immediate Containment:** | Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms. |
| **Short-Term Hardening:** | Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests. |
| **Long-Term Strategic Fix:** | Adopt a modern web framework with built-in CSRF middleware and automated security header injection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-29: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.130 (Ports: N/A) \| Asset Class: Workstation / SMB Peer Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |

| | |
|---|---|
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-CSP-MISSING \| Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.130 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection. |
| **Security Risk:** | MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw. |
| **EvidenceCore V3 Record:** | ID: PROV-F-29-38BAA33E55 \| SHA-256: 38baa33e5505114f4f20be70... \| HMAC-SHA256: a15507c58fbb59328ffcf045... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-29):**

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.130:80) |
| **Immediate Containment:** | Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. |
| **Short-Term Hardening:** | Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files. |
| **Long-Term Strategic Fix:** | Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-30: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.130 (Ports: N/A) \| Asset Class: Workstation / SMB Peer Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |

| | |
|---|---|
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-CSRF-BUNDLE \| Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.130:5985 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers. |
| **Security Risk:** | MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page. |
| **EvidenceCore V3 Record:** | ID: PROV-F-30-AADD60A8FB \| SHA-256: aadd60a8fb8ca581e72b4d20... \| HMAC-SHA256: 8c6990f0279e22dcc6c5c947... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-30):**

```
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send X-Frame-Options or CSP frame-ancestors header.
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.130:80) |
| **Immediate Containment:** | Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms. |
| **Short-Term Hardening:** | Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests. |
| **Long-Term Strategic Fix:** | Adopt a modern web framework with built-in CSRF middleware and automated security header injection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-31: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |

| | |
|---|---|
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-CSP-MISSING \| Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection. |
| **Security Risk:** | MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw. |
| **EvidenceCore V3 Record:** | ID: PROV-F-31-48C5125842 \| SHA-256: 48c51258421767558f3f345b... \| HMAC-SHA256: 8d6ae9c7ceb7ded01cb7da7d... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-31):**

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.139:80 missing content-security-policy header
---
Missing header: Content-Security-Policy | CWE: CWE-1021 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. |
| **Short-Term Hardening:** | Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files. |
| **Long-Term Strategic Fix:** | Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |

| | |
|---|---|
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-32: DNS Open Recursion Enabled on ISC BIND 9.4.2 (Port 53) [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-DNS-OPEN-RECURSION \| Advisory: US-CERT Alert TA13-088A / ISC BIND Recursion Access Control \| CWE: CWE-406 \| MITRE: T1498.002 (Impact — Network Denial of Service: Reflection Amplification) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-406 (Insufficient Control of Network Message Volume) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:53 |
| **Root Cause & Compliance:** | Service Hardening & Configuration Baseline Gap [PROBABLE] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | ISC BIND 9.4.2 on port 53 permits recursive DNS queries from untrusted network clients. |
| **Security Risk:** | MEDIUM — Can be abused for DNS amplification and cache-poisoning attacks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-32-0F0941B786 \| SHA-256: 0f0941b786a12ce60c880edd... \| HMAC-SHA256: 0ec9ea34a2a88af4617382db... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-32):**

```
DNS server allows recursive queries — can be abused for amplification attacks

Evidence: DNS recursion available on 192.168.195.139:53 (RA flag set)
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable open recursion in BIND `/etc/bind/named.conf.options` (`recursion no;` or `allow-recursion { 127.0.0.1; };`) and reload `named`. |
| **Short-Term Hardening:** | Upgrade ISC BIND 9.4.2 to a supported BIND 9.18 LTS release and enable response rate limiting (RRL). |
| **Long-Term Strategic Fix:** | Separate authoritative DNS servers from recursive resolvers. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `dig @192.168.195.139 example.com` from an untrusted host and confirm `status: REFUSED`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `dig @192.168.195.139 example.com` from an untrusted host and confirm `status: REFUSED`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-33: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XFO-MISSING \| Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet \| CWE: CWE-1021 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-1021 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe. |
| **Security Risk:** | MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-33-A9EE8ABF71 \| SHA-256: a9ee8abf7190284f476308a2... \| HMAC-SHA256: 5e0602810d5686b352e12442... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-33):**

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.139:80 missing x-frame-options header
---
Missing header: X-Frame-Options | CWE: CWE-1021 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration. |

| | |
|---|---|
| **Short-Term Hardening:** | Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding. |
| **Long-Term Strategic Fix:** | Enforce standard security header middleware across all web application frameworks. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-34: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-CSRF-BUNDLE \| Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/phpinfo.php |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers. |
| **Security Risk:** | MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page. |
| **EvidenceCore V3 Record:** | ID: PROV-F-34-1CCB211FF2 \| SHA-256: 1ccb211ff2aa801b4403b2a9... \| HMAC-SHA256: c3ccb144dc1b4ddb273c995f... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-34):**

```
Discovered 3 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
[DEBUG-01] Sensitive Information & Debug Disclosures (1): PHP Info Configuration Exposed at
http://192.168.195.139:80/phpinfo.php
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms. |
| **Short-Term Hardening:** | Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests. |
| **Long-Term Strategic Fix:** | Adopt a modern web framework with built-in CSRF middleware and automated security header injection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-35: Content-Security-Policy (CSP) Header Not Set [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-CSP-MISSING \| Advisory: W3C CSP Level 3 / OWASP Content Security Policy Cheat Sheet \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 24 raw observation(s) across 4 unique endpoint(s): 192.168.195.140, 192.168.195.140:8080, http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web application responses omit the 'Content-Security-Policy' header across multiple endpoints, reducing browser defense-in-depth against Cross-Site Scripting (XSS) and unauthorized script injection. |
| **Security Risk:** | MEDIUM — Lack of browser script-execution policy increases impact of any client-side injection flaw. |
| **EvidenceCore V3 Record:** | ID: PROV-F-35-893EAB2AA0 \| SHA-256: 893eab2aa077f7a0c303a2a0... \| HMAC-SHA256: fd828a2b2d9918b9d7267b1b... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-35):**

```
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain
types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks a
---
No CSP header — XSS and injection attacks not mitigated

Evidence: HTTP response from 192.168.195.140:8080 missing content-security-policy header
---
Missing header: Content-Security-Policy | CWE: CWE-1021 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Add `Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"` in Apache `httpd.conf` / `.htaccess`. |
| **Short-Term Hardening:** | Eliminate `'unsafe-inline'` and `'unsafe-eval'` script directives by migrating inline scripts to external hashed or nonce-protected JS files. |
| **Long-Term Strategic Fix:** | Enable CSP violation reporting (`report-to` / `report-uri`) to monitor policy regressions continuously. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Content-Security-Policy` response header is present without wildcard (`*`) script sources.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-36: Missing Anti-Clickjacking Protection (X-Frame-Options / frame-ancestors) [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XFO-MISSING \| Advisory: RFC 7034 / OWASP Clickjacking Defense Cheat Sheet \| CWE: CWE-1021 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-1021 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 10 raw observation(s) across 4 unique endpoint(s): 192.168.195.140, 192.168.195.140:8080, http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |

| | |
|---|---|
| **Technical Description:** | HTTP responses do not include 'X-Frame-Options' or CSP 'frame-ancestors' directives, permitting the web interface to be embedded inside an external iframe. |
| **Security Risk:** | MEDIUM — Exposes authenticated web users to UI redressing (Clickjacking) attacks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-36-2FB4164783 \| SHA-256: 2fb4164783664584de8fb8cb... \| HMAC-SHA256: d32ec75194c663c560cab5fa... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-36):**

```
The response does not protect against 'ClickJacking' attacks. It should include either
Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
---
No clickjacking protection — X-Frame-Options header missing

Evidence: HTTP response from 192.168.195.140:8080 missing x-frame-options header
---
Missing header: X-Frame-Options | CWE: CWE-1021 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Add `Header always set X-Frame-Options "DENY"` (or `"SAMEORIGIN"`) and CSP `frame-ancestors 'self'` in the web server configuration. |
| **Short-Term Hardening:** | Verify no legacy application workflows depend on cross-origin `<iframe src=...>` embedding. |
| **Long-Term Strategic Fix:** | Enforce standard security header middleware across all web application frameworks. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `X-Frame-Options: DENY` or `SAMEORIGIN` is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-37: Web Application Missing Anti-CSRF Tokens & Hardening Headers [MEDIUM · CVSS 5.4 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-CSRF-BUNDLE \| Advisory: OWASP Cross-Site Request Forgery Prevention Cheat Sheet \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.140:80, 192.168.195.140:8080, 192.168.195.140:8081 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Automated web assessment identified HTML forms lacking anti-CSRF tokens alongside missing HTTP response hardening headers. |
| **Security Risk:** | MEDIUM — State-changing web requests may be forged cross-origin if authenticated users visit a malicious page. |
| **EvidenceCore V3 Record:** | ID: PROV-F-37-F7F7A02BE8 \| SHA-256: f7f7a02be8bd03047bd2adf2... \| HMAC-SHA256: 4c77f41df1b9274ebb61a74f... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-37):**

```
Discovered 1 web vulnerabilities:
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
---
Discovered 2 web vulnerabilities:
[CSRF-01] Missing Anti-CSRF Token and SameSite Defenses: No anti-CSRF token found in HTML forms and
session cookie lacks SameSite protect
[CLICK-01] Missing Clickjacking Defense (X-Frame-Options / frame-ancestors): Endpoint does not send
X-Frame-Options or CSP frame-ancestors header.
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Implement cryptographically random per-session anti-CSRF tokens (`hash_hmac('sha256', session_id(), $secret)`) on all state-changing HTML `POST` forms. |
| **Short-Term Hardening:** | Set `SameSite=Lax` or `SameSite=Strict` on all session cookies and validate `Origin`/`Referer` headers on state-changing requests. |
| **Long-Term Strategic Fix:** | Adopt a modern web framework with built-in CSRF middleware and automated security header injection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Submit a cross-origin POST request without a valid CSRF token and confirm the server returns HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-38: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |

| | |
|---|---|
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED \| Advisory: OWASP A01:2021 — Administrative Interface Access Control \| CWE: CWE-284 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-284 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=90% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.1:80/Config |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation. |
| **Security Risk:** | MEDIUM — Expands attack surface for credential stuffing and administrative application exploits. |
| **EvidenceCore V3 Record:** | ID: PROV-F-38-9A40608317 \| SHA-256: 9a40608317729982eba3e9dd... \| HMAC-SHA256: 6866d3f05393cace06b565c3... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-38):**

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/admin: Admin panel accessible
/admin/: Admin panel accessible
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls. |
| **Short-Term Hardening:** | Enforce multi-factor authentication and TLS client certificates on all administrative web consoles. |
| **Long-Term Strategic Fix:** | Bind administrative interfaces to an isolated out-of-band management network or VPN. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-39: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |

| | |
|---|---|
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED \| Advisory: OWASP A01:2021 — Administrative Interface Access Control \| CWE: CWE-284 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-284 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/Config |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation. |
| **Security Risk:** | MEDIUM — Expands attack surface for credential stuffing and administrative application exploits. |
| **EvidenceCore V3 Record:** | ID: PROV-F-39-4E4B404A84 \| SHA-256: 4e4b404a84027951b634f337... \| HMAC-SHA256: 4f2cec9b6feab9c9003b2aab... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-39):**

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/: Admin panel accessible
/phpMyAdmin/: Admin panel accessible
/dvwa/login.php: Admin panel accessible
/mutillidae/: Admin panel accessible
/mutillidae/index.php: Admin panel accessible
/server-status: Apache server-status exposed
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls. |
| **Short-Term Hardening:** | Enforce multi-factor authentication and TLS client certificates on all administrative web consoles. |
| **Long-Term Strategic Fix:** | Bind administrative interfaces to an isolated out-of-band management network or VPN. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-40: Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE (Unauthenticated HTTP 200) \| Auth: False \| File: NONE \| DB: UI_REACHABLE_ONLY (HTTP 200 administrative interface; unauthenticated DB read/write NOT demonstrated) \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: EXPOSED_ADMIN_SURFACE \| Privilege: NONE (Unauthenticated HTTP 200) \| DataAccess: HTML_LOGIN_OR_INDEX_ONLY \| Impact: ADMINISTRATIVE_SURFACE_EXPOSURE \| EvidenceConf: 94% |
| **Access Scope Summary:** | HTTP 200 administrative interface reachable at /phpMyAdmin/; unauthenticated DB read/write not independently demonstrated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PHPMYADMIN-EXPOSED \| Advisory: phpMyAdmin Documentation — Securing Your phpMyAdmin Installation \| CWE: CWE-306 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-306 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/phpMyAdmin/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The phpMyAdmin web interface at http://192.168.195.139:80/phpMyAdmin/ returned HTTP 200. While the administrative interface is reachable without network-layer restriction, unauthenticated database read/write execution was not demonstrated in the captured evidence. |
| **Security Risk:** | MEDIUM (VALIDATED EXPOSURE, CVSS 5.3) — Publicly reachable database administration console; exposes backend MySQL authentication surface. |
| **EvidenceCore V3 Record:** | ID: PROV-F-40-28B056E9DC \| SHA-256: 28b056e9dc2bc87a1a604755... \| HMAC-SHA256: b4faf83182dd429a9576b177... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-40):**

```
[HTTP Probe 200 OK on /phpMyAdmin/ — Exposed administrative web interface; unauthenticated SQL
read/write NOT demonstrated]
Data: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="lt
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict `/phpMyAdmin/` in Apache `/etc/apache2/conf.d/phpmyadmin.conf` to localhost or administrative VPN IPs (`Require ip 127.0.0.1`) and reload Apache. |
| **Short-Term Hardening:** | Enforce cookie-based authentication (`$cfg['Servers'][$i]['auth_type'] = 'cookie'`), set `$cfg['AllowNoPassword'] = false`, and place HTTP Basic Auth in front of `/phpMyAdmin/`. |
| **Long-Term Strategic Fix:** | Remove internet/LAN-facing phpMyAdmin installations and perform database administration exclusively over SSH port-forwarding. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |

| | |
|---|---|
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-41: NFS RPC Service & Export Table Exposed (Ports 111 / 2049) [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-NFS-EXPORTS-2049 \| Advisory: CERT/CC CA-1991-21 / Linux nfs-kernel-server /etc/exports Hardening \| CWE: CWE-732 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-732 (Incorrect Permission Assignment) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139:111, 192.168.195.139:2049, 192.168.195.139 |
| **Root Cause & Compliance:** | Access Control & Network Share Misconfiguration [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Network File System (NFS) and portmapper services are reachable on TCP ports 111 and 2049 with an exported share entry. Remote filesystem mounting was not executed during the assessment. |
| **Security Risk:** | MEDIUM (VALIDATED, CVSS 6.5) — Exposed NFS daemon; if world-readable or no_root_squash exports exist, remote attackers can read or modify host files. |
| **EvidenceCore V3 Record:** | ID: PROV-F-41-EF854751D1 \| SHA-256: ef854751d10996e74fd7a95b... \| HMAC-SHA256: 66e60aeac2ab9fecb1342e18... \| Module: AutoPentest-Exploit, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-41):**

```
NFS Exports: Nmap scan report for 192.168.195.139
Host is up (0.00013s latency).

PORT STATE SERVICE
111/tcp open rpcbind
| nfs-showmount:
|_ / *
| nfs-ls: Volume /
| access: Read Lookup Modify Extend Delete NoExecute
| PERMISSION UID GI
---
NFS Exports: Nmap scan report for 192.168.195.139
Host is up (0.00088s latency).

PORT STATE SERVICE
2049/tcp open nfs
MAC Address: 00:0C:29:05:D7:6A (VMware)
---
```

```
NFS service detected. Attackers can enumerate and mount shared directories, potentially accessing
sensitive files or writing SSH keys for privilege escalation.
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Stop the NFS kernel server (`exportfs -ua && service nfs-kernel-server stop`) and remove any wildcard `/ *(rw,no_root_squash)` entry from `/etc/exports`. |
| **Short-Term Hardening:** | If NFS is required, export only dedicated non-system directories restricted to specific client IPs with `root_squash,ro,nosuid,nodev` flags. |
| **Long-Term Strategic Fix:** | Migrate network file sharing to NFSv4 with Kerberos (`sec=krb5p`) mutual authentication and encryption. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `showmount -e 192.168.195.139` and verify `/` is no longer exported to `*`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `showmount -e 192.168.195.139` and verify `/` is no longer exported to `*`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-42: PHP Configuration Diagnostic Page Exposed (/phpinfo.php) [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-PHPINFO-EXPOSED \| Advisory: OWASP A01/A05 — Forced Browsing & Diagnostic Page Exposure \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 4 raw observation(s) across 4 unique endpoint(s): http://192.168.195.139:80/phpinfo.php:, http://192.168.195.139:80/icons/:, http://192.168.195.139:80/, http://192.168.195.139:80/phpinfo.php |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The /phpinfo.php diagnostic script is publicly accessible (HTTP 200), exposing PHP runtime settings, environment variables, loaded extensions, and server filesystem paths (consolidated with OWASP A01 forced browsing telemetry). |
| **Security Risk:** | MEDIUM (CVSS 5.3) — Environment and configuration disclosure facilitating targeted web exploitation. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-42-2F41BCD36E \| SHA-256: 2f41bcd36ea185f6c5d92f40... \| HMAC-SHA256: b672ee24e294f69167365c98... \| Module: AutoPentest-OWASP, AutoPentest-AegisProbe, AutoPentest-PrivEsc |

**Captured Technical Evidence (F-42):**

```
A01 Broken Access Control: 1 finding(s)
[CWE-425] Forced Browsing: /phpinfo.php: Accessible! (200) Content: <!DOCTYPE html PUBLIC "-//W3C//DTD
XHTML 1.0 Transitional//EN" "DTD/xhtml
---
A05 Misconfiguration: 4 finding(s)
[CWE-548] Directory Listing: /icons/: Full directory contents exposed
[CWE-16] HTTP PUT Enabled: Can upload files via PUT method!
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
[CWE-200] phpinfo() at /phpinfo.php: Full PHP configuration exposed
---
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "DTD/xhtml1-transitional.dtd">
<html><head>
<style type="text/css">
body {background-color
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Remove `/var/www/phpinfo.php` immediately (`rm -f /var/www/phpinfo.php`) or block `/phpinfo.php` in Apache (`<Location /phpinfo.php> Require all denied </Location>`). |
| **Short-Term Hardening:** | Set `disable_functions = phpinfo,exec,passthru,shell_exec,system,proc_open,popen` in `/etc/php5/apache2/php.ini` and reload Apache. |
| **Long-Term Strategic Fix:** | Add pre-deployment CI checks that block diagnostic files (`phpinfo.php`, `test.php`, `.env`) from production web roots. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/phpinfo.php` and confirm HTTP 404 Not Found or 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/phpinfo.php` and confirm HTTP 404 Not Found or 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-43: Web Authentication Endpoint Missing Brute-Force Rate Limiting (/dvwa/login.php) [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-NO-RATE-LIMIT \| Advisory: OWASP A04:2021 / A07:2021 — Missing Authentication Rate Limiting \| CWE: CWE-307 \| MITRE: T1110.001 (Credential Access — Brute Force: Password Guessing) \| Taxonomy: OWASP-A04:2021 (Insecure Design) \| CWE-307 (Improper Restriction of Excessive Authentication Attempts) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/dvwa/login.php |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web login endpoint (/dvwa/login.php) processed rapid consecutive authentication requests without account lockout, throttling, or CAPTCHA challenge (consolidated from OWASP A04 testing). |
| **Security Risk:** | MEDIUM — Permits automated high-speed credential stuffing and dictionary brute-force attacks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-43-DAA99D7CE5 \| SHA-256: daa99d7ce5efbd0d0882d112... \| HMAC-SHA256: 1f0556c67a735963d3b32684... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-43):**

```
A04 Insecure Design: 2 finding(s)
[CWE-209] Verbose Error at /index.php?id='
[CWE-307] No Rate Limiting: /dvwa/login.php
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Enable request rate limiting on `/dvwa/login.php` and authentication routes using Apache `mod_evasive` / `mod_ratelimit` or Fail2Ban. |
| **Short-Term Hardening:** | Enforce progressive account lockout (e.g., 5 failed attempts -> 15-minute cooldown) and exponential backoff on authentication endpoints. |
| **Long-Term Strategic Fix:** | Integrate centralized identity provider (IdP) authentication with MFA and anomaly-based brute-force protection. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Send 15 rapid failed login POST requests to `/dvwa/login.php` and confirm HTTP 429 Too Many Requests or account lockout triggers. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Send 15 rapid failed login POST requests to `/dvwa/login.php` and confirm HTTP 429 Too Many Requests or account lockout triggers.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-44: Administrative Web Interface Reachable Without Network Restriction [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-ADMIN-EXPOSED \| Advisory: OWASP A01:2021 — Administrative Interface Access Control \| CWE: CWE-284 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-284 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=90% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 1 unique endpoint(s): http://192.168.195.140:80/Config |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Administrative web paths (/admin/, /phpMyAdmin/) are reachable over the network without IP allowlisting or VPN segmentation. |
| **Security Risk:** | MEDIUM — Expands attack surface for credential stuffing and administrative application exploits. |
| **EvidenceCore V3 Record:** | ID: PROV-F-44-1EB89C7090 \| SHA-256: 1eb89c7090b853f9eb03f826... \| HMAC-SHA256: 79f1194fa2d24e0609f8d6d7... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-44):**

```
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/: Admin panel accessible
/phpmyadmin/: Admin panel accessible
/cgi-bin/: Admin panel accessible
---
EXPOSED SENSITIVE DATA / ADMIN PANELS:
/admin/: Admin panel accessible
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Restrict `/admin/`, `/phpMyAdmin/`, and `/manager/` URI prefixes to administrative management IPs via Apache `<Location>` access controls. |
| **Short-Term Hardening:** | Enforce multi-factor authentication and TLS client certificates on all administrative web consoles. |
| **Long-Term Strategic Fix:** | Bind administrative interfaces to an isolated out-of-band management network or VPN. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request administrative paths from the untrusted assessment subnet and verify HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-45: Exposed phpMyAdmin Web Administrative Interface (/phpMyAdmin/) [MEDIUM · CVSS 5.3 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE (Unauthenticated HTTP 200) \| Auth: False \| File: NONE \| DB: UI_REACHABLE_ONLY (HTTP 200 administrative interface; unauthenticated DB read/write NOT demonstrated) \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |

| | |
|---|---|
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: EXPOSED_ADMIN_SURFACE \| Privilege: NONE (Unauthenticated HTTP 200) \| DataAccess: HTML_LOGIN_OR_INDEX_ONLY \| Impact: ADMINISTRATIVE_SURFACE_EXPOSURE \| EvidenceConf: 94% |
| **Access Scope Summary:** | HTTP 200 administrative interface reachable at /phpMyAdmin/; unauthenticated DB read/write not independently demonstrated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PHPMYADMIN-EXPOSED \| Advisory: phpMyAdmin Documentation — Securing Your phpMyAdmin Installation \| CWE: CWE-306 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-306 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=52% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=52% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.140:80/phpmyadmin/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The phpMyAdmin web interface at http://192.168.195.139:80/phpMyAdmin/ returned HTTP 200. While the administrative interface is reachable without network-layer restriction, unauthenticated database read/write execution was not demonstrated in the captured evidence. |
| **Security Risk:** | MEDIUM (VALIDATED EXPOSURE, CVSS 5.3) — Publicly reachable database administration console; exposes backend MySQL authentication surface. |
| **EvidenceCore V3 Record:** | ID: PROV-F-45-312A4ECE2D \| SHA-256: 312a4ece2df69fcf2adf4f62... \| HMAC-SHA256: 77a8fb0984d6cb0b400cdec3... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-45):**

```
[HTTP Probe 200 OK on /phpMyAdmin/ — Exposed administrative web interface; unauthenticated SQL
read/write NOT demonstrated]
Data: <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="lt
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Restrict `/phpMyAdmin/` in Apache `/etc/apache2/conf.d/phpmyadmin.conf` to localhost or administrative VPN IPs (`Require ip 127.0.0.1`) and reload Apache. |
| **Short-Term Hardening:** | Enforce cookie-based authentication (`$cfg['Servers'][$i]['auth_type'] = 'cookie'`), set `$cfg['AllowNoPassword'] = false`, and place HTTP Basic Auth in front of `/phpMyAdmin/`. |
| **Long-Term Strategic Fix:** | Remove internet/LAN-facing phpMyAdmin installations and perform database administration exclusively over SSH port-forwarding. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/phpMyAdmin/` from the assessment subnet and confirm HTTP 403 Forbidden.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-46: PostgreSQL Database Listener Exposed on Network (TCP Port 5432) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-PGSQL-PORT-EXPOSED \| Advisory: PostgreSQL listen_addresses Network Hardening Guideline \| CWE: CWE-200 \| MITRE: T1046 (Discovery — Network Service Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:5432 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | TCP port 5432 (PostgreSQL) is reachable over the network. Unauthenticated or default-credential login was not demonstrated on this host; classified as OBSERVED service exposure. |
| **Security Risk:** | MEDIUM (OBSERVED) — Network-accessible database port increases brute-force and protocol attack surface. |
| **EvidenceCore V3 Record:** | ID: PROV-F-46-3D1DA58247 \| SHA-256: 3d1da58247e58fa59769bd06... \| HMAC-SHA256: 97e3614346623400cdd1e46a... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-46):**

```
[2026-10-31 06:41:22] PostgreSQL database service on 192.168.195.1:5432.
Service: postgresql, Product: PostgreSQL DB, Version: 9.6.0 or later
Database exposed on network. Default credential testing pending.
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Bind PostgreSQL to `127.0.0.1` (`listen_addresses = 'localhost'` in `postgresql.conf`) and restrict TCP port 5432 via host firewall rules to authorized application servers only. |
| **Short-Term Hardening:** | Enforce `scram-sha-256` authentication and TLS client connections (`hostssl`) in `pg_hba.conf`. |
| **Long-Term Strategic Fix:** | Place all database listeners in an isolated database VLAN with zero direct routing from user/workstation segments. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/postgresql/8.3/main/pg_hba.conf` and `postgresql.conf` (`cp -p pg_hba.conf pg_hba.conf.bak`); run `pg_ctl reload` to revert if dependent local services lose DB connectivity. |
| **Verification & Closure Rule:** | Run `nmap -p 5432 <host>` from the assessment subnet and confirm TCP port 5432 is `closed` or `filtered`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 5432 <host>` from the assessment subnet and confirm TCP port 5432 is `closed` or `filtered`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-47: End-of-Life OpenSSH 4.7p1 Service Banner Observed (TCP Port 22) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |

| | |
|---|---|
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-OPENSSH-EOL-47P1 \| Advisory: OpenSSH Legacy Lifecycle & Backported Patch Verification Advisory \| CWE: CWE-1104 \| MITRE: T1021.004 (Lateral Movement — Remote Services: SSH) \| Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) \| CWE-1104 (Use of Unmaintained Third Party Components) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:22 |
| **Root Cause & Compliance:** | Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | The SSH daemon runs an end-of-life OpenSSH 4.7p1 Debian-8ubuntu1 release observed via service banner fingerprinting. |
| **Security Risk:** | MEDIUM (OBSERVED) — Legacy SSH daemon version; verify distribution backported patches or upgrade OS. |
| **EvidenceCore V3 Record:** | ID: PROV-F-47-B35CFF918E \| SHA-256: b35cff918e6583a53cf397c6... \| HMAC-SHA256: 53fcd1b701beac8c039d842e... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-47):**

```
Legacy OpenSSH versions vulnerable to information leak and authentication bypass

Evidence: Banner match on 192.168.195.139:22: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict SSH access on port 22 to authorized management IPs via host firewall (`ufw allow from <mgmt_subnet> to any port 22`). |
| **Short-Term Hardening:** | Upgrade OpenSSH 4.7p1 to a supported release (>= 9.x) and disable legacy CBC ciphers and SHA-1 MACs in `sshd_config`. |
| **Long-Term Strategic Fix:** | Migrate the underlying Ubuntu 8.04 host to a supported LTS OS release. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -sV -p 22 --script ssh2-enum-algos` and confirm modern OpenSSH version and cipher suite. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 22 --script ssh2-enum-algos` and confirm modern OpenSSH version and cipher suite.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-48: Java RMI Registry Exposed on Network (TCP Port 1099) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |

| | |
|---|---|
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-JAVA-RMI-1099 \| Advisory: Oracle Java RMI / GNU Classpath grmiregistry Deserialization Exposure \| CWE: CWE-502 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A08:2021 (Software and Data Integrity Failures) \| CWE-502 (Deserialization of Untrusted Data) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:1099 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | GNU Classpath grmiregistry listener is exposed on TCP port 1099; remote class loading or deserialization payload execution was not performed. |
| **Security Risk:** | MEDIUM (OBSERVED) — Exposed Java RMI registry surface susceptible to insecure deserialization if default class loaders are active. |
| **EvidenceCore V3 Record:** | ID: PROV-F-48-EFCCAEC01F \| SHA-256: efccaec01fee1bd46f4045dd... \| HMAC-SHA256: 2d21c07ec9fcc52710851f2a... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-48):**

```
Java RMI exploitable: Nmap scan report for 192.168.195.139
Host is up (0.00013s latency).

PORT STATE SERVICE
1099/tcp open rmiregistry
| rmi-vuln-classloader:
| VULNERABLE:
| RMI registry default configuration remote code execution vulnerability
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Stop the `grmiregistry` / Java RMI daemon listening on TCP port 1099 and block port 1099 at the host firewall (`iptables -A INPUT -p tcp --dport 1099 -j DROP`). |
| **Short-Term Hardening:** | If Java RMI is required locally, bind it strictly to `127.0.0.1` and enable JEP 290 serialization filtering (`jdk.serialFilter`). |
| **Long-Term Strategic Fix:** | Decommission legacy Java RMI services in favor of mutually authenticated TLS APIs. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -p 1099 192.168.195.139` and confirm TCP port 1099 is `closed` or `filtered`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 1099 192.168.195.139` and confirm TCP port 1099 is `closed` or `filtered`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-49: MySQL Database Listener Exposed on Network (TCP Port 3306) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-MYSQL-PORT-EXPOSED \| Advisory: MySQL bind-address Network Exposure Guideline \| CWE: CWE-200 \| MITRE: T1046 (Discovery — Network Service Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:3306 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | MySQL 5.0.51a database listener is reachable on TCP port 3306; unauthenticated login was not demonstrated during the assessment. |
| **Security Risk:** | MEDIUM (OBSERVED) — Network-accessible database port increases brute-force and protocol attack surface. |
| **EvidenceCore V3 Record:** | ID: PROV-F-49-CC75662DDE \| SHA-256: cc75662dde35bb8cbbf0077f... \| HMAC-SHA256: cc1666c4b64a45aec897a877... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-49):**

```
[2026-10-31 06:26:32] MySQL database service on 192.168.195.139:3306.
Service: mysql, Product: MySQL, Version: 5.0.51a-3ubuntu5
Database exposed on network. Default credential testing pending.
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Bind MySQL to `127.0.0.1` (`bind-address = 127.0.0.1` in `/etc/mysql/my.cnf`) and restart `mysqld` so TCP port 3306 is not exposed to the network. |
| **Short-Term Hardening:** | Remove anonymous MySQL accounts, require strong passwords for `root@localhost`, and revoke remote root login (`DELETE FROM mysql.user WHERE User='root' AND Host NOT IN ('localhost', '127.0.0.1')`). |
| **Long-Term Strategic Fix:** | Upgrade MySQL 5.0.51a to MySQL 8.0 LTS or MariaDB 10.11 LTS. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -p 3306 192.168.195.139` from the network and confirm port 3306 is `closed` or `filtered`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 3306 192.168.195.139` from the network and confirm port 3306 is `closed` or `filtered`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-50: VNC Remote Desktop Service Exposed on TCP Port 5900 (Protocol 3.3) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-VNC-5900 \| Advisory: RFB Protocol 3.3 VNC Authentication & Encryption Guideline \| CWE: CWE-287 \| MITRE: T1021.001 (Lateral Movement — Remote Services: Remote Desktop Protocol) \| Taxonomy: OWASP-A07:2021 (Identification and Authentication Failures) \| CWE-287 (Improper Authentication) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:5900 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | VNC remote desktop service on TCP port 5900 was fingerprinted (RFB protocol 3.3); authentication bypass or password brute-forcing was not executed. |
| **Security Risk:** | MEDIUM (OBSERVED) — Exposed remote desktop protocol on internal subnet. |
| **EvidenceCore V3 Record:** | ID: PROV-F-50-BD7534057A \| SHA-256: bd7534057a4a365ac3b9a9b0... \| HMAC-SHA256: c107734209a0bc268f161e51... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-50):**

```
VNC RealVNC allows authentication bypass via modified client

Evidence: Banner match on 192.168.195.139:5900: RFB 003.003
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Stop the VNC server on TCP port 5900 (`vncserver -kill :0`) and block port 5900 at the host firewall. |
| **Short-Term Hardening:** | If VNC is required, bind `Xvnc` to `-localhost` only, enforce a strong VNC password, and tunnel access exclusively over SSH. |
| **Long-Term Strategic Fix:** | Upgrade from legacy RFB 3.3 to modern remote management with MFA. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -p 5900 192.168.195.139` from the subnet and confirm port 5900 is `closed`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 5900 192.168.195.139` from the subnet and confirm port 5900 is `closed`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-51: X11 Display Server Listener Exposed (TCP Port 6000) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-X11-PORT-6000 \| Advisory: X.Org X11 Server -nolisten tcp Hardening Guideline \| CWE: CWE-306 \| MITRE: T1113 (Collection — Screen Capture) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-306 (Missing Authentication for Critical Function) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:6000 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | X11 display server TCP port 6000 is open; unauthenticated display capture or keystroke logging was not verified via x11-access. |
| **Security Risk:** | MEDIUM (OBSERVED) — Exposed X11 TCP listener on port 6000. |
| **EvidenceCore V3 Record:** | ID: PROV-F-51-7E53A7B986 \| SHA-256: 7e53a7b986f0c1f73667103c... \| HMAC-SHA256: b5a40b3c34df3f5422cd6a2d... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-51):**

```
X11 no-auth! Can capture display. Nmap scan report for 192.168.195.139
Host is up (0.00088s latency).

PORT STATE SERVICE
6000/tcp open X11
MAC Address: 00:0C:29:0
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable X11 TCP listening by adding `-nolisten tcp` to the X server startup configuration (`/etc/X11/xinit/xserverrc` or display manager config) and block TCP port 6000. |
| **Short-Term Hardening:** | Terminate any unauthenticated Xvfb/X11 server processes on headless server hosts. |
| **Long-Term Strategic Fix:** | Remove X11 desktop packages from server base images. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -p 6000 192.168.195.139` and confirm port 6000 is `closed`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -p 6000 192.168.195.139` and confirm port 6000 is `closed`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-52: End-of-Life OpenSSH 4.7p1 Service Banner Observed (TCP Port 22) [MEDIUM · CVSS 5.3 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-OPENSSH-EOL-47P1 \| Advisory: OpenSSH Legacy Lifecycle & Backported Patch Verification Advisory \| CWE: CWE-1104 \| MITRE: T1021.004 (Lateral Movement — Remote Services: SSH) \| Taxonomy: OWASP-A06:2021 (Vulnerable and Outdated Components) \| CWE-1104 (Use of Unmaintained Third Party Components) \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140:22 |
| **Root Cause & Compliance:** | Patch & Lifecycle Management Deficit (EOL Software) [DIRECTLY_ESTABLISHED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | The SSH daemon runs an end-of-life OpenSSH 4.7p1 Debian-8ubuntu1 release observed via service banner fingerprinting. |
| **Security Risk:** | MEDIUM (OBSERVED) — Legacy SSH daemon version; verify distribution backported patches or upgrade OS. |
| **EvidenceCore V3 Record:** | ID: PROV-F-52-321760211F \| SHA-256: 321760211f264838b3fe1512... \| HMAC-SHA256: 112ecf16c4eddac33fade280... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-52):**

```
Legacy OpenSSH versions vulnerable to information leak and authentication bypass

Evidence: Banner match on 192.168.195.140:22: SSH-2.0-OpenSSH_5.3p1 Debian-3ubuntu4
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Restrict SSH access on port 22 to authorized management IPs via host firewall (`ufw allow from <mgmt_subnet> to any port 22`). |
| **Short-Term Hardening:** | Upgrade OpenSSH 4.7p1 to a supported release (>= 9.x) and disable legacy CBC ciphers and SHA-1 MACs in `sshd_config`. |
| **Long-Term Strategic Fix:** | Migrate the underlying Ubuntu 8.04 host to a supported LTS OS release. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `nmap -sV -p 22 --script ssh2-enum-algos` and confirm modern OpenSSH version and cipher suite. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `nmap -sV -p 22 --script ssh2-enum-algos` and confirm modern OpenSSH version and cipher suite.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-53: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [MEDIUM · CVSS 0.0 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: NONE \| Impact: EXPOSURE_ONLY \| EvidenceConf: 38% |
| **Access Scope Summary:** | Port-open / service banner observation only; vulnerability NOT verified |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMB-445-CANDIDATE \| Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) \| CWE: CWE-200 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A06:2021 (Vulnerable Components) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Conditional CVE-2017-0144 severity (9.8) is held in reserve pending protocol verification. |
| **Security Risk:** | MEDIUM (OBSERVED, CVSS 0.0 Active / 9.8 Conditional) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies. |
| **EvidenceCore V3 Record:** | ID: PROV-F-53-C9280A2E4B \| SHA-256: c9280a2e4bc3f4bb4b8b2e72... \| HMAC-SHA256: 2c465c20f895b700181d9a5c... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-53):**

```
[2026-10-31 06:41:22] TCP connection to 192.168.195.1:445 succeeded.
Service: microsoft-ds, Product: unknown, Version: unknown
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.1
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only. |
| **Short-Term Hardening:** | Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed. |
| **Long-Term Strategic Fix:** | Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |

| | |
|---|---|
| **Verification & Closure Rule:** | Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-54: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [MEDIUM · CVSS 0.0 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.130 (Ports: N/A) \| Asset Class: Workstation / SMB Peer Host (STANDARD) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: NONE \| Impact: EXPOSURE_ONLY \| EvidenceConf: 38% |
| **Access Scope Summary:** | Port-open / service banner observation only; vulnerability NOT verified |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMB-445-CANDIDATE \| Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) \| CWE: CWE-200 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A06:2021 (Vulnerable Components) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.130 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Conditional CVE-2017-0144 severity (9.8) is held in reserve pending protocol verification. |
| **Security Risk:** | MEDIUM (OBSERVED, CVSS 0.0 Active / 9.8 Conditional) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies. |
| **EvidenceCore V3 Record:** | ID: PROV-F-54-05CD375584 \| SHA-256: 05cd375584e26b9ae23d44a6... \| HMAC-SHA256: 64a0e0fc94d72c5e8d15cb00... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-54):**

```
[2026-10-31 06:37:51] TCP connection to 192.168.195.130:445 succeeded.
Service: microsoft-ds, Product: Microsoft Windows Server 2008 R2 - 2012 microsoft-ds, Version: unknown
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.130
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.130:80) |
| **Immediate Containment:** | Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only. |
| **Short-Term Hardening:** | Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed. |
| **Long-Term Strategic Fix:** | Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-55: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [MEDIUM · CVSS 0.0 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: NONE \| Impact: EXPOSURE_ONLY \| EvidenceConf: 38% |
| **Access Scope Summary:** | Port-open / service banner observation only; vulnerability NOT verified |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMB-445-CANDIDATE \| Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) \| CWE: CWE-200 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A06:2021 (Vulnerable Components) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Conditional CVE-2017-0144 severity (9.8) is held in reserve pending protocol verification. |
| **Security Risk:** | MEDIUM (OBSERVED, CVSS 0.0 Active / 9.8 Conditional) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies. |
| **EvidenceCore V3 Record:** | ID: PROV-F-55-411415889C \| SHA-256: 411415889cc7f97a76f61528... \| HMAC-SHA256: 93b3c066c3044dc2ad47c069... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-55):**

```
[2026-10-31 06:26:32] TCP connection to 192.168.195.139:445 succeeded.
Service: netbios-ssn, Product: Samba smbd, Version: 3.X - 4.X
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.139
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only. |
| **Short-Term Hardening:** | Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed. |

| | |
|---|---|
| **Long-Term Strategic Fix:** | Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-56: SMB Port 445 Exposed — Unverified MS17-010 (EternalBlue) Candidate [MEDIUM · CVSS 0.0 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: NONE \| Impact: EXPOSURE_ONLY \| EvidenceConf: 38% |
| **Access Scope Summary:** | Port-open / service banner observation only; vulnerability NOT verified |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-0144 \| Custom ID: XSTRIKE-SMB-445-CANDIDATE \| Advisory: Microsoft Security Bulletin MS17-010 (Unverified Port-Open Candidate) \| CWE: CWE-200 \| MITRE: T1210 (Lateral Movement — Exploitation of Remote Services) \| Taxonomy: OWASP-A06:2021 (Vulnerable Components) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | TCP port 445 (SMB) is reachable. As recorded in the tool output, this is a port-open observation only; SMBv1/MS17-010 vulnerability status has NOT been verified and no exploitation was performed. Conditional CVE-2017-0144 severity (9.8) is held in reserve pending protocol verification. |
| **Security Risk:** | MEDIUM (OBSERVED, CVSS 0.0 Active / 9.8 Conditional) — Exposed SMB attack surface; requires explicit MS17-010 protocol validation to determine whether CVE-2017-0144 applies. |
| **EvidenceCore V3 Record:** | ID: PROV-F-56-3EFCD4CA82 \| SHA-256: 3efcd4ca8219013d5c08e754... \| HMAC-SHA256: 26a5d9042903b343c06f9b7e... \| Module: AutoPentest-VulnScan |

**Captured Technical Evidence (F-56):**

```
[2026-10-31 06:32:47] TCP connection to 192.168.195.140:445 succeeded.
Service: netbios-ssn, Product: Samba smbd, Version: 3.X - 4.X
NOTE: Port-open detection only. SMBv1/EternalBlue status NOT verified.
Verification required: nmap --script smb-vuln-ms17-010 192.168.195.140
Or Metasploit: auxiliary/scanner/smb/smb_ms17_010
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |

| | |
|---|---|
| **Immediate Containment:** | Restrict TCP port 445 access using host firewall rules (`New-NetFirewallRule` on Windows or `iptables`/`ufw` on Linux) to authorized management hosts only. |
| **Short-Term Hardening:** | Run an explicit SMB dialect and MS17-010 verification check (`nmap --script smb-vuln-ms17-010,smb-protocols -p 445 <target>`) and ensure Microsoft security update MS17-010 or Samba >= 4.6.4 is installed. |
| **Long-Term Strategic Fix:** | Enforce SMBv3 with mandatory SMB signing (`RequireSecuritySignature=1`) and segment SMB traffic across VLAN boundaries. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Confirm `nmap --script smb-protocols -p 445` reports SMBv1 disabled and `smb-vuln-ms17-010` returns clean.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-57: Developer / Debugging Comments Exposed in HTML/JS Source [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-ZAP-COMMENTS \| Advisory: OWASP ZAP Alert 10027 — Information Disclosure: Suspicious Comments \| CWE: CWE-615 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-615 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=90% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTML and JavaScript responses contain developer comments that may disclose internal application logic, hints, or endpoints. |
| **Security Risk:** | LOW — Information disclosure in client-accessible markup. |
| **EvidenceCore V3 Record:** | ID: PROV-F-57-87983E3E08 \| SHA-256: 87983e3e08dca63f49686b8b... \| HMAC-SHA256: b49133800de8a4605cc3b9cd... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-57):**

```
The response appears to contain suspicious comments which may help an attacker.
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |

| | |
|---|---|
| **Immediate Containment:** | Strip developer, TODO, and debugging HTML/JS comments from production templates in `/var/www/`. |
| **Short-Term Hardening:** | Audit client-side HTML and JavaScript files to ensure no hints, credentials, or internal SQL queries are embedded in comments. |
| **Long-Term Strategic Fix:** | Add HTML/JS minification that strips comments in the build pipeline. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect page source via `curl -s` and confirm developer/debugging comments are removed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect page source via `curl -s` and confirm developer/debugging comments are removed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-58: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY \| Advisory: W3C Permissions Policy Specification \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 (Protection Mechanism Failure) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer. |
| **Security Risk:** | LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution. |
| **EvidenceCore V3 Record:** | ID: PROV-F-58-9B6D602736 \| SHA-256: 9b6d6027369ae4c50fdc5b87... \| HMAC-SHA256: 9f0671f57171fe46ff81c648... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-58):**

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |

| | |
|---|---|
| **Immediate Containment:** | Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration. |
| **Short-Term Hardening:** | Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs. |
| **Long-Term Strategic Fix:** | Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-59: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-REFERRER-POLICY \| Advisory: W3C Referrer Policy / OWASP Secure Headers \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation. |
| **Security Risk:** | LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins. |
| **EvidenceCore V3 Record:** | ID: PROV-F-59-4D3954EE1B \| SHA-256: 4d3954ee1be933c1fa96ad77... \| HMAC-SHA256: 626f57a837d5a828c68cf503... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-59):**

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration. |

| | |
|---|---|
| **Short-Term Hardening:** | Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers. |
| **Long-Term Strategic Fix:** | Include `Referrer-Policy` in baseline web security header automated tests. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-60: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-SERVER-BANNER \| Advisory: Apache ServerTokens Prod / CIS Web Server Hardening \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 55 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints. |
| **Security Risk:** | LOW — Facilitates precise vulnerability fingerprinting by external adversaries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-60-4EF53AC123 \| SHA-256: 4ef53ac12322b6d32310c261... \| HMAC-SHA256: ce080f1ab433691be6a7d1fc... \| Module: AutoPentest-ZAP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-60):**

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server: Splunkd | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |

| | |
|---|---|
| **Immediate Containment:** | Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). |
| **Short-Term Hardening:** | Configure reverse-proxy header sanitization to strip detailed upstream server version banners. |
| **Long-Term Strategic Fix:** | Maintain automated configuration management to prevent verbose banner headers in production. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-61: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-HSTS-MISSING \| Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet \| CWE: CWE-319 \| MITRE: T1557 (Credential Access — Adversary-in-the-Middle) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-319 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 4 raw observation(s) across 3 unique endpoint(s): 192.168.195.1:8080, 192.168.195.1, 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks. |
| **Security Risk:** | LOW — Enables protocol downgrade and cleartext session interception on untrusted networks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-61-1C1640C0A7 \| SHA-256: 1c1640c0a70976c844ec9833... \| HMAC-SHA256: 68f908f8c358f333cc79c8d6... \| Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-61):**

```
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.1:8080 missing strict-transport-security header
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
```

```
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, Content-Security-Policy
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host. |
| **Short-Term Hardening:** | Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints. |
| **Long-Term Strategic Fix:** | Standardize internal PKI certificate automation (ACME/step-ca) across all web services. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-62: Session Cookie Missing 'HttpOnly' Flag [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-COOKIE-HTTPONLY \| Advisory: OWASP Session Management Cheat Sheet — HttpOnly \| CWE: CWE-1004 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-1004 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 80 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Cookies are set without the 'HttpOnly' flag, permitting client-side JavaScript ('document.cookie') to read session identifiers. |
| **Security Risk:** | LOW — Enables session theft if combined with a Cross-Site Scripting (XSS) vulnerability. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-62-811C0B0C8D \| SHA-256: 811c0b0c8dd7dc5934aee528... \| HMAC-SHA256: ce6d2556b1150952457b02fe... \| Module: AutoPentest-ZAP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-62):**

```
A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by
JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be
---
Cookie: cval=1915971765... | CWE: CWE-1004 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Set `session.cookie_httponly = 1` in `/etc/php5/apache2/php.ini` and add `HttpOnly` to all application `setcookie()` calls. |
| **Short-Term Hardening:** | Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; HttpOnly"` for legacy applications. |
| **Long-Term Strategic Fix:** | Enforce automated DAST checks verifying `HttpOnly` on all session identifiers. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-63: Session Cookie Missing 'SameSite' Attribute [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-COOKIE-SAMESITE \| Advisory: RFC 6265bis — SameSite Cookie Attribute \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 220 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Session cookies are issued without the 'SameSite=Lax' or 'SameSite=Strict' attribute, allowing cookies to be transmitted in cross-origin requests. |
| **Security Risk:** | LOW — Weakens browser defense against Cross-Site Request Forgery (CSRF). |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-63-AFBCB2DA9C \| SHA-256: afbcb2da9cf03106737efcc0... \| HMAC-SHA256: e95745b6c62aed470eaa590a... \| Module: AutoPentest-ZAP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-63):**

```
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-sit
---
Cookie: cval | CWE: CWE-352 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Update PHP/application session configuration (`session.cookie_samesite = "Lax"` or `"Strict"`) or add Apache `Header edit Set-Cookie ^(.*)$ "$1; SameSite=Lax"`. |
| **Short-Term Hardening:** | Audit cross-site authentication flows and enforce `SameSite=Strict` on high-privilege session cookies. |
| **Long-Term Strategic Fix:** | Standardize session management using framework-managed `__Host-` prefixed cookies. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-64: Unix Timestamp Disclosure in HTTP Response Content [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-ZAP-TIMESTAMP \| Advisory: OWASP ZAP Alert 10096 — Timestamp Disclosure \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 288 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | OWASP ZAP identified Unix epoch timestamps embedded within HTTP response bodies/headers across multiple application endpoints. |

| | |
|---|---|
| **Security Risk:** | LOW — Minor informational leakage of server clock or cache generation timestamps. |
| **EvidenceCore V3 Record:** | ID: PROV-F-64-794877E490 \| SHA-256: 794877e4900f4fcfdc38b1a0... \| HMAC-SHA256: f44f349525ee15aa58dba446... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-64):**

```
A timestamp was disclosed by the application/web server. - Unix
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Configure ETag generation to exclude inode/mtime timestamps (`FileETag None` in Apache) and remove Unix epoch values from unauthenticated HTML responses. |
| **Short-Term Hardening:** | Ensure static asset cache keys use content hashes rather than server timestamps. |
| **Long-Term Strategic Fix:** | Standardize response header normalization across web servers. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect HTTP response headers and body for 10-digit Unix epoch patterns and confirm none are disclosed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect HTTP response headers and body for 10-digit Unix epoch patterns and confirm none are disclosed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-65: Verbose Content Body Returned in HTTP Redirect Response (Big Redirect) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-ZAP-BIG-REDIRECT \| Advisory: OWASP ZAP Alert 10044 — Big Redirect Detected \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 74 raw observation(s) across 1 unique endpoint(s): 192.168.195.1 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP 3xx redirect responses contain a larger-than-expected HTML body, which may indicate page content is rendered despite a redirect header. |
| **Security Risk:** | LOW — Verify that unauthenticated redirects call 'exit()' immediately after setting the Location header. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-65-979D261826 \| SHA-256: 979d261826fb1f1d0eb78355... \| HMAC-SHA256: 2cef7cff3c27ce1c234bd00a... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-65):**

```
The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensi
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Ensure all PHP authentication/redirect handlers call `exit;` immediately after `header('Location: ...');` so authenticated page content is not rendered in the 301/302 body. |
| **Short-Term Hardening:** | Audit all 3xx responses across Mutillidae/DVWA/phpMyAdmin to ensure response bodies contain zero sensitive HTML. |
| **Long-Term Strategic Fix:** | Use centralized router middleware for HTTP redirects. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Issue `curl -i http://<target>/<redirect_path>` and confirm the 302 response body length is minimal with no sensitive HTML. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Issue `curl -i http://<target>/<redirect_path>` and confirm the 302 response body length is minimal with no sensitive HTML.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-66: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-DIR-LISTING \| Advisory: Apache Options -Indexes Hardening Guideline \| CWE: CWE-548 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-548 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, http://192.168.195.1:80/images/: |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks). |
| **Security Risk:** | LOW — Enables unauthenticated enumeration of static and backup files. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-66-386B2E082F \| SHA-256: 386b2e082f5c42338887db7a... \| HMAC-SHA256: 437330ecfa8dcf947c743289... \| Module: AutoPentest-ZAP, AutoPentest-OWASP |

**Captured Technical Evidence (F-66):**

```
It is possible to view the directory listing. Directory listing may reveal hidden scripts, include
files, backup source files, etc. which can be accessed to read sensitive information.
---
It is possible to view a listing of the directory contents. Directory listings may reveal hidden
scripts, include files, backup source files, etc., which can be accessed to reveal sensitive informatio
---
A05 Misconfiguration: 2 finding(s)
[CWE-548] Directory Listing: /images/: Full directory contents exposed
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`. |
| **Short-Term Hardening:** | Remove default Apache `/icons/` alias or restrict it to specific file extensions. |
| **Long-Term Strategic Fix:** | Enforce `Options -Indexes` in baseline web server hardening templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-67: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: N/A) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XCTO-MISSING \| Advisory: OWASP Secure Headers Project — X-Content-Type-Options \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 45 raw observation(s) across 2 unique endpoint(s): 192.168.195.1, 192.168.195.1:8080 |

| | |
|---|---|
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types. |
| **Security Risk:** | LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content. |
| **EvidenceCore V3 Record:** | ID: PROV-F-67-DBC683DC10 \| SHA-256: dbc683dc106af6f4ebb48a09... \| HMAC-SHA256: 2a0473703d9a5bc8e921a416... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln |

**Captured Technical Evidence (F-67):**

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.1:8080 missing x-content-type-options header
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`). |
| **Short-Term Hardening:** | Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers. |
| **Long-Term Strategic Fix:** | Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-68: robots.txt Disallows Sensitive Web Paths [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.1 (Ports: 8000) \| Asset Class: Hypervisor / Management Host Gateway (INFRASTRUCTURE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-ROBOTS-TXT \| Advisory: OWASP WSTG-INFO-03 — Review Webserver Metafiles for Information Leakage \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 (Exposure of Sensitive Information) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.1:8000 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The /robots.txt file is publicly readable and lists internal or administrative URI paths intended to be hidden from search crawlers. |
| **Security Risk:** | LOW — Provides attackers with a reconnaissance map of internal application directories. |
| **EvidenceCore V3 Record:** | ID: PROV-F-68-D430CB0DB2 \| SHA-256: d430cb0db2e09277de6361de... \| HMAC-SHA256: 8f6af4aa296ac09dc4c52a22... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-68):**

```
User-agent: *
Disallow: /
| CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Windows / VMware Host Gateway (VMware Auth :902/:912, SMB :445, DNS :53) |
| **Immediate Containment:** | Remove sensitive administrative or internal path entries from `/var/www/robots.txt` and enforce proper authentication on every sensitive directory. |
| **Short-Term Hardening:** | Use `<meta name="robots" content="noindex, nofollow">` inside authenticated pages rather than listing secret paths in a public `robots.txt`. |
| **Long-Term Strategic Fix:** | Audit all Paths formerly listed in `robots.txt` to ensure none rely on security-by-obscurity. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Snapshot VM/container state and backup `/etc/inetd.conf` / daemon config on `192.168.195.1` before stopping service on port `8000`; restore config snapshot if rollback is required. |
| **Verification & Closure Rule:** | Fetch `http://192.168.195.139:80/robots.txt` and verify no sensitive internal directories are enumerated. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Fetch `http://192.168.195.139:80/robots.txt` and verify no sensitive internal directories are enumerated.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-69: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.129 (Ports: N/A) \| Asset Class: Application / Network Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-SERVER-BANNER \| Advisory: Apache ServerTokens Prod / CIS Web Server Hardening \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.129 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints. |
| **Security Risk:** | LOW — Facilitates precise vulnerability fingerprinting by external adversaries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-69-7166A50DB1 \| SHA-256: 7166a50db1a7d84799884ff6... \| HMAC-SHA256: 98afd8e4d2e59e84851ffbef... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-69):**

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.129:80) |
| **Immediate Containment:** | Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). |
| **Short-Term Hardening:** | Configure reverse-proxy header sanitization to strip detailed upstream server version banners. |
| **Long-Term Strategic Fix:** | Maintain automated configuration management to prevent verbose banner headers in production. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-70: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.130 (Ports: N/A) \| Asset Class: Workstation / SMB Peer Host (STANDARD) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-SERVER-BANNER \| Advisory: Apache ServerTokens Prod / CIS Web Server Hardening \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 1 unique endpoint(s): 192.168.195.130 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints. |
| **Security Risk:** | LOW — Facilitates precise vulnerability fingerprinting by external adversaries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-70-0A8D257646 \| SHA-256: 0a8d2576469461dba8076440... \| HMAC-SHA256: 3e5fd20a8ab833748b344bc5... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-70):**

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.130:80) |
| **Immediate Containment:** | Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). |
| **Short-Term Hardening:** | Configure reverse-proxy header sanitization to strip detailed upstream server version banners. |
| **Long-Term Strategic Fix:** | Maintain automated configuration management to prevent verbose banner headers in production. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-71: Apache HTTP OPTIONS Allow Header Heuristic (Optionsbleed CVE-2017-9798 Candidate) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: CVE-2017-9798 \| Custom ID: XSTRIKE-APACHE-OPTIONSBLEED \| Advisory: Apache Security Advisory CVE-2017-9798 (Optionsbleed) \| CWE: CWE-200 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 (Exposure of Sensitive Information) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |

| | |
|---|---|
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.139:80 |
| **Root Cause & Compliance:** | Service Hardening & Configuration Baseline Gap [PROBABLE] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Apache httpd 2.2.8 was flagged by a banner/header heuristic for CVE-2017-9798 (Optionsbleed); corrupted Allow header memory leakage was not observed. |
| **Security Risk:** | LOW (OBSERVED) — Version/header heuristic; verify Apache Limit/Options directives. |
| **EvidenceCore V3 Record:** | ID: PROV-F-71-C8F952103D \| SHA-256: c8f952103db3f36bc4c3dcd6... \| HMAC-SHA256: 7bbfebf0a4d94f5946977fce... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-71):**

```
Apache 2.2.x-2.4.x Optionsbleed information leak via OPTIONS requests

Evidence: Banner match on 192.168.195.139:80: HTTP/1.1 200 OK
Date: Sat, 31 Oct 2026 10:53:30 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html

<html><head><title>Metaspl
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Audit Apache `<Directory>` and `.htaccess` files to ensure `Limit` and `Options` directives contain only valid HTTP methods and tokens, or disable `OPTIONS` via `RewriteEngine`. |
| **Short-Term Hardening:** | Apply the CVE-2017-9798 patch or upgrade Apache httpd to 2.4.x. |
| **Long-Term Strategic Fix:** | Include `.htaccess` syntax validation in deployment checks. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Send repeated `curl -i -X OPTIONS http://192.168.195.139/` requests and confirm clean, deterministic `Allow:` headers. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Send repeated `curl -i -X OPTIONS http://192.168.195.139/` requests and confirm clean, deterministic `Allow:` headers.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-72: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |

| | |
|---|---|
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY \| Advisory: W3C Permissions Policy Specification \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 (Protection Mechanism Failure) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer. |
| **Security Risk:** | LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution. |
| **EvidenceCore V3 Record:** | ID: PROV-F-72-C41FEE5081 \| SHA-256: c41fee508178852d5b00be43... \| HMAC-SHA256: 366dde18c9046ddcb5c42f91... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-72):**

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration. |
| **Short-Term Hardening:** | Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs. |
| **Long-Term Strategic Fix:** | Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-73: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |

| | |
|---|---|
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-REFERRER-POLICY \| Advisory: W3C Referrer Policy / OWASP Secure Headers \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation. |
| **Security Risk:** | LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins. |
| **EvidenceCore V3 Record:** | ID: PROV-F-73-579B019A38 \| SHA-256: 579b019a383092aabdd09680... \| HMAC-SHA256: 3bd76ebb5f2e715d68a8a3e3... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-73):**

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration. |
| **Short-Term Hardening:** | Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers. |
| **Long-Term Strategic Fix:** | Include `Referrer-Policy` in baseline web security header automated tests. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-74: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-SERVER-BANNER \| Advisory: Apache ServerTokens Prod / CIS Web Server Hardening \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints. |
| **Security Risk:** | LOW — Facilitates precise vulnerability fingerprinting by external adversaries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-74-8AE350E466 \| SHA-256: 8ae350e46676fc9ef04af9bf... \| HMAC-SHA256: 9cf1871903015cc6024fd8a5... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-74):**

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server header exposes version: Apache/2.2.8 (Ubuntu) DAV/2

Evidence: Server: Apache/2.2.8 (Ubuntu) DAV/2
---
Server: Apache/2.2.8 (Ubuntu) DAV/2 | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). |
| **Short-Term Hardening:** | Configure reverse-proxy header sanitization to strip detailed upstream server version banners. |
| **Long-Term Strategic Fix:** | Maintain automated configuration management to prevent verbose banner headers in production. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-75: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |

| | |
|---|---|
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-HSTS-MISSING \| Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet \| CWE: CWE-319 \| MITRE: T1557 (Credential Access — Adversary-in-the-Middle) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-319 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139:80, http://192.168.195.139:80/dvwa/login.php, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks. |
| **Security Risk:** | LOW — Enables protocol downgrade and cleartext session interception on untrusted networks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-75-5F53D90274 \| SHA-256: 5f53d90274571ce29044085e... \| HMAC-SHA256: a4b04aeebdbe6c4fd059904e... \| Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-75):**

```
A02 Cryptographic Failures: 2 finding(s)
[CWE-319] Login over HTTP: /dvwa/login.php
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
---
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.139:80 missing strict-transport-security header
---
Missing header: Strict-Transport-Security | CWE: CWE-319 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host. |
| **Short-Term Hardening:** | Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints. |
| **Long-Term Strategic Fix:** | Standardize internal PKI certificate automation (ACME/step-ca) across all web services. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |

| | |
|---|---|
| **Verification & Closure Rule:** | Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-76: HTTP Technology Stack Disclosure ('X-Powered-By' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XPOWEREDBY \| Advisory: PHP expose_php=Off Hardening Guideline \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web application discloses backend runtime versions (e.g., 'X-Powered-By: PHP/5.2.4-2ubuntu5.10') in HTTP response headers. |
| **Security Risk:** | LOW — Reveals exact application framework version to aid targeted exploit selection. |
| **EvidenceCore V3 Record:** | ID: PROV-F-76-EFEC47D1D0 \| SHA-256: efec47d1d0c5ada5e6e86851... \| HMAC-SHA256: 5394fa10034effa354ea9111... \| Module: AutoPentest-ZAP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-76):**

```
The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers.
Access to such information may facilitate attackers identifying other frameworks/components your
---
X-Powered-By: PHP/5.2.4-2ubuntu5.10 | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Set `expose_php = Off` in `/etc/php5/apache2/php.ini` and add `Header unset X-Powered-By` in Apache configuration. |
| **Short-Term Hardening:** | Audit application middleware to suppress framework version headers (`X-AspNet-Version`, `X-Generator`). |
| **Long-Term Strategic Fix:** | Enforce header stripping at the edge reverse proxy. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `X-Powered-By` header is completely absent. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `X-Powered-By` header is completely absent.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-77: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-DIR-LISTING \| Advisory: Apache Options -Indexes Hardening Guideline \| CWE: CWE-548 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-548 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.139:80/icons/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks). |
| **Security Risk:** | LOW — Enables unauthenticated enumeration of static and backup files. |
| **EvidenceCore V3 Record:** | ID: PROV-F-77-3EFEE9B1FC \| SHA-256: 3efee9b1fcc53b893b2e97fc... \| HMAC-SHA256: 5dae0bb233b91efde5f952b5... \| Module: XStrike-BuiltinVuln |

**Captured Technical Evidence (F-77):**

```
Sensitive path accessible: /icons/

Evidence: HTTP 200 on http://192.168.195.139:80/icons/
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`. |
| **Short-Term Hardening:** | Remove default Apache `/icons/` alias or restrict it to specific file extensions. |
| **Long-Term Strategic Fix:** | Enforce `Options -Indexes` in baseline web server hardening templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-78: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: 80) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XCTO-MISSING \| Advisory: OWASP Secure Headers Project — X-Content-Type-Options \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 3 raw observation(s) across 3 unique endpoint(s): 192.168.195.139, 192.168.195.139:80, http://192.168.195.139:80/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types. |
| **Security Risk:** | LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content. |
| **EvidenceCore V3 Record:** | ID: PROV-F-78-D09020B64D \| SHA-256: d09020b64d59fb302c5fcbc9... \| HMAC-SHA256: 9a9c4cb14a1b08457fa78792... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-78):**

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.139:80 missing x-content-type-options header
---
Missing header: X-Content-Type-Options | CWE: CWE-693 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`). |
| **Short-Term Hardening:** | Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers. |

| | |
|---|---|
| **Long-Term Strategic Fix:** | Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-79: Developer / Debugging Comments Exposed in HTML/JS Source [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-ZAP-COMMENTS \| Advisory: OWASP ZAP Alert 10027 — Information Disclosure: Suspicious Comments \| CWE: CWE-615 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-615 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=90% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=90% (Det=96%, Val=92%, Art=75%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTML and JavaScript responses contain developer comments that may disclose internal application logic, hints, or endpoints. |
| **Security Risk:** | LOW — Information disclosure in client-accessible markup. |
| **EvidenceCore V3 Record:** | ID: PROV-F-79-5E0AECD466 \| SHA-256: 5e0aecd46690374f359a8173... \| HMAC-SHA256: 13b1a604d6804bf47f8465b3... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-79):**

```
The response appears to contain suspicious comments which may help an attacker.
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Strip developer, TODO, and debugging HTML/JS comments from production templates in `/var/www/`. |
| **Short-Term Hardening:** | Audit client-side HTML and JavaScript files to ensure no hints, credentials, or internal SQL queries are embedded in comments. |
| **Long-Term Strategic Fix:** | Add HTML/JS minification that strips comments in the build pipeline. |

| | |
|---|---|
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect page source via `curl -s` and confirm developer/debugging comments are removed. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect page source via `curl -s` and confirm developer/debugging comments are removed.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-80: HTTP Permissions-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-PERMISSIONS-POLICY \| Advisory: W3C Permissions Policy Specification \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 (Protection Mechanism Failure) \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Permissions-Policy' (formerly Feature-Policy) header, leaving browser APIs (camera, microphone, geolocation, payment) unrestricted at the document policy layer. |
| **Security Risk:** | LOW — Defense-in-depth browser hardening omission; does not directly enable remote code execution. |
| **EvidenceCore V3 Record:** | ID: PROV-F-80-3C0FFD8E56 \| SHA-256: 3c0ffd8e564e847275ee781d... \| HMAC-SHA256: f5cc36c90e93a901b74918a6... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-80):**

```
Missing header: Permissions-Policy | CWE: CWE-732 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Add `Header always set Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=(), usb=()"` in the web server configuration. |
| **Short-Term Hardening:** | Audit frontend application requirements and explicitly disable all unused browser hardware/sensor APIs. |
| **Long-Term Strategic Fix:** | Enforce `Permissions-Policy` alongside CSP in automated HTTP security header regression tests. |

| | |
|---|---|
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm the `Permissions-Policy` header is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-81: HTTP Referrer-Policy Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-REFERRER-POLICY \| Advisory: W3C Referrer Policy / OWASP Secure Headers \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit the 'Referrer-Policy' header, which may cause full URLs (including query parameters) to be leaked in the Referer header during cross-origin navigation. |
| **Security Risk:** | LOW — Potential disclosure of sensitive URL paths or query parameters to third-party origins. |
| **EvidenceCore V3 Record:** | ID: PROV-F-81-8BCA01910E \| SHA-256: 8bca01910e45e67605d98edd... \| HMAC-SHA256: 0bd66216998668d1677e9c65... \| Module: AutoPentest-AegisProbe |

**Captured Technical Evidence (F-81):**

```
Missing header: Referrer-Policy | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Add `Header always set Referrer-Policy "strict-origin-when-cross-origin"` in Apache `/etc/apache2/conf.d/security` or Nginx configuration. |
| **Short-Term Hardening:** | Ensure sensitive tokens or session identifiers are never passed in URL query strings where they could leak via Referer headers. |
| **Long-Term Strategic Fix:** | Include `Referrer-Policy` in baseline web security header automated tests. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |

| | |
|---|---|
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Referrer-Policy: strict-origin-when-cross-origin` is returned.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-82: HTTP Server Banner Version Disclosure ('Server' Header) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-SERVER-BANNER \| Advisory: Apache ServerTokens Prod / CIS Web Server Hardening \| CWE: CWE-200 \| MITRE: T1592 (Reconnaissance — Gather Victim Host Information) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-200 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 34 raw observation(s) across 3 unique endpoint(s): 192.168.195.140, http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | The web server discloses exact software and OS release identifiers (e.g., 'Apache/2.2.8 (Ubuntu) DAV/2') in the HTTP 'Server' response header across multiple endpoints. |
| **Security Risk:** | LOW — Facilitates precise vulnerability fingerprinting by external adversaries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-82-96A1A192A3 \| SHA-256: 96a1a192a30115280aeb44c9... \| HMAC-SHA256: e4a9fc5be13b60e15b5aa54f... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-82):**

```
The web/application server is leaking version information via the "Server" HTTP response header. Access
to such information may facilitate attackers identifying other vulnerabilities your web/applicat
---
Server header exposes version: Apache-Coyote/1.1

Evidence: Server: Apache-Coyote/1.1
---
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1
mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4
Perl/v5.10.1 | CWE: CWE-200 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Set `ServerTokens Prod` and `ServerSignature Off` in Apache `/etc/apache2/apache2.conf` and reload Apache (`service apache2 reload`). |

| | |
|---|---|
| **Short-Term Hardening:** | Configure reverse-proxy header sanitization to strip detailed upstream server version banners. |
| **Long-Term Strategic Fix:** | Maintain automated configuration management to prevent verbose banner headers in production. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and confirm `Server: Apache` returns no version or OS string.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-83: HTTP Strict-Transport-Security (HSTS) Header Missing [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-HSTS-MISSING \| Advisory: RFC 6797 / OWASP HTTP Strict Transport Security Cheat Sheet \| CWE: CWE-319 \| MITRE: T1557 (Credential Access — Adversary-in-the-Middle) \| Taxonomy: OWASP-A02:2021 (Cryptographic Failures) \| CWE-319 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 6 raw observation(s) across 4 unique endpoint(s): 192.168.195.140:8080, 192.168.195.140, http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP/HTTPS responses omit the 'Strict-Transport-Security' header, allowing clients to connect over unencrypted HTTP and exposing sessions to SSL-stripping attacks. |
| **Security Risk:** | LOW — Enables protocol downgrade and cleartext session interception on untrusted networks. |
| **EvidenceCore V3 Record:** | ID: PROV-F-83-0D060299D4 \| SHA-256: 0d060299d4754260145eca84... \| HMAC-SHA256: 9c53840559841536217cf11a... \| Module: XStrike-BuiltinVuln, AutoPentest-OWASP, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-83):**

```
No HSTS header — susceptible to SSL stripping attacks

Evidence: HTTP response from 192.168.195.140:8080 missing strict-transport-security header
---
A02 Cryptographic Failures: 1 finding(s)
[CWE-693] Missing Security Headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options
---
Missing header: Strict-Transport-Security | CWE: CWE-319 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Configure TLS (HTTPS) on port 443 and add `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"` to the HTTPS virtual host. |
| **Short-Term Hardening:** | Configure HTTP port 80 to issue permanent `301 Moved Permanently` redirects to `https://` for all endpoints. |
| **Long-Term Strategic Fix:** | Standardize internal PKI certificate automation (ACME/step-ca) across all web services. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect HTTPS response headers via `curl -I https://<target>/` and confirm `Strict-Transport-Security` is returned with `max-age>=31536000`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-84: Session Cookie Missing 'HttpOnly' Flag [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-COOKIE-HTTPONLY \| Advisory: OWASP Session Management Cheat Sheet — HttpOnly \| CWE: CWE-1004 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-1004 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Cookies are set without the 'HttpOnly' flag, permitting client-side JavaScript ('document.cookie') to read session identifiers. |
| **Security Risk:** | LOW — Enables session theft if combined with a Cross-Site Scripting (XSS) vulnerability. |
| **EvidenceCore V3 Record:** | ID: PROV-F-84-29FCC5B7B6 \| SHA-256: 29fcc5b7b604e3b51d512c9f... \| HMAC-SHA256: dc2680feeef2b7e6b3acd708... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-84):**

```
A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by
JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Set `session.cookie_httponly = 1` in `/etc/php5/apache2/php.ini` and add `HttpOnly` to all application `setcookie()` calls. |
| **Short-Term Hardening:** | Add Apache header rewrite `Header edit Set-Cookie ^(.*)$ "$1; HttpOnly"` for legacy applications. |
| **Long-Term Strategic Fix:** | Enforce automated DAST checks verifying `HttpOnly` on all session identifiers. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie: PHPSESSID=...` via `curl -I` and confirm the `HttpOnly` flag is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-85: Session Cookie Missing 'SameSite' Attribute [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-COOKIE-SAMESITE \| Advisory: RFC 6265bis — SameSite Cookie Attribute \| CWE: CWE-352 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A01:2021 (Broken Access Control) \| CWE-352 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 10 raw observation(s) across 1 unique endpoint(s): 192.168.195.140 |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Session cookies are issued without the 'SameSite=Lax' or 'SameSite=Strict' attribute, allowing cookies to be transmitted in cross-origin requests. |
| **Security Risk:** | LOW — Weakens browser defense against Cross-Site Request Forgery (CSRF). |
| **EvidenceCore V3 Record:** | ID: PROV-F-85-35B82920C6 \| SHA-256: 35b82920c6606a7bc4d4eab0... \| HMAC-SHA256: 6d2e1179d33d2cdbc06e4903... \| Module: AutoPentest-ZAP |

**Captured Technical Evidence (F-85):**

```
A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-sit
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |

| | |
|---|---|
| **Immediate Containment:** | Update PHP/application session configuration (`session.cookie_samesite = "Lax"` or `"Strict"`) or add Apache `Header edit Set-Cookie ^(.*)$ "$1; SameSite=Lax"`. |
| **Short-Term Hardening:** | Audit cross-site authentication flows and enforce `SameSite=Strict` on high-privilege session cookies. |
| **Long-Term Strategic Fix:** | Standardize session management using framework-managed `__Host-` prefixed cookies. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Inspect `Set-Cookie` via `curl -I` and confirm `SameSite=Lax` or `SameSite=Strict` is present.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-86: Web Server Directory Listing Enabled (/icons/ & Static Directories) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-WEB-DIR-LISTING \| Advisory: Apache Options -Indexes Hardening Guideline \| CWE: CWE-548 \| MITRE: T1083 (Discovery — File and Directory Discovery) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-548 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 1 raw observation(s) across 1 unique endpoint(s): http://192.168.195.140:80/images/: |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | Web server directories (such as /icons/) return an auto-generated directory index listing internal files (consolidated with OWASP A05 misconfiguration checks). |
| **Security Risk:** | LOW — Enables unauthenticated enumeration of static and backup files. |
| **EvidenceCore V3 Record:** | ID: PROV-F-86-F7405A8098 \| SHA-256: f7405a809831e470664bdebc... \| HMAC-SHA256: c79f35c5467a549bde2241bb... \| Module: AutoPentest-OWASP |

**Captured Technical Evidence (F-86):**

```
A05 Misconfiguration: 4 finding(s)
[CWE-548] Directory Listing: /images/: Full directory contents exposed
[CWE-548] Directory Listing: /icons/: Full directory contents exposed
[CWE-548] Directory Listing: /assets/: Full directory contents exposed
[CWE-693] HTTP TRACE Enabled: XST (Cross-Site Tracing) possible
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Disable directory indexing in Apache `/etc/apache2/apache2.conf` and `/etc/apache2/mods-enabled/alias.conf` by setting `Options -Indexes` on `/var/www/` and `/usr/share/apache2/icons/`. |
| **Short-Term Hardening:** | Remove default Apache `/icons/` alias or restrict it to specific file extensions. |
| **Long-Term Strategic Fix:** | Enforce `Options -Indexes` in baseline web server hardening templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Request `http://192.168.195.139:80/icons/` and confirm HTTP 403 Forbidden instead of `Index of /icons`.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-87: X-Content-Type-Options Header Missing (MIME-Sniffing Exposure) [LOW · CVSS 3.1 · VALIDATED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: 80, 8080) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | VALIDATED (Legacy Tier: VALIDATED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: SAFE_PROBE_EXECUTED \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: CONFIGURATION_WEAKNESS \| Privilege: NONE \| DataAccess: METADATA_OR_HEADERS_ONLY \| Impact: DEFENSE_IN_DEPTH_DEGRADATION \| EvidenceConf: 94% |
| **Access Scope Summary:** | Technical configuration, protocol flag, or HTTP response header/cookie directly validated |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-HDR-XCTO-MISSING \| Advisory: OWASP Secure Headers Project — X-Content-Type-Options \| CWE: CWE-693 \| MITRE: T1190 (Initial Access — Exploit Public-Facing Application) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-693 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=95% \| ExploitabilityConf=25% \| ImpactConf=30% \| 5-D Vector: EvidenceConf=95% (Det=96%, Val=92%, Art=100%) \| ExploitabilityConf=25% \| ImpactConf=30% \| FP Band: Tier 2 — Deterministically Validated by Protocol/HTTP Response (Exploitability Separate) |
| **Deduplication & Endpoints:** | Consolidated 10 raw observation(s) across 4 unique endpoint(s): 192.168.195.140, 192.168.195.140:8080, http://192.168.195.140:80/, http://192.168.195.140:8080/ |
| **Root Cause & Compliance:** | Web Server & HTTP Security Header Hardening Gap [DIRECTLY_ESTABLISHED] \| Compliance Status: EVIDENCE_OF_CONTROL_FAILURE |
| **Technical Description:** | HTTP responses omit 'X-Content-Type-Options: nosniff', allowing browsers to MIME-sniff response bodies into executable content types. |
| **Security Risk:** | LOW — Browser MIME-type guessing can facilitate content-spoofing or stored XSS in uploaded content. |
| **EvidenceCore V3 Record:** | ID: PROV-F-87-E03141C86C \| SHA-256: e03141c86c71ae2d3f7a3525... \| HMAC-SHA256: aed52f3ddbf49efa1d24c7a6... \| Module: AutoPentest-ZAP, XStrike-BuiltinVuln, AutoPentest-AegisProbe |

**Captured Technical Evidence (F-87):**

```
The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older
versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially cau
```

```
---
No X-Content-Type-Options header — MIME sniffing not prevented

Evidence: HTTP response from 192.168.195.140:8080 missing x-content-type-options header
---
Missing header: X-Content-Type-Options | CWE: CWE-693 | Payload:
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Add `Header always set X-Content-Type-Options "nosniff"` in the web server configuration (`apache2.conf` / `nginx.conf`). |
| **Short-Term Hardening:** | Ensure all static and dynamic responses set explicit, accurate `Content-Type` MIME headers. |
| **Long-Term Strategic Fix:** | Include `X-Content-Type-Options: nosniff` in baseline infrastructure-as-code web templates. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/apache2/apache2.conf` and `/etc/php5/apache2/php.ini` (`cp -p /etc/apache2/apache2.conf /etc/apache2/apache2.conf.bak`), run `apache2ctl configtest` before reload, and restore `.bak` if HTTP 500 regressions occur. |
| **Verification & Closure Rule:** | Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `curl -I http://<target>/` and verify `X-Content-Type-Options: nosniff` is present on all responses.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-88: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.130 (Ports: N/A) \| Asset Class: Workstation / SMB Peer Host (STANDARD) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-SMB-ENUM-SURFACE \| Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration \| CWE: CWE-287 \| MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-287 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.130:139, 192.168.195.130:445 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure. |
| **Security Risk:** | LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries. |

| | |
|---|---|
| **EvidenceCore V3 Record:** | ID: PROV-F-88-9DBBE1849F \| SHA-256: 9dbbe1849f89072deeca1dc8... \| HMAC-SHA256: 26d76460ec018378a14bc3ec... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-88):**

```
SMB Enum: Nmap scan report for 192.168.195.130
Host is up (0.00s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:73:FE:EC (VMware)

Host script results:
|_smb-os-discovery: ERROR: Script execution failed (use -d to debug)
|_smb-enum-users: ERROR: Script execution failed (use -d to debug)
|_smb-enum-shares: ERR
---
SMB Enum: Nmap scan report for 192.168.195.130
Host is up (0.00088s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:73:FE:EC (VMware)

Host script results:
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
|_smb-enum-users: ERROR: Script execution f
```

| | |
|---|---|
| **Target Environment Profile:** | LAN Endpoint (192.168.195.130:80) |
| **Immediate Containment:** | Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`. |
| **Short-Term Hardening:** | Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall. |
| **Long-Term Strategic Fix:** | Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-89: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.139 (Ports: N/A) \| Asset Class: Multi-Role Application & Database Server (CROWN_JEWEL) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |

| | |
|---|---|
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-SMB-ENUM-SURFACE \| Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration \| CWE: CWE-287 \| MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-287 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.139:139, 192.168.195.139:445 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure. |
| **Security Risk:** | LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-89-03970C9D18 \| SHA-256: 03970c9d1849fe3eb5d8ab08... \| HMAC-SHA256: 85e6bfa83eb5d4f64e9c6e1a... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-89):**

```
SMB Enum: Nmap scan report for 192.168.195.139
Host is up (0.00013s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:05:D7:6A (VMware)

Host script results:
|_smb-os-discovery: ERROR: Script execution failed (use -d to debug)
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
|_smb-enum-groups:
---
SMB Enum: Nmap scan report for 192.168.195.139
Host is up (0.00s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:05:D7:6A (VMware)

Host script results:
|_smb-enum-users: ERROR: Script execution failed (use -d to debug)
|_smb-enum-shares: ERROR: Script execution fail
```

| | |
|---|---|
| **Target Environment Profile:** | Ubuntu 8.04 LTS (Linux 2.6.24-16-server, dpkg/apt, Apache 2.2.8, OpenSSH 4.7p1, PostgreSQL 8.3.1, Samba 3.0.20) |
| **Immediate Containment:** | Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`. |
| **Short-Term Hardening:** | Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall. |
| **Long-Term Strategic Fix:** | Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |

| | |
|---|---|
| **Verification & Closure Rule:** | Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

## F-90: SMB NetBIOS/CIFS Service Enumeration Surface (Ports 139/445) [LOW · CVSS 3.1 · OBSERVED]

| | |
|---|---|
| **Target Asset & Port:** | 192.168.195.140 (Ports: N/A) \| Asset Class: Application & Web Middleware Server (HIGH_VALUE) |
| **Proof State & Scope:** | OBSERVED (Legacy Tier: OBSERVED) \| Privilege: NONE \| Auth: False \| File: NONE \| DB: NONE \| Privesc Lifecycle: NOT_APPLICABLE_NON_PRIVESC |
| **7-D Proof Vector (V3):** | Execution: BANNER_ONLY \| Auth: UNAUTHENTICATED_PROBE \| Exploitability: UNVERIFIED_CANDIDATE \| Privilege: NONE \| DataAccess: SERVICE_BANNER_ONLY \| Impact: EXPOSURE_ONLY \| EvidenceConf: 42% |
| **Access Scope Summary:** | Service version or banner matched to known vulnerability; active exploitation not demonstrated in this record |
| **Taxonomy & CVSS v3.1:** | CVE: N/A \| Custom ID: XSTRIKE-SMB-ENUM-SURFACE \| Advisory: CIS Benchmark — Restrict Anonymous SMB/NetBIOS Enumeration \| CWE: CWE-287 \| MITRE: T1021.002 (Lateral Movement — Remote Services: SMB/Windows Admin Shares) \| Taxonomy: OWASP-A05:2021 (Security Misconfiguration) \| CWE-287 \| Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N |
| **Separated Confidence (V3):** | EvidenceConf=48% \| ExploitabilityConf=15% \| ImpactConf=22% \| 5-D Vector: EvidenceConf=48% (Det=86%, Val=25%, Art=45%) \| ExploitabilityConf=15% \| ImpactConf=22% \| FP Band: Tier 3 — Unverified Banner/Port Heuristic (Manual Verification Required) |
| **Deduplication & Endpoints:** | Consolidated 2 raw observation(s) across 2 unique endpoint(s): 192.168.195.140:139, 192.168.195.140:445 |
| **Root Cause & Compliance:** | Network Segmentation & Perimeter Filter Exposure [INFERRED] \| Compliance Status: POTENTIAL_CONTROL_WEAKNESS |
| **Technical Description:** | SMB ports 139/445 were probed via Nmap NSE (smb-enum-shares, smb-enum-users). Script output did not return unauthenticated share contents or user RIDs; classified as OBSERVED service exposure. |
| **Security Risk:** | LOW (OBSERVED) — Exposed SMB enumeration surface; restrict anonymous/null session queries. |
| **EvidenceCore V3 Record:** | ID: PROV-F-90-FBCDC04736 \| SHA-256: fbcdc047367e848acd619275... \| HMAC-SHA256: ce91b53766dfa861502666ca... \| Module: AutoPentest-Exploit |

**Captured Technical Evidence (F-90):**

```
SMB Enum: Nmap scan report for 192.168.195.140
Host is up (0.00088s latency).

PORT STATE SERVICE
139/tcp open netbios-ssn
MAC Address: 00:0C:29:86:5E:7D (VMware)

Host script results:
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
---
SMB Enum: Nmap scan report for 192.168.195.140
Host is up (0.00s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds
MAC Address: 00:0C:29:86:5E:7D (VMware)

Host script results:
```

```
|_smb-enum-shares: ERROR: Script execution failed (use -d to debug)
```

| | |
|---|---|
| **Target Environment Profile:** | Linux Middleware Host (Apache Tomcat/Jetty :8080/:8081, SMB :445) |
| **Immediate Containment:** | Restrict anonymous/null SMB sessions by setting `restrict anonymous = 2` and `map to guest = Never` in `/etc/samba/smb.conf`, then reload `smbd`. |
| **Short-Term Hardening:** | Block TCP ports 139 and 445 from untrusted internal subnets at the host firewall. |
| **Long-Term Strategic Fix:** | Audit all Samba/Windows shares to ensure explicit group ACLs are required for share enumeration. |
| **Approval & Change Window:** | Scheduled Maintenance Window + Peer Configuration Review (14–30 Day SLA) |
| **Backup & Rollback Plan:** | Backup `/etc/samba/smb.conf` (`cp -p /etc/samba/smb.conf /etc/samba/smb.conf.bak`) or Windows Registry `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` prior to disabling SMBv1; restore backup and restart `smbd`/`LanmanServer` if legacy clients fail. |
| **Verification & Closure Rule:** | Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected. \| EVIDENCE_BASED_CLOSURE_ONLY: Finding remains OPEN until an automated XStrike re-test executes `Run `rpcclient -U "" -N <target>` and `smbclient -L //<target>/ -N` and verify anonymous enumeration is rejected.`, captures a signed SHA-256/HMAC negative-control transcript, and transitions proof_state to REMEDIATION_VERIFIED. |

# 3B. Consolidated Reconnaissance & Attack Surface Inventory (R-01 through R-26)

To prevent reconnaissance telemetry from inflating vulnerability or confirmed-exploitation counts, all **26 consolidated surface discovery groups** (representing **690** raw discovery observations, including `ZAP: User Agent Fuzzer`, `ZAP: Modern Web Application`, `JavaScript Source File Discovered`, `Postfix SMTP Banner`, `Open Port`, and `Host Discovered` records) are isolated below with `Proof State = DISCOVERED` and `CVSS = 0.0`.

| Recon ID | Host | Canonical Discovery Class | Normalized Title | Raw Observations Consolidated | Unique Endpoints / Ports | Provenance ID |
|---|---|---|---|---|---|---|
| R-01 | 192.168.195.1 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 1 | 1 | PROV-R-01-4DF732E1A8 |
| R-02 | 192.168.195.1 | RECON_CRED_SURFACE | Authentication Service Surface Identified (FTP/SSH/SMB) | 1 | 1 | PROV-R-02-498CF90543 |
| R-03 | 192.168.195.1 | RECON_WEB_SURFACE | HTTP/HTTPS Web Application Surface & Endpoints Enumerated | 2 | 2 | PROV-R-03-93757138F6 |
| R-04 | 192.168.195.1 | RECON_ZAP_MODERN_WEB_APP | OWASP ZAP Informational Telemetry: Modern Web Application Fingerprinted | 95 | 1 | PROV-R-04-2514D97FFD |
| R-05 | 192.168.195.1 | RECON_ZAP_USER_AGENT_FUZZER | OWASP ZAP Informational Telemetry: User-Agent Response Differential Probe | 444 | 1 | PROV-R-05-4C2218D36A |
| R-06 | 192.168.195.1 | RECON_OPEN_PORT | Open Network Service Port Enumerated | 16 | 16 | PROV-R-06-062135D8C7 |
| R-07 | 192.168.195.129 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 1 | 1 | PROV-R-07-332D21C307 |
| R-08 | 192.168.195.129 | RECON_OPEN_PORT | Open Network Service Port Enumerated | 2 | 2 | PROV-R-08-A576618718 |
| R-09 | 192.168.195.130 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 1 | 1 | PROV-R-09-B269E35E96 |
| R-10 | 192.168.195.130 | RECON_CRED_SURFACE | Authentication Service Surface Identified (FTP/SSH/SMB) | 1 | 1 | PROV-R-10-45753A0067 |
| R-11 | 192.168.195.130 | RECON_OPEN_PORT | Open Network Service Port Enumerated | 4 | 4 | PROV-R-11-B4D9725EAD |
| R-12 | 192.168.195.131 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 1 | 1 | PROV-R-12-A33B5ED1ED |
| R-13 | 192.168.195.139 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 2 | 1 | PROV-R-13-279CDB8950 |
| R-14 | 192.168.195.139 | RECON_CRED_SURFACE | Authentication Service Surface Identified (FTP/SSH/SMB) | 1 | 1 | PROV-R-14-DFC555AA54 |

| Recon ID | Host | Canonical Discovery Class | Normalized Title | Raw Observations Consolidated | Unique Endpoints / Ports | Provenance ID |
|---|---|---|---|---|---|---|
| R-15 | 192.168.195.139 | RECON_JS_ASSET | Client-Side JavaScript Source Asset Enumerated | 5 | 5 | PROV-R-15-3852261785 |
| R-16 | 192.168.195.139 | RECON_WEB_SURFACE | HTTP/HTTPS Web Application Surface & Endpoints Enumerated | 2 | 2 | PROV-R-16-07846EFC59 |
| R-17 | 192.168.195.139 | RECON_OPEN_PORT | Open Network Service Port Enumerated | 24 | 24 | PROV-R-17-55A5019535 |
| R-18 | 192.168.195.139 | RECON_SMTP_BANNER | Postfix SMTP Service Banner Enumerated (Port 25) | 1 | 1 | PROV-R-18-5C22434893 |
| R-19 | 192.168.195.140 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 2 | 1 | PROV-R-19-4EF5E83C8A |
| R-20 | 192.168.195.140 | RECON_CRED_SURFACE | Authentication Service Surface Identified (FTP/SSH/SMB) | 1 | 1 | PROV-R-20-609DA36E96 |
| R-21 | 192.168.195.140 | RECON_JS_ASSET | Client-Side JavaScript Source Asset Enumerated | 15 | 15 | PROV-R-21-FC27E5E434 |
| R-22 | 192.168.195.140 | RECON_WEB_SURFACE | HTTP/HTTPS Web Application Surface & Endpoints Enumerated | 6 | 6 | PROV-R-22-AB79FC6262 |
| R-23 | 192.168.195.140 | RECON_ZAP_MODERN_WEB_APP | OWASP ZAP Informational Telemetry: Modern Web Application Fingerprinted | 4 | 1 | PROV-R-23-B0CB13465D |
| R-24 | 192.168.195.140 | RECON_ZAP_USER_AGENT_FUZZER | OWASP ZAP Informational Telemetry: User-Agent Response Differential Probe | 48 | 1 | PROV-R-24-54884FB1B4 |
| R-25 | 192.168.195.140 | RECON_OPEN_PORT | Open Network Service Port Enumerated | 9 | 9 | PROV-R-25-0C24F8EACE |
| R-26 | 192.168.195.254 | RECON_HOST_DISCOVERED | Active Network Host Discovered (ICMP/ARP/TCP Probe) | 1 | 1 | PROV-R-26-9EC1080559 |

# 4. Four-Stage Evidence-Backed Attack Graph V3, 5-State Taxonomy & Choke-Point Analysis

**Path Count Reconciliation:** The raw graph generator enumerated 101 port-level path permutations (0 high/critical permutations across open ports). AttackGraph V3/V4 deduplicated these by underlying CVE/CWE and per-edge proof state into 6 distinct attack chains: 3 EXECUTED (2 Full Root Compromises on 192.168.195.139 + 1 DB Superuser Auth), 2 PARTIALLY_VALIDATED, and 1 INFERRED_NOT_EXECUTED, plus 2 BLOCKED_BY_CONTROLS host paths and 3 NOT_TESTED_BY_SAFETY_ROE payloads, governed by 5 remediation choke points and exported to Neo4j Cypher.

**Attack Path Priority Score Formula (0–100 Priority Index, Not Statistical Exploitation Probability):**

```
AttackPathPriorityScore(C) = min(100, round(BaseCVSS * 6.0 * W_exec + ImpactBonus + HopBonus)) [0-100 Priority Index, not statistical probability], where W_exec = 1.00 (Confirmed Full Root Compromise), 0.90 (Confirmed DB/Service Authentication), 0.70-0.85 (Partially Validated Foothold/Precondition), 0.35 (Inferred Port-Open Candidate), or 0.00 (Blocked by Controls).
```

| Chain ID | Attack Chain Name | Target Host(s) | Validation State | 7-Metric Path Vector (Feas / Conf / Priv / Imp / Hops / Lev) | Attack Path Priority Score |
|---|---|---|---|---|---|
| CHAIN-01 | vsFTPd 2.3.4 Backdoor -> Unauthenticated Root Shell -> /etc/shadow Dump | 192.168.195.139 | CONFIRMED_EXECUTED | Feas:0.99 \| Conf:99.0% \| Priv:ROOT (uid=0) \| Imp:CROWN_JEWEL_HOST_TAKEOVER \| Hops:4 \| Lev:9 raw paths broken by stopping vsFTPd / blocking TCP 21 & 6200 chains | 100/100 (P0_IMMEDIATE) |
| CHAIN-02 | Ingreslock TCP/1524 Bindshell -> Unauthenticated Root Shell -> Credential Extraction | 192.168.195.139 | CONFIRMED_EXECUTED | Feas:0.99 \| Conf:99.0% \| Priv:ROOT (uid=0) \| Imp:CROWN_JEWEL_HOST_TAKEOVER \| Hops:4 \| Lev:8 raw paths broken by killing /bin/sh on TCP 1524 & disabling inetd chains | 100/100 (P0_IMMEDIATE) |
| CHAIN-03 | SSH Default Credentials (uid=1000) -> Validated SUID Nmap / DirtyCow PrivEsc -> Local Root | 192.168.195.139 | PARTIALLY_VALIDATED | Feas:0.88 \| Conf:88.0% \| Priv:USER (uid=1000) -> Projected ROOT (uid=0) \| Imp:PRIVILEGE_ESCALATION_TO_ROOT \| Hops:4 \| Lev:7 raw paths + FTP/SSH credential reuse broken by rotating msfadmin & removing SUID bits chains | 76/100 (P1_HIGH) |
| CHAIN-04 | PostgreSQL 5432 Default Superuser (postgres:postgres) -> DB Catalog Read Access | 192.168.195.139 | CONFIRMED_EXECUTED | Feas:0.95 \| Conf:95.0% \| Priv:DB_SUPERUSER (postgres) \| Imp:RELATIONAL_DATABASE_COMPROMISE \| Hops:4 \| Lev:5 raw DB paths broken by rotating postgres password & binding 5432 to localhost chains | 78/100 (P0_IMMEDIATE) |
| CHAIN-05 | NFS Export Surface & Web SQLi / DVWA -> Inferred Filesystem/DB Takeover | 192.168.195.139 | PARTIALLY_VALIDATED | Feas:0.78 \| Conf:83.0% \| Priv:WEB_APP_DB_READ -> Projected FILESYSTEM_ACCESS \| Imp:APPLICATION_AND_DATA_EXPOSURE \| Hops:4 \| Lev:5 raw paths broken by stopping nfs-kernel-server & parameterizing SQL queries chains | 63/100 (P1_HIGH) |

| Chain ID | Attack Chain Name | Target Host(s) | Validation State | 7-Metric Path Vector (Feas / Conf / Priv / Imp / Hops / Lev) | Attack Path Priority Score |
|---|---|---|---|---|---|
| CHAIN-06 | Internal Subnet SMB Port 445 Exposure -> Theoretical Lateral Movement (Unverified) | 192.168.195.1, 192.168.195.130, 192.168.195.140 | INFERRED_NOT_EXECUTED | Feas:0.25 \| Conf:30.0% \| Priv:NONE (Port-Open Candidate Only) \| Imp:POTENTIAL_LATERAL_MOVEMENT \| Hops:2 \| Lev:63 raw port permutations broken by disabling SMBv1 & enforcing SMB signing chains | 19/100 (P2_MEDIUM) |

## 4.1 Five-State Attack Path Classification Model (Executed vs Validated vs Inferred vs Blocked vs Safety-RoE Held)

| Path Classification State | Count | Chain IDs & W_exec Weight | Technical Definition & Execution Boundary |
|---|---|---|---|
| EXECUTED_PATHS | 3 | CHAIN-01 (vsFTPd Root), CHAIN-02 (Ingreslock Root), CHAIN-04 (PostgreSQL Superuser Auth) [W_exec = 1.00 (Full OS Compromise: CHAIN-01, CHAIN-02) \| W_exec = 0.90 (Confirmed DB Superuser Auth: CHAIN-04)] | End-to-end command execution or database superuser authentication verified with captured session transcript. |
| PARTIALLY_VALIDATED_PATHS | 2 | CHAIN-03 (SSH uid=1000 + SUID/DirtyCow Vector), CHAIN-05 (NFS Export + Web SQLi/DVWA) [W_exec = 0.85 (Authenticated Shell + Validated PrivEsc Precondition) \| W_exec = 0.70 (Validated Surface)] | Initial foothold or vulnerability precondition validated, while destructive final escalation/write was withheld. |
| INFERRED_PATHS | 1 | CHAIN-06 (Internal Subnet SMB Port 445 Lateral Movement Candidate) [W_exec = 0.35 (Port-Open / Protocol Exposure Candidate Only)] | Theoretical multi-host pivot inferred from open SMB ports (139/445); lateral exploitation NOT verified or executed. |
| BLOCKED_BY_CONTROLS_PATHS | 2 | 192.168.195.131 & 192.168.195.254 (0 Open TCP Ports / Host Firewall Filtered) [W_exec = 0.00 (Blocked at Network/Transport Layer)] | Target endpoints discovered via ARP/DHCP where host firewall or service filtering blocked all TCP connection attempts. |
| NOT_TESTED_BY_SAFETY_ROE_PATHS | 3 | DirtyCow Kernel Race Execution (CVE-2016-5195), Active MS17-010 Kernel Payload, Destructive SQL/NFS Writes [W_exec = N/A (Restricted by Mandatory Authorization & RoE Safety Policy Engine)] | Techniques intentionally withheld by the XStrike Safety Policy Engine to prevent kernel panic, data corruption, or denial of service. |

## 4.2 Four-Stage Attack Graph Edge Provenance Table

| Stage | Source -> Target Node | MITRE Technique | Finding & Provenance Ref | Validation State | Conf |
|---|---|---|---|---|---|
| S1: Initial Access | Assessor (192.168.195.130) -> 192.168.195.139:21 (vsFTPd 2.3.4) | T1190: Exploit Public-Facing Service (FTP Banner & USER Trigger) | F-02 (PROV-F-02-97A9FA7E47) | CONFIRMED_EXECUTED | 99% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.139:21 -> 192.168.195.139:6200 (Backdoor Shell) | T1059.004: CVE-2011-2523 Backdoor Listener Activation | F-02 (PROV-F-02-97A9FA7E47) | CONFIRMED_EXECUTED | 99% |
| S3: Privilege Escalation | 192.168.195.139:6200 -> root@192.168.195.139 (uid=0) | T1068: Direct Daemon Root Execution (uid=0(root) Inherited) | F-02 (PROV-F-02-97A9FA7E47) | CONFIRMED_EXECUTED | 99% |
| S4: Target Impact | root@192.168.195.139 (uid=0) -> 192.168.195.139 (/etc/shadow & Full Host Control) | T1003.008: OS Credential Dumping (/etc/shadow & Crown-Jewel DB Host Takeover) | F-02 (PROV-F-02-97A9FA7E47) | CONFIRMED_EXECUTED | 99% |
| S1: Initial Access | Assessor (192.168.195.130) -> 192.168.195.139:1524 (ingreslock) | T1190: Connect to Exposed TCP Port 1524 Bind Shell | F-01 (PROV-F-01-424450284F) | CONFIRMED_EXECUTED | 99% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.139:1524 -> /bin/sh Interactive Session | T1059.004: Unauthenticated Unix Shell Execution (Consolidated with rsh/1524 probe) | F-01 (PROV-F-01-424450284F) | CONFIRMED_EXECUTED | 99% |
| S3: Privilege Escalation | /bin/sh Interactive Session -> root@192.168.195.139 (uid=0) | T1068: Root Context Pre-Established by Bindshell Daemon | F-01 (PROV-F-01-424450284F) | CONFIRMED_EXECUTED | 99% |
| S4: Target Impact | root@192.168.195.139 (uid=0) -> 192.168.195.139 (/etc/passwd, /etc/shadow & System Control) | T1003.008: Full Host Compromise & Credential Hash Extraction | F-01 (PROV-F-01-424450284F) | CONFIRMED_EXECUTED | 99% |
| S1: Initial Access | Assessor (192.168.195.130) -> 192.168.195.139:22 (OpenSSH 4.7p1) | T1078.001: Default Account Login (msfadmin:msfadmin) | F-05 (PROV-F-05-6715A75078) | CONFIRMED_EXECUTED | 95% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.139:22 -> msfadmin@192.168.195.139 (uid=1000) | T1021.004: Authenticated Non-Root Shell Session Established (uid=1000) | F-05 (PROV-F-05-6715A75078) | CONFIRMED_EXECUTED | 95% |
| S3: Privilege Escalation | msfadmin@192.168.195.139 (uid=1000) -> SUID /usr/bin/nmap & DirtyCow (CVE-2016-5195) Vector | T1548.001: Local Privilege Escalation Vector Validated (Not Triggered via SSH Session) | F-06 (PROV-F-06-E061A6DE7E) | PARTIALLY_VALIDATED | 88% |
| S4: Target Impact | SUID /usr/bin/nmap & DirtyCow (CVE-2016-5195) Vector -> root@192.168.195.139 (Projected Escalation) | T1068: Local Root Compromise via nmap --interactive !sh | F-06 (PROV-F-06-E061A6DE7E) | INFERRED_NOT_EXECUTED | 84% |
| S1: Initial Access | Assessor (192.168.195.130) -> 192.168.195.139:5432 (PostgreSQL 8.3.1) | T1190: Network Connection to Exposed PostgreSQL Port 5432 | F-03 (PROV-F-03-5EBB5E02B0) | CONFIRMED_EXECUTED | 95% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.139:5432 -> postgres@192.168.195.139:5432 | T1078.001: Default Superuser Authentication (postgres:postgres) | F-03 (PROV-F-03-5EBB5E02B0) | CONFIRMED_EXECUTED | 95% |

| Stage | Source -> Target Node | MITRE Technique | Finding & Provenance Ref | Validation State | Conf |
|---|---|---|---|---|---|
| S3: Privilege Escalation | postgres@192.168.195.139:5432 -> PostgreSQL Superuser Role (rolsuper=true) | T1078: Database Superuser Context Granted on Login | F-03 (PROV-F-03-5EBB5E02B0) | CONFIRMED_EXECUTED | 95% |
| S4: Target Impact | PostgreSQL Superuser Role (rolsuper=true) -> pg_catalog / template1 / postgres Databases | T1005: Authenticated Database Schema & Catalog Enumeration | F-03 (PROV-F-03-5EBB5E02B0) | CONFIRMED_EXECUTED | 95% |
| S1: Initial Access | Assessor (192.168.195.130) -> 192.168.195.139:2049 (NFS) & :80 (HTTP) | T1190: RPC/NFS Export Mount Discovery & HTTP Parameter Fuzzing | F-41 (PROV-F-41-EF854751D1) | CONFIRMED_EXECUTED | 92% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.139:2049 & :80 -> Exported NFS Share & Mutillidae SQLi / DVWA Admin | T1190: Validated NFS Export Surface & Web SQLi / Default Creds | F-08 (PROV-F-08-9CC3744D82) | PARTIALLY_VALIDATED | 88% |
| S3: Privilege Escalation | Exported NFS Share -> Root Filesystem Write / SSH authorized_keys Injection | T1098.004: Inferred NFS Mount Modification (Not Mounted Destructively) | F-41 (PROV-F-41-EF854751D1) | INFERRED_NOT_EXECUTED | 78% |
| S4: Target Impact | Root Filesystem Write / SSH authorized_keys Injection -> 192.168.195.139 (Projected Host Takeover / DB Extraction) | T1005: Inferred Full Filesystem Access & Backend Database Extraction | F-41 (PROV-F-41-EF854751D1) | INFERRED_NOT_EXECUTED | 75% |
| S1: Initial Access | 192.168.195.139 (Compromised Pivot) -> 192.168.195.1 / .130 / .140 (TCP Port 445) | T1046: Internal Subnet SMB Port 445 Discovery | F-56 (PROV-F-56-3EFCD4CA82) | CONFIRMED_EXECUTED | 90% |
| S2: Credential / Vulnerability Exploitation | 192.168.195.1 / .130 / .140 (TCP Port 445) -> Unverified SMBv1 / Lateral Movement Candidate | T1210: Theoretical Lateral Exploitation (NOT Verified / NOT Executed) | F-56 (PROV-F-56-3EFCD4CA82) | INFERRED_NOT_EXECUTED | 25% |

## 4.3 AttackGraph V3 Remediation Choke-Point Analysis (Maximum Chain Disruption)

| Choke-Point ID | Remediation Control & Target Node | Finding Ref | Chains Broken | Risk Score Reduction | SLA Priority |
|---|---|---|---|---|---|
| CP-01 | Isolate 192.168.195.139 & Terminate Backdoor Daemons (192.168.195.139 (TCP/21, TCP/6200, TCP/1524)) — Stop vsFTPd 2.3.4 (:21/:6200) & kill /bin/sh on Ingreslock (:1524) | F-01, F-02 | 2 (CHAIN-01, CHAIN-02) | -44.0 pts | P0_IMMEDIATE (0–24h) |
| CP-02 | Rotate Default Accounts & Enforce SSH Public-Key Auth (192.168.195.139 (TCP/22, TCP/21, TCP/5432, HTTP /dvwa/)) — Rotate postgres, msfadmin (SSH/FTP), and DVWA admin credentials; disable anonymous FTP | F-03, F-04, F-05, F-19 | 2 (CHAIN-03, CHAIN-04) | -20.0 pts | P0_IMMEDIATE (0–24h) |
| CP-03 | Remove SUID Bits & Upgrade Legacy Linux 2.6.24 Kernel (192.168.195.139 (Local Privilege Escalation Surface)) — chmod u-s /usr/bin/nmap /bin/mount; upgrade kernel to remediate DirtyCow (CVE-2016-5195) | F-06, F-10, F-20 | 1 (CHAIN-03 (Stage 3->4 Escalation)) | -9.5 pts | P1_HIGH (7 Days) |

| Choke-Point ID | Remediation Control & Target Node | Finding Ref | Chains Broken | Risk Score Reduction | SLA Priority |
|---|---|---|---|---|---|
| CP-04 | Disable Unauthenticated NFS Exports & Parameterize SQL Queries (192.168.195.139 (TCP/111, TCP/2049, TCP/80)) — Stop nfs-kernel-server (:2049), restrict /etc/exports, and remediate Mutillidae SQLi (:80) | F-08 | 1 (CHAIN-05) | -8.0 pts | P1_HIGH (7 Days) |
| CP-05 | Disable SMBv1 Dialect & Enforce Mandatory SMB Signing (192.168.195.1, .130, .139, .140 (TCP/445)) — Disable SMBv1 protocol and require SMB2/3 packet signing across all subnet hosts | F-11 | 1 (CHAIN-06) | -6.5 pts | P2_MEDIUM (7–30 Days) |

## 4.4 Neo4j Property Graph & Cypher Attack Chain Architecture (Strict Per-Edge Evidence Non-Inheritance)

Attack chains in XStrike V3/V4 are modeled as a directed property graph compatible with **Neo4j 5.x Property Graph + OpenGraph (BloodHound-Compatible) Export** (38 unique graph nodes and 22 typed attack-stage relationships). Crucially, the graph enforces the **Strict Non-Inheritance Invariant**: **ChainState(C) = min_{e in E(C)} EdgeState(e) — A chain with any PARTIALLY_VALIDATED or INFERRED_NOT_EXECUTED hop can NEVER be labeled CONFIRMED_EXECUTED.** — an executed initial foothold (such as SSH `uid=1000` on `CHAIN-03` or NFS/SQLi discovery on `CHAIN-05`) never upgrades unexecuted downstream escalation or lateral hops to `CONFIRMED_EXECUTED`.

| Query ID | Analytical Graph Query Title | Security & Audit Purpose | Executable Neo4j Cypher Query |
|---|---|---|---|
| CYPHER-01 | Verified End-to-End Root Compromise Paths Only (Strict Edge-State Filter) | Returns only attack chains where EVERY hop in the path has validation_state = 'CONFIRMED_EXECUTED' (never inherits executed status onto inferred hops). | MATCH p = (src:XStrikeNode)-[:EXECUTED_COMPROMISE*1..4]->(dst:XStrikeNode) WHERE ALL(r IN relationships(p) WHERE r.validation_state = 'CONFIRMED_EXECUTED') AND dst.name CONTAINS 'uid=0' RETURN p, [r IN relationships(p) \| r.finding_id] AS findings, [r IN relationships(p) \| r.evidence_ref] AS proofs; |
| CYPHER-02 | Hybrid / Partially Validated Chains with Unexecuted Escalation or Pivot Hops | Identifies chains (such as CHAIN-03 SSH->SUID and CHAIN-05 NFS/SQLi) that start with an executed foothold but transition into a validated or inferred step. | MATCH p = (src:XStrikeNode)-[r1:EXECUTED_COMPROMISE]->(mid:XStrikeNode)-[r2:VALIDATED_PRECONDITION\|INFERRED_LATERAL_CANDIDATE*1..3]->(dst:XStrikeNode) RETURN r1.chain_id AS chain, mid.name AS foothold_boundary, [rel IN r2 \| rel.validation_state] AS downstream_states; |
| CYPHER-03 | Betweenness Centrality & Choke-Point Remediation ROI Ranking | Computes which remediation control node (e.g., 192.168.195.139:1524, :21, :22, :5432) severs the maximum number of active attack chains. | MATCH (s:XStrikeNode)-[r]->(t:XStrikeNode) RETURN r.finding_id AS finding_id, t.name AS choke_point_node, count(DISTINCT r.chain_id) AS chains_severed, collect(DISTINCT r.chain_id) AS chains ORDER BY chains_severed DESC; |

# 5. Verified Exploitation & 3-State Post-Exploitation Privilege Lifecycle Matrix

The table below distinguishes confirmed root shell compromises (`CONFIRMED_COMPROMISE`), confirmed default/anonymous credential logins (`CONFIRMED_AUTH`), and post-exploitation local privilege escalation vectors using XStrike V3's **3-State Post-Exploitation Privilege Transition Model** (`PRECONDITION_DISCOVERED`, `TECHNIQUE_VALIDATED`, `PRIVILEGE_TRANSITION_EXECUTED`). Because initial access via `F-01` (`:1524` Ingreslock) and `F-02` (`:21/:6200` vsFTPd) already yielded `uid=0(root)` on `192.168.195.139`, local privilege escalation vectors discovered from the `msfadmin` (`uid=1000`) SSH session were validated non-destructively without executing kernel-modifying payloads.

| Finding ID | Target Host:Port | Vulnerability / Vector | Proof State | Privilege Achieved | File / DB Access Scope | 3-State Privesc Lifecycle |
|---|---|---|---|---|---|---|
| F-01 | 192.168.195.139: | Ingreslock / Bindshell Unauthenticated Root Shell on TCP Port 1524 | CONFIRMED_COMPROMISE | ROOT (uid=0 / gid=0) | File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) \| DB: NONE | PRIVILEGE_TRANSITION_EXECUTED |
| F-02 | 192.168.195.139: | vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root Compromise (CVE-2011-2523) | CONFIRMED_COMPROMISE | ROOT (uid=0 / gid=0) | File: READ_CONFIRMED (/etc/shadow read via cat/head; write not executed per RoE) \| DB: NONE | PRIVILEGE_TRANSITION_EXECUTED |
| F-03 | 192.168.195.139: | PostgreSQL 8.3.1 Default Superuser Authentication (postgres:postgres) | CONFIRMED_AUTH | DB_SUPERUSER (postgres) | File: NONE \| DB: AUTHENTICATED_SCHEMA_READ (PostgreSQL 8.3.1 databases & pg_catalog tables enumerated) | TECHNIQUE_VALIDATED |
| F-04 | 192.168.195.139: | FTP Default Credential Authentication (msfadmin:msfadmin) | CONFIRMED_AUTH | STANDARD_USER (msfadmin) | File: READ_LIST (user directory listing verified; write not executed) \| DB: NONE | PRECONDITION_DISCOVERED |
| F-05 | 192.168.195.139: | SSH Default Credential Shell Access (msfadmin:msfadmin) | CONFIRMED_AUTH | STANDARD_USER (uid=1000 msfadmin, gid=1000) | File: READ_CONFIRMED (standard user home directory; write not executed per RoE) \| DB: NONE | PRECONDITION_DISCOVERED |

| Finding ID | Target Host:Port | Vulnerability / Vector | Proof State | Privilege Achieved | File / DB Access Scope | 3-State Privesc Lifecycle |
|---|---|---|---|---|---|---|
| F-06 | 192.168.195.139: | Local Privilege Escalation Vector: SUID Binary (/usr/bin/nmap) | EXPLOITABLE | LOCAL_ESCALATION_PRECONDITION (uid=1000 -> uid=0 via nmap --interactive) | File: READ_ONLY (/usr/bin/nmap SUID-root bit verified) \| DB: NONE | TECHNIQUE_VALIDATED |
| F-10 | 192.168.195.139: | Legacy Linux Kernel 2.6.24-16-server Vulnerable to DirtyCow (CVE-2016-5195) | VALIDATED | LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | File: NONE \| DB: NONE | PRECONDITION_DISCOVERED |
| F-19 | 192.168.195.139: | FTP Anonymous Authentication Enabled | CONFIRMED_AUTH | ANONYMOUS (ftp) | File: READ_ONLY_EMPTY (0 files in anonymous root; no sensitive files exfiltrated) \| DB: NONE | NOT_APPLICABLE_NON_PRIVESC |
| F-20 | 192.168.195.139: | Local Privilege Escalation Vector: SUID Binary (/bin/mount) | VALIDATED | LOCAL_ESCALATION_VECTOR (uid=1000 -> uid=0 potential) | File: NONE \| DB: NONE | PRECONDITION_DISCOVERED |

## 6. Four-Tier Evidence-Driven Compliance Control Mapping

Instead of marking every scanner observation as a `NON-COMPLIANT` audit failure, Engine 07 classifies each finding into one of four evidence-backed compliance states: `CONFIRMED_COMPLIANCE_DEFICIENCY` (backed by active compromise or credential auth), `EVIDENCE_OF_CONTROL_FAILURE` (backed by validated technical proof), `POTENTIAL_CONTROL_WEAKNESS` (backed by observed banner/port exposure), or `TECHNICAL_OBSERVATION` (reconnaissance telemetry).

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-01 | Ingreslock / Bindshell Unauthenticated Root S | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Direct exploitation/authentication proof (CONFIRMED_COMPROMISE) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-02 | vsFTPd 2.3.4 Smiley-Face Backdoor Remote Root | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Direct exploitation/authentication proof (CONFIRMED_COMPROMISE) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |
| F-03 | PostgreSQL 8.3.1 Default Superuser Authentica | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Direct exploitation/authentication proof (CONFIRMED_AUTH) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |
| F-04 | FTP Default Credential Authentication (msfadm | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Direct exploitation/authentication proof (CONFIRMED_AUTH) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |
| F-05 | SSH Default Credential Shell Access (msfadmin | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Direct exploitation/authentication proof (CONFIRMED_AUTH) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-06 | Local Privilege Escalation Vector: SUID Binar | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 7.2.2 (Assign Privileges Based on Job Function / Least Privilege) \| NIST 800-53 AC-6 (Least Privilege) | ISO 27001:2022 A.8.2 (Privileged Access Rights) \| CIS Control 5.4 & 6.8 (Restrict Administrator Privileges) | Deterministic HTTP/protocol validation (EXPLOITABLE) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-07 | DVWA Web Application Default Administrative C | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-08 | Web Application SQL Injection Indicator (Muti | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) \| NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation) | ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) \| CIS Control 16.12 (Implement Code-Level Security Checks) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-09 | DVWA Web Application Default Administrative C | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.140. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-10 | Legacy Linux Kernel 2.6.24-16-server Vulnerab | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-11 | Deprecated SMBv1 Dialect Enabled on SMB Servi | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) \| NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection) | ISO 27001:2022 A.8.24 (Use of Cryptography) \| CIS Control 3.10 (Encrypt Sensitive Data in Transit) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-12 | Web Application Server-Side Request Forgery ( | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) \| NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation) | ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) \| CIS Control 16.12 (Implement Code-Level Security Checks) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-13 | Deprecated SMBv1 Dialect Enabled on SMB Servi | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) \| NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection) | ISO 27001:2022 A.8.24 (Use of Cryptography) \| CIS Control 3.10 (Encrypt Sensitive Data in Transit) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.140. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-14 | SMB Message Signing Not Required (NTLM Relay | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) \| NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection) | ISO 27001:2022 A.8.24 (Use of Cryptography) \| CIS Control 3.10 (Encrypt Sensitive Data in Transit) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-15 | Cleartext Telnet Service Enabled on TCP Port | POTENTIAL_CONTROL_WEAKNESS | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) \| NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection) | ISO 27001:2022 A.8.24 (Use of Cryptography) \| CIS Control 3.10 (Encrypt Sensitive Data in Transit) | Service port or version banner exposure observed; requires host configuration verification to confirm compliance failure. [Limitation: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.] |
| F-16 | End-of-Life Apache HTTP Server 2.2.8 Deployed | POTENTIAL_CONTROL_WEAKNESS | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Service port or version banner exposure observed; requires host configuration verification to confirm compliance failure. [Limitation: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.] |
| F-17 | End-of-Life Apache HTTP Server 2.2.8 Deployed | POTENTIAL_CONTROL_WEAKNESS | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Service port or version banner exposure observed; requires host configuration verification to confirm compliance failure. [Limitation: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.] |
| F-18 | PHP-CGI Argument Injection Candidate (CVE-201 | POTENTIAL_CONTROL_WEAKNESS | PCI-DSS v4.0 Req 6.2.4 & 6.4.1 (Prevent Injection, SSRF & Insecure Deserialization) \| NIST 800-53 SI-10 & SI-2 (Information Input Validation & Flaw Remediation) | ISO 27001:2022 A.8.26 & A.8.28 (Application Security Requirements & Secure Coding) \| CIS Control 16.12 (Implement Code-Level Security Checks) | Service port or version banner exposure observed; requires host configuration verification to confirm compliance failure. [Limitation: Banner/port observation only; cannot be cited as a confirmed audit non-conformity without authenticated configuration inspection.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-19 | FTP Anonymous Authentication Enabled | CONFIRMED_COMPLIANCE_DEFICIENCY | PCI-DSS v4.0 Req 2.2.2 & 8.2 (Default Accounts & Strong Authentication) \| NIST 800-53 IA-2, IA-5 & AC-3 (Identification, Authenticator Mgmt, Access Enforcement) | ISO 27001:2022 A.5.17 & A.8.5 (Authentication Information & Secure Authentication) \| CIS Control 4.7 & 5.2 (Manage Default Accounts & Use Unique Passwords) | Direct exploitation/authentication proof (CONFIRMED_AUTH) demonstrates an active failure of access control or system integrity on 192.168.195.139. [Limitation: Technical control failure confirmed on target asset; full regulatory audit determination also requires reviewing compensating network/organizational controls.] |
| F-20 | Local Privilege Escalation Vector: SUID Binar | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 7.2.2 (Assign Privileges Based on Job Function / Least Privilege) \| NIST 800-53 AC-6 (Least Privilege) | ISO 27001:2022 A.8.2 (Privileged Access Rights) \| CIS Control 5.4 & 6.8 (Restrict Administrator Privileges) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-21 | Client-Manipulable Session/Tracking Cookie Pa | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-22 | Content-Security-Policy (CSP) Header Not Set | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-23 | Missing Anti-Clickjacking Protection (X-Frame | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-24 | Session Cookie Missing 'Secure' Flag | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 2.2.7 & 4.2.1 (Encrypt Non-Console Admin Access & Strong Cryptography) \| NIST 800-53 SC-8 & SC-13 (Transmission Confidentiality & Cryptographic Protection) | ISO 27001:2022 A.8.24 (Use of Cryptography) \| CIS Control 3.10 (Encrypt Sensitive Data in Transit) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-25 | Verbose Application / Database Error Message | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-26 | Web Application Missing Anti-CSRF Tokens & Ha | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.1. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-27 | Content-Security-Policy (CSP) Header Not Set | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.129. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-28 | Web Application Missing Anti-CSRF Tokens & Ha | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.129. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-29 | Content-Security-Policy (CSP) Header Not Set | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.130. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-30 | Web Application Missing Anti-CSRF Tokens & Ha | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.130. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-31 | Content-Security-Policy (CSP) Header Not Set | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-32 | DNS Open Recursion Enabled on ISC BIND 9.4.2 | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-33 | Missing Anti-Clickjacking Protection (X-Frame | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |
| F-34 | Web Application Missing Anti-CSRF Tokens & Ha | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.139. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

| ID | Finding Title | 4-Tier Compliance Status | PCI-DSS v4.0 / NIST 800-53 | ISO 27001:2022 & CIS v8 | Evidence Rationale & Assessment Limitation |
|---|---|---|---|---|---|
| F-35 | Content-Security-Policy (CSP) Header Not Set | EVIDENCE_OF_CONTROL_FAILURE | PCI-DSS v4.0 Req 1.2.1 & 2.2.1 (Configuration Standards & Network Service Restrictions) \| NIST 800-53 CM-6, CM-7 & RA-5 (Configuration Settings, Least Functionality, Vuln Monitoring) | ISO 27001:2022 A.8.8 & A.8.9 (Management of Technical Vulnerabilities & Configuration Mgmt) \| CIS Control 4.1 & 7.1 (Establish Secure Configurations & Vulnerability Management) | Deterministic HTTP/protocol validation (VALIDATED) confirms a technical control gap requiring remediation on 192.168.195.140. [Limitation: Demonstrates a specific technical sub-control deficiency; does not alone constitute a full-program compliance failure without scoping CDE/organizational boundaries.] |

# 7. Deduplicated Root-Cause Intelligence & Attribution Certainty

Root-cause distribution is computed strictly on the **90 deduplicated security vulnerabilities** (never on the 1,559 raw scanner alerts, which previously skewed 'Configuration Error' to 88.3%). Each root cause is paired with a 4-tier attribution certainty (`DIRECTLY_ESTABLISHED`, `PROBABLE`, `INFERRED`, `UNKNOWN`).

| Root-Cause Category | Deduplicated Findings | Share (%) | Directly Established | Probable / Inferred | Primary Remediation Owner |
|---|---|---|---|---|---|
| Web Server & HTTP Security Header Hardening Gap | 53 | 58.9% | 53 | 0 | Infrastructure / AppSec Team |
| Network Segmentation & Perimeter Filter Exposure | 13 | 14.4% | 0 | 13 | Infrastructure / AppSec Team |
| Identity & Credential Hygiene Deficiency | 6 | 6.7% | 6 | 0 | SecOps / Platform Engineering |
| Patch & Lifecycle Management Deficit (EOL Software) | 5 | 5.6% | 5 | 0 | Infrastructure / AppSec Team |
| Service Hardening & Configuration Baseline Gap | 5 | 5.6% | 0 | 5 | Infrastructure / AppSec Team |
| Insecure Application Coding (Input Validation) | 3 | 3.3% | 2 | 1 | Infrastructure / AppSec Team |
| Malicious Backdoor / Intentional Vulnerable Build | 2 | 2.2% | 2 | 0 | SecOps / Platform Engineering |
| Excessive Local Privilege / File Permission Misconfiguration | 2 | 2.2% | 2 | 0 | Infrastructure / AppSec Team |
| Access Control & Network Share Misconfiguration | 1 | 1.1% | 1 | 0 | Infrastructure / AppSec Team |

# 8. Prioritized Remediation Roadmap & Reproducible SLA Risk-Reduction Trajectory

The SLA Risk-Reduction Trajectory below is computed by re-running the 4-component Evidence-Weighted Risk Formula (`R = min(100, S_compromise + S_exposure + S_asset + S_reachability)`) after removing the findings remediated in each SLA window:

**Residual Architectural Risk Floor (`1.5/100` at Day 30 when `0` Active Findings Remain):** When all 85 active security findings are remediated (30-Day Forecast: 0 remaining findings), Active Vulnerability Risk drops to 0.0/100 (S_compromise=0.0, S_exposure=0.0). The 1.5/100 Projected Score represents the explicit Residual Architectural Risk Floor: S_asset=1.0 pt (intrinsic operational criticality of Crown-Jewel database/application host 192.168.195.139) + S_reachability=0.5 pt (baseline internal /24 LAN reachability prior to zero-trust micro-segmentation).

| SLA Phase | SLA Window | Remaining Findings | S_comp (45) | S_exp (25) | S_asset (15) | S_reach (15) | Active Vuln Risk | XStrike Risk Index (incl. Floor) |
|---|---|---|---|---|---|---|---|---|
| Current Baseline (T0 — Measured) | Immediate | 90 | 45.0 | 25.0 | 15.0 | 13.5 | 98.5/100 | 98.5/100 (-0.0%) |
| Phase 1 — Emergency Containment (Forecast) | 24 Hours | 87 | 15.0 | 25.0 | 15.0 | 9.0 | 64.0/100 | 64.0/100 (-35.0%) |

| SLA Phase | SLA Window | Remaining Findings | S_comp (45) | S_exp (25) | S_asset (15) | S_reach (15) | Active Vuln Risk | XStrike Risk Index (incl. Floor) |
|---|---|---|---|---|---|---|---|---|
| Phase 2 — High-Priority Hardening (Forecast) | 7 Days | 72 | 3.0 | 25.0 | 5.0 | 9.0 | 42.0/100 | 42.0/100 (-57.4%) |
| Phase 3 — Full Closure & Residual Floor (Forecast) | 30 Days | 0 | 0.0 | 0.0 | 1.0 | 0.5 | 0.0/100 | 1.5/100 (-98.5%) |

# 9. EvidenceCore V3 Cryptographic Manifest, SQLite Verifier & 18-Rule Quality Gate Attestation

To enable independent offline verification of every finding, command transcript, and provenance hash, **EvidenceCore V3** generates an HMAC-SHA256 signed evidence manifest, an OASIS SARIF v2.1.0 machine-verifiable bundle, and an independently verified 5-table SQLite database snapshot:

| | |
|---|---|
| **Manifest Version:** | EvidenceCore-V3.0 |
| **Assessment ID:** | XSTRIKE-V3-20261031 |
| **Total Signed Records:** | 116 (90 Security + 26 Recon) |
| **Manifest Root SHA-256:** | 7ea65d203a10fcc1bf25ec5f08ec294b73448e64648f47913c7ac4e55e58d202 |
| **Manifest HMAC-SHA256:** | 5965172dd811e3b694f4997c43479a7312baf9fa59e1ccce30a24d82daec718d |
| **Signing Key ID & Policy:** | XSTRIKE-V3-DEFAULT-KEY-01 \| 90-Day Automated Key Rotation with Per-Assessment Key ID Binding & Non-Repudiation Audit Log |
| **Independent Hash & HMAC Check:** | 116/116 SHA-256 Verified \| 116/116 HMAC-SHA256 Verified |
| **Integrity vs. Authenticity Scope:** | SHA-256 + HMAC-SHA256 proves post-capture immutability and database-to-PDF consistency; independent target authenticity requires raw PCAP/session-log co-signing or external witness attestation. |
| **Tamper-Detection Self-Test:** | PASSED (1-byte mutation immediately rejected by HMAC-SHA256 verifier) |
| **SQLite 5-Table Snapshot Audit:** | VERIFIED — 116/116 DB record hashes matched (v2_intelligence.db) |
| **Offline Verification CLI:** | python -m cyber_range.services.verify_manifest --manifest XStrike_Signed_Evidence_Manifest.json --db v2_intelligence.db |
| **OASIS SARIF v2.1.0 Bundle:** | 90 machine-verifiable results exported with 7-D proof vectors & provenance hashes |

Prior to generating this deliverable, **Engine 08 (ReportQualityEngine V3)** executed all **18 mandatory acceptance checks** (`AC-01` through `AC-18`) against the enriched finding dataset, cross-section transition table, attack graph, risk model, and SQLite snapshot. Overall Gate Status: **18 automated acceptance criteria passed out of 18 (18/18 PASSED)**.

| Rule ID | Quality Gate Verification Rule | Status | Verification Telemetry |
|---|---|---|---|
| AC-01 | Zero Unverified / Port-Open Findings Marked CONFIRMED | PASS | 0 violations across 116 findings |
| AC-02 | Repeated Web/Network Observations Consolidated with Endpoint Counts Preserved | PASS | 1835 target observations consolidated into 90 security findings + 26 recon items |
| AC-03 | Zero Title / Description / CWE / CVE / MITRE Semantic Mismatches | PASS | 100% semantic alignment across all findings |
| AC-04 | 7-Dimensional Proof Vector & Granular Access Scope Separation | PASS | All findings carry 7-D proof vectors (Execution, Auth, Exploitability, Privilege, DataAccess, Impact, EvidenceConf) |
| AC-05 | Per-Host Asset Classification & Classification Source/Confidence | PASS | 0 misclassified non-DB hosts; 7 hosts reconciled with explicit classification_source & confidence |
| AC-06 | Reconnaissance & Telemetry Separated from Security Vulnerabilities | PASS | 26 recon items isolated in Section 3B with CVSS 0.0 and DISCOVERED state |
| AC-07 | Separated Confidence Model (EvidenceConf vs ExploitabilityConf vs ImpactConf) | PASS | All findings separate Evidence Confidence from Exploitability Confidence and Impact Confidence |
| AC-08 | AttackGraph V3: 4-Stage Provenance, 7 Path Metrics & Choke-Point Analysis | PASS | 6 chains, 22 edges, and 5 remediation choke points |

| Rule ID | Quality Gate Verification Rule | Status | Verification Telemetry |
|---|---|---|---|
| AC-09 | RiskEngine V3: 4-Component Score, Calibrated Exposure & SLA Trajectory | PASS | Baseline 98.5 -> 24h (64.0) -> 7d (42.0) -> 30d (1.5) |
| AC-10 | Root-Cause Analysis Computed on Deduplicated Findings with 4-Tier Certainty | PASS | Root cause computed on 90 deduplicated findings (not raw scanner volume) |
| AC-11 | 100% Vulnerability-Specific Remediation Guidance (Zero Generic Fallbacks) | PASS | 0 generic fallback remediations across 116 findings |
| AC-12 | 4-Tier Evidence-Driven Compliance Mapping with Rationale | PASS | All findings mapped to PCI-DSS v4.0, NIST 800-53, ISO 27001, and CIS Controls with 4-tier status |
| AC-13 | EvidenceCore V3: 10-Control Provenance & HMAC-SHA256 Integrity Signatures | PASS | 100% of findings (116) bound to SHA-256 + HMAC-SHA256 signed provenance records |
| AC-14 | Strict CVE Syntax (^CVE-YYYY-NNNN+$) & Specific CWE Mapping (Zero CWE-16) | PASS | 0 custom IDs in CVE field; 0 generic CWE-16 placeholders across all security findings |
| AC-15 | Strict NVD CVSS v3.1 Score-to-Severity Band Alignment | PASS | 100% CVSS-to-Severity alignment across 90 security findings |
| AC-16 | Endpoint Hygiene (Zero w3.org/nmap.org URLs) & Zero Generic OWASP Rollups | PASS | 0 external reference URLs in affected_endpoints; 0 generic OWASP A01..A10 rollup rows |
| AC-17 | Cross-Section Finding ID Reconciliation & 3-State Privesc Lifecycle Model | PASS | 100% cross-section ID alignment (Phase 3A=['F-03', 'F-04', 'F-05', 'F-19'], Phase 3B=['F-01', 'F-02'], Phase 4=['F-06', 'F-10', 'F-20']) |
| AC-18 | Independent Cryptographic (SHA-256 / HMAC / Merkle) & SQLite Snapshot Verification | PASS | Verified 116/116 SHA-256 & HMAC signatures, Merkle root, tamper self-test, and 116 SQLite records |

# 10. XStrike V3 Autonomous Architecture & Unified TrePath v7.0 Integration

The tables below summarize the five core XStrike V3 autonomous capabilities operational in this assessment and how **TrePath v7.0** (Web/API DAST) and **XStrike V3** (Network, Host, Exploitation & Post-Exploitation) operate together on the shared EvidenceCore V3 intelligence layer:

| Capability ID | XStrike V3 Autonomous Capability | Status | Technical Summary |
|---|---|---|---|
| CAP-01 | Rules-of-Engagement (RoE) & Safety Policy Engine | OPERATIONAL (v3.0) | Enforces CIDR scope boundaries, per-technique exploit allowlists, DoS/crash prevention gates (holding MS17-010 and Dirty COW in non-destructive states), and read-only command whitelists. |
| CAP-02 | Session-Aware Post-Exploitation Collector | OPERATIONAL (v3.0) | Collects structured OS, kernel, interface, SUID, NFS export, and DB catalog telemetry from established sessions using a 3-State Privilege Escalation Lifecycle (PRECONDITION_DISCOVERED, TECHNIQUE_VALIDATED, PRIVILEGE_TRANSITION_EXECUTED). |
| CAP-03 | Cross-Host Pivot & Trust-Relationship Validator | OPERATIONAL (v3.0) | Maps SSH key reuse, NFS no_root_squash exports, database credential reuse, and SMB lateral paths across the 5-State Attack Path Taxonomy (EXECUTED, PARTIALLY_VALIDATED, INFERRED, BLOCKED_BY_CONTROLS, NOT_TESTED_BY_SAFETY_ROE). |

| Capability ID | XStrike V3 Autonomous Capability | Status | Technical Summary |
|---|---|---|---|
| CAP-04 | Cryptographic Evidence Bundle & SQLite Verifier | OPERATIONAL (v3.0) | Generates tamper-evident SHA-256 + HMAC-SHA256 provenance records, Merkle root manifests, OASIS SARIF v2.1.0 bundles, and independently verified 5-table SQLite snapshots. |
| CAP-05 | Automated Remediation Re-Test & Verification Loop | READY FOR RE-SCAN | Re-executes the exact deterministic proof command for each remediated finding (e.g., Ingreslock :1524, vsFTPd :21, PostgreSQL :5432) and transitions verified fixes to REMEDIATION_VERIFIED. |

| Architectural Dimension | TrePath v7.0 (Web & API DAST) | XStrike V3 (Network, Host & Post-Exploit) | Unified Platform Value |
|---|---|---|---|
| Primary Assessment Domain | Web Application & API DAST (HTTP/HTTPS, REST/GraphQL, OWASP Top 10:2025) | Autonomous Network, Host, Database, Exploitation & Post-Exploitation Engine | Full-stack L3–L7 coverage from network perimeter to web app & database internals |
| Validation & Proof Semantics | HTTP Request/Response Replay, DOM/Reflection Proof & Status Diffing | 7-State Proof Model + 3-State Privesc Lifecycle + Interactive Shell/Auth Transcripts | Zero unverified 'Confirmed' inflation across both web and infrastructure findings |
| Attack Graph & Choke Points | Application Endpoint & Auth-Bypass Dependency Chains | 5-State Multi-Hop Network/Host Attack Graph with Priority Index & Choke-Point ROI | End-to-end kill-chain modeling from web/network entry to Crown-Jewel data stores |
| Evidence Integrity & GRC Export | SHA-256 Evidence Hashing & OWASP/PCI/NIST Mapping | HMAC-SHA256 Signed Merkle Manifest + Independent SQLite Verifier + SARIF v2.1.0 | Cryptographically verifiable audit artifacts ready for CI/CD and enterprise GRC |

## 11. Sign-Off & Deliverables Attestation

**Lead Penetration Tester:** _____ Date: 2026-10-31

**Principal Security Architect (Quality Gate Reviewer):** _____ Date: 2026-10-31

**Client System Owner:** _____ Date: 2026-10-31